
INFORMATION SECURITY PROGRAM (ISP)

Internal Distribution

KAUFMAN | ROSSIN
cpa • advisors

Table of Contents

INFORMATION SECURITY PROGRAM (ISP) OVERVIEW	5
INTRODUCTION	5
PURPOSE	5
SCOPE & APPLICABILITY	6
POLICY OVERVIEW	6
VIOLATIONS	6
EXCEPTIONS	6
KEY TERMINOLOGY	7
INFORMATION SECURITY POLICY STRUCTURE	9
1.0 INFORMATION SECURITY PROGRAM POLICY	9
1.1 MANAGEMENT DIRECTION FOR INFORMATION SECURITY	9
1.2 MANAGEMENT DIRECTION FOR INFORMATION SECURITY	9
ORGANIZATION OF INFORMATION SECURITY - POLICY & STANDARDS	12
2.0 INFORMATION SECURITY ORGANIZATION POLICY	12
2.1 INTERNAL ORGANIZATION	12
HUMAN RESOURCE SECURITY - POLICY & STANDARDS	16
3.0 HUMAN RESOURCE SECURITY POLICY	16
3.1 PRIOR TO EMPLOYMENT	16
3.2 DURING EMPLOYMENT	16
3.3 TERMINATION AND CHANGE OF EMPLOYMENT	20
ASSET MANAGEMENT - POLICY & STANDARDS	22
4.0 ASSET MANAGEMENT POLICY	22
4.1 RESPONSIBILITY FOR ASSETS	22
4.2 INFORMATION CLASSIFICATION	24
4.3 MEDIA HANDLING	26
ACCESS CONTROL - POLICY & STANDARDS	28
5.0 ACCESS CONTROL POLICY	28
5.1 BUSINESS REQUIREMENTS OF ACCESS CONTROL	28
5.2 USER ACCESS MANAGEMENT	30
5.3 USER RESPONSIBILITIES	35
5.4 SYSTEM AND APPLICATION ACCESS CONTROL	36
ENCRYPTION - POLICY & STANDARDS	43
6.0 CRYPTOGRAPHY POLICY	43
6.1 CRYPTOGRAPHIC CONTROLS	43
PHYSICAL & ENVIRONMENTAL SECURITY - POLICY & STANDARDS	46
7.0 PHYSICAL AND ENVIRONMENTAL SECURITY POLICY	46
7.1 SECURE AREAS	46
7.2 EQUIPMENT	52
OPERATIONS SECURITY - POLICY & STANDARDS	59
8.0 OPERATIONS SECURITY POLICY	59
8.1 OPERATIONAL PROCEDURES AND RESPONSIBILITIES	59
8.2 PROTECTION FROM MALWARE	62
8.3 BACKUP	63
8.4 LOGGING AND MONITORING	66
8.5 CONTROL OF OPERATIONAL SOFTWARE	69
8.6 TECHNICAL VULNERABILITY MANAGEMENT	70
8.7 INFORMATION SYSTEMS AUDIT CONSIDERATIONS	73

COMMUNICATIONS SECURITY - POLICY & STANDARDS	74
9.0 COMMUNICATIONS SECURITY POLICY	74
9.1 NETWORK SECURITY MANAGEMENT	74
9.2 INFORMATION TRANSFER	78
SYSTEM ACQUISITION, DEVELOPMENT & MAINTENANCE - POLICY & STANDARDS	82
10.0 SYSTEM ACQUISITION, DEVELOPMENT AND MAINTENANCE POLICY	82
10.1 SECURITY REQUIREMENTS OF INFORMATION SYSTEMS	82
10.2 SECURITY IN DEVELOPMENT AND SUPPORT PROCESSES	83
VENDOR MANAGEMENT - POLICY & STANDARDS	90
11.0 SUPPLIER RELATIONSHIPS POLICY	90
11.1 INFORMATION SECURITY IN SUPPLIER RELATIONSHIPS	90
INCIDENT RESPONSE - POLICY & STANDARDS	93
12.0 INFORMATION SECURITY INCIDENT MANAGEMENT POLICY	93
12.1 MANAGEMENT OF INFORMATION SECURITY INCIDENTS AND IMPROVEMENTS	93
BUSINESS CONTINUITY MANAGEMENT - POLICY & STANDARDS	98
13.0 BUSINESS CONTINUITY MANAGEMENT POLICY	98
13.1 INFORMATION SECURITY CONTINUITY	98
13.2 REDUNDANCIES	100
INFORMATION SECURITY COMPLIANCE - POLICY & STANDARDS	102
14.0 COMPLIANCE POLICY	102
14.1 COMPLIANCE WITH LEGAL AND CONTRACTUAL REQUIREMENTS	102
14.2 INFORMATION SECURITY REVIEWS	107
APPENDICES	110
APPENDIX A: DATA CLASSIFICATION & HANDLING GUIDELINES	110
A-1: DATA CLASSIFICATION	110
A-2: GENERAL ASSUMPTIONS	111
A-3: PERSONALLY, IDENTIFIABLE INFORMATION (PII)	111
A-4: DATA HANDLING GUIDELINES	111
APPENDIX B: DATA CLASSIFICATION EXAMPLES	114
APPENDIX C: BASELINE SECURITY CATEGORIZATION GUIDELINES	115
C-1: DATA SENSITIVITY	115
C-2: SAFETY & CRITICALITY	115
C-3: BASIC ASSURANCE REQUIREMENTS	115
C-4: ENHANCED ASSURANCE REQUIREMENTS	115
APPENDIX D: INFORMATION SECURITY ROLES & RESPONSIBILITIES	116
D-1: INFORMATION SECURITY ROLES	116
D-2: INFORMATION SECURITY RESPONSIBILITIES	117
APPENDIX E: INFORMATION SECURITY EXCEPTION REQUEST PROCEDURES	120
APPENDIX F: TYPES OF SECURITY CONTROLS	122
F-1: PREVENTATIVE CONTROLS	122
F-2: DETECTIVE CONTROLS	122
F-3: CORRECTIVE CONTROLS	122
F-4: RECOVERY CONTROLS	122
F-5: DIRECTIVE CONTROLS	122
F-6: DETERRENT CONTROLS	122
F-7: COMPENSATING CONTROLS	122
APPENDIX G: RULES OF BEHAVIOR / USER ACCEPTABLE USE	124
G-1: ADDITIONAL RULES FOR SECURITY & PRIVILEGED USERS	124
APPENDIX H: SYSTEM HARDENING	126
H-1: SERVER-CLASS SYSTEMS	126
H-2: WORKSTATION-CLASS SYSTEMS	126

<i>H-3: NETWORK DEVICES</i>	<i>126</i>
<i>H-4: MOBILE DEVICES</i>	<i>126</i>
<i>H-5: DATABASES</i>	<i>127</i>
GLOSSARY: ACRONYMS & DEFINITIONS	128
ACRONYMS	128
DEFINITIONS	128
KEY WORD INDEX	129
RECORD OF CHANGES	130

INFORMATION SECURITY PROGRAM (ISP) OVERVIEW

Introduction

The Information Security Program (ISP) provides definitive information on the prescribed measures used to establish and enforce the IT security program at Kaufman Rossin & Co. (KR or Kaufman Rossin Group).

Note: The Kaufman Rossin Group consists of Kaufman Rossin CPAs and Advisors, a professional association providing accounting and advisory services; its wholly owned subsidiaries Kaufman Rossin Wealth, LLC, a Registered Investment Advisor, Kaufman Rossin Insurance Services, an insurance solutions provider, and Kaufman Rossin Registries, LLC, a registered agent; and its affiliated entity, Kaufman Rossin Alternative Investment Services, LLC, a full service fund administration provider.

KR is committed to protecting its employees, partners, clients and the firm as a whole from damaging acts that are intentional or unintentional. Effective security is a team effort involving the participation and support of every KR user who interacts with data and information systems. Therefore, it is the responsibility of every user to know these policies and to conduct their activities accordingly.

Protecting company information and the systems that collect, process, and maintain this information is of critical importance. Consequently, the security of information systems must include controls and safeguards to offset possible threats, as well as controls to ensure accountability, availability, integrity, and confidentiality of the data:

- Confidentiality – Confidentiality addresses preserving restrictions on information access and disclosure so that access is restricted to only authorized users and services.
- Integrity – Integrity addresses the concern that sensitive data has not been modified or deleted in an unauthorized and undetected manner.
- Availability – Availability addresses ensuring timely and reliable access to and use of information.

Security measures must be taken to guard against unauthorized access to, alteration, disclosure or destruction of data and information systems. This also includes against accidental loss or destruction.

Purpose

The purpose of the Information Security Program (ISP) is to prescribe a comprehensive framework for:

- Creating an Information Security Management System (ISMS) in accordance with ISO 27001.
- Protecting the confidentiality, integrity, and availability of KR data and information systems.
- Protecting KR, its employees, and its clients from illicit use of KR information systems and data.
- Ensuring the effectiveness of security controls over data and information systems that support KR's operations.
- Recognizing the highly networked nature of the current computing environment and provide effective company-wide management and oversight of those related Information Security risks.
- Providing for development, review, and maintenance of minimum-security controls required to protect KR's data and information systems.

The formation of the policies is driven by many factors, with the key factor being a risk. These policies set the ground rules under which KR operates and safeguards its data and information systems to both reduce risk and minimize the effect of potential incidents.

These policies, including their related standards, procedures, and guidelines, are necessary to support the management of information risks in daily operations. The development of policies provides due care to ensure KR users understand their day-to-day security responsibilities and the threats that could impact the firm.

Implementing consistent security controls across the firm will help KR comply with current and future legal obligations to ensure long term due diligence in protecting the confidentiality, integrity, and availability of KR data.

Scope & Applicability

These policies, standards, and procedures apply to all KR data, information systems, activities, and assets owned, leased, controlled, or used by KR, its agents, contractors, or other business partners on behalf of KR. These policies, standards, and procedures apply to all KR employees, contractors, sub-contractors, and their respective facilities supporting KR business operations, wherever KR data is stored or processed, including any third-party contracted by KR to handle, process, transmit, store, or dispose of KR data.

Some policies are explicitly stated for persons with a specific job function (e.g., a System Administrator); otherwise, all personnel supporting KR business functions shall comply with the policies. KR departments shall use these policies or may create a more restrictive policy, but not one that is less restrictive, less comprehensive, or less compliant than this policy.

These policies do not supersede any other applicable law, higher-level company directive or existing labor management agreement in effect as of the effective date of this policy.

Information security will be coordinated across different parts of the firm with relevant roles and job functions. Information security responsibilities will be clearly defined and communicated. Security of KR's information assets and information technology that are accessed, processed, communicated to, or managed by external parties will be maintained.

[Appendix D: Information Security Roles & Responsibilities](#) provides a detailed description of KR user roles and responsibilities, in regard to Information Security.

KR reserves the right to revoke, change, or supplement these policies, procedures, standards, and guidelines at any time without prior notice. Such changes shall be effective immediately upon approval by management, unless otherwise stated.

Policy Overview

In an effort to ensure an acceptable level of Information Security risk, KR is required to design, implement and maintain a coherent set of policies, standards, and procedures to manage risks to its data and information systems.

KR users are required to protect and ensure the Confidentiality, Integrity, and Availability (CIA) of data and information systems, regardless of how its data is created, distributed or stored. Security controls will be tailored accordingly so that cost-effective controls can be applied commensurate with the risk and sensitivity of the data and information system. Security controls must be designed and maintained to ensure compliance with all legal requirements.

Violations

Any KR user found to have violated any policy, standard or procedure may be subject to disciplinary action, up to and including termination of employment. Violators of local, state, Federal, and/or international law will be reported to the appropriate law enforcement agency for civil and/or criminal prosecution.

Exceptions

While every exception to a policy or standard potentially weakens protection mechanisms for KR information systems and underlying data, occasionally exceptions will exist. Procedures for requesting an exception to policies, procedures or standards are available in [Appendix E: Information Security Exception Request Procedures](#).

Key Terminology

In the realm of IT security terminology, the National Institute of Standards and Technology (NIST) IR 7298, Revision 1, *Glossary of Key Information Security Terms*, is the primary reference document that KR uses to define common IT security terms.¹ Key terminology to be aware of includes:

Data Security Steering Group: Responsible for information security in the firm, for reducing risk exposure, and for ensuring the firm's activities do not introduce undue risk to the enterprise. The group also is responsible for ensuring compliance with enterprise security policies, standards, and security initiatives, and with state and federal regulations.

Asset Custodian: A term describing a person or entity with the responsibility to assure that the assets are properly maintained, to assure that the assets are used for the purposes intended and assure that information regarding the equipment is properly documented.

Data Environment (CDE): A term describing the area of the network that possesses data or sensitive authentication data and those systems and segments that directly attach or support cardholder processing, storage, or transmission. Adequate network segmentation, which isolates systems that store, process, or transmit data from those that do not, may reduce the scope of the data environment and thus the scope of the PCI assessment

Control: A term describing any management, operational, or technical method that is used to manage risk. Controls are designed to monitor and measure specific aspects of standards to help KR accomplish stated goals or objectives. All controls map to standards, but not all standards map to Controls.

Control Applicability: A term describing the scope in which a control or standard is relevant and applicable.

Control Objective: A term describing targets or desired conditions to be met that are designed to ensure that policy intent is met. Where applicable, Control Objectives are directly linked to an industry-recognized leading practice to align KR with accepted due care requirements.

Data: A term describing an information resource that is maintained in electronic or digital format. Data may be accessed, searched, or retrieved via electronic networks or other electronic data processing technologies. [Appendix A: Data Classification & Handling Guidelines](#) provides guidance on data classification and handling restrictions.

Data Owner: A term describing a person or entity that has been given formal responsibility for the security of an asset, asset category, or the data hosted on the asset. It does not mean that the asset belongs to the owner in a legal sense. Asset owners are formally responsible for making sure that assets are secure while they are being developed, produced, maintained, and used.

Encryption: A term describing the conversion of data from its original form to a form that can only be read by someone that can reverse the encryption process. The purpose of encryption is to prevent unauthorized disclosure of data.

Guidelines: A term describing recommended practices that are based on industry-recognized leading practices. Unlike Standards, Guidelines allow users to apply discretion or leeway in their interpretation, implementation, or use.

Information Security: A term that covers the protection of information against unauthorized disclosure, transfer, modification, or destruction, whether accidental or intentional. The focus is on the Confidentiality, Integrity, and Availability (CIA) of data.

Information System: A term describing an asset; a system or network that can be defined, scoped, and managed. Includes, but is not limited to, computers, workstations, laptops, servers, routers, switches, firewalls, and mobile devices.

Least Privilege: A term describing the theory of restricting access by only allowing users or processes the least set of privileges necessary to complete a specific job or function.

¹ NIST IR 7298 - <http://nvlpubs.nist.gov/nistpubs/ir/2013/NIST.IR.7298r2.pdf>

Policy: A term describing a formally established requirement to guide decisions and achieve rational outcomes. Essentially, a policy is a statement of expectation that is enforced by standards and further implemented by procedures.

Procedure: A term describing an established or official way of doing something, based on a series of actions conducted in a certain order or manner. Procedures are the responsibility of the asset custodian to build and maintain, in support of standards and policies.

Sensitive Data: A term that covers categories of data that must be kept secure. Examples of sensitive data include Personally Identifiable Information, Electronic Protected Health Information (ePHI), and all other forms of data classified as Restricted or Confidential in [Appendix A: Data Classification & Handling Guidelines](#).

Sensitive Personally Identifiable Information (sPII): sPII is commonly defined as the first name or first initial and last name, in combination with any one or more of the following data elements: ²

- Social Security Number (SSN) / Taxpayer Identification Number (TIN) / National Identification Number (NIN)
- Driver License (DL) or another government-issued identification number (e.g., passport, permanent resident card, etc.)
- Financial account number
- Payment card number (e.g., credit or debit card)
- Any information regarding an individual's medical history, mental or physical condition, or medical treatment or diagnosis by a health care professional; or
- An individual's health insurance policy number or subscriber identification number and any unique identifier used by a health insurer to identify the individual.
- A username or e-mail address, in combination with a password or security question and answer that would permit access to an online account.

Standard: A term describing formally established requirements in regard to processes, actions, and configurations.

Target Audience: A term describing the intended group for which a control or standard is directed.

² The source of this definition comes from three state laws - Oregon Consumer Identity Theft Protection Act - ORS 646A.600(11)(a) - <http://www.leg.state.or.us/ors/646a.html> and Massachusetts 201 CMR 17.00" Standards For The Protection of Personal Information of Residents of The Commonwealth - MA201CMR17.02 <http://www.mass.gov/ocabr/docs/idtheft/201cmr1700reg.pdf> and Florida Protection Act - http://www.leg.state.fl.us/statutes/index.cfm?App_mode=Display_Statute&Search_String&URL=0500-0599/0501/Sections/0501.171.html

1.0 Information Security Program Policy

KR shall protect the confidentiality, integrity, and availability of its data and information systems, regardless of how its data is created, distributed, or stored. Security controls will be tailored accordingly so that cost-effective controls can be applied commensurate with the risk and sensitivity of the data and information system, in accordance with all legal obligations.

Management Intent: The purpose of this policy is for KR to specify the development, implementation, assessment, authorization, and monitoring of the IT security program. The successful implementation of security controls depends on the successful implementation of KR's program-level controls.

1.1 Management Direction for Information Security

The objective is to provide management direction and support for information security in accordance with business requirements and relevant laws and regulations.³

An Information Security Management System (ISMS) focuses on IT security management and IT-related risks. The governing principle behind KR's ISMS is that, as with all management processes, the ISMS must remain effective and efficient in the long-term, adapting to changes in the internal organization and external environment.

Information security documentation is comprised of five main parts:

- (1) Core policy that establishes management's intent;
- (2) Control objective that identifies the condition that should be met;
- (3) Standards that provides quantifiable requirements to be met;
- (4) Procedures that establish how tasks must be performed to meet the requirements established in standards; and
- (5) Guidelines are recommended, but not mandatory.

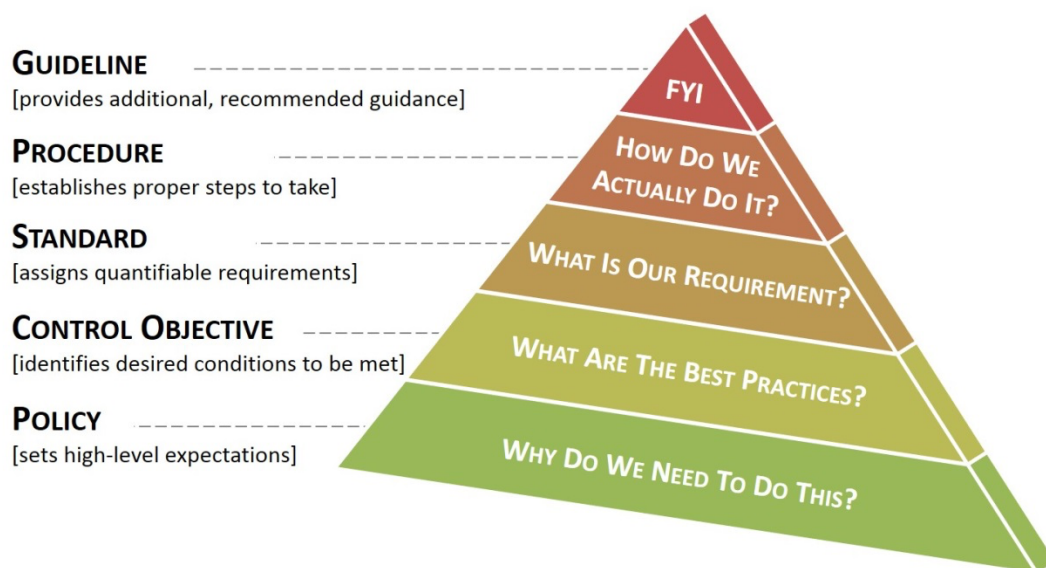


Figure 1.1: Information Security Documentation Framework

1.2 Management Direction for Information Security

A set of policies for information security should be defined, approved by management, published and communicated to employees and relevant external parties.⁴

³ ISO/IEC 27002:2013 – 5.1

⁴ ISO/IEC 27002:2013 – 5.1.1

1.2.1.1 PUBLISHING AN INFORMATION SECURITY POLICY

Control Objective: The firm establishes, publishes, maintains and disseminates a security policy.

Standard: KR's information security policies and standards shall be represented in a single document, the Information Security Program (ISP) that shall be:

- (a) Endorsed by executive management; and
- (b) Disseminated to the appropriate parties to ensure all KR personnel understand their applicable requirements.

Supplemental Guidance: A company's information security policy creates the roadmap for implementing security measures to protect its most valuable assets. All personnel should be aware of the sensitivity of data and their responsibilities for protecting it.

1.2.1.2 INFORMATION SECURITY PROGRAM PLAN

Control Objective: The firm:⁵

- Develops and disseminates organization-wide information security standards that:
 - Provides an overview of the requirements for the information security program and a description of the controls in place, or planned, for meeting those requirements;
 - Provides sufficient information about controls to enable an implementation that is unambiguously compliant with the intent of the plan;
 - Includes roles, responsibilities, management commitment, and compliance;
 - Is approved by senior management with responsibility and accountability for the risk being incurred to organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, and other organizations;
- Reviews standards for applicability; and
- Revises standards to address organizational changes and problems identified during implementation or security assessments.

Standard: KR's information security policies and standards shall be represented in a single document, the Information Security Program (ISP) that:

- (a) Shall be reviewed and updated at least annually; and
- (b) Disseminated to the appropriate parties to ensure all KR personnel understand their applicable requirements.

Supplemental Guidance: The security plans for individual information systems and the firm -wide information security program plan together, provide complete coverage for all security controls employed within the firm.

1.2.1.3 ASSIGNED INFORMATION SECURITY RESPONSIBILITIES

Control Objective: The firm appoints an individual assigned with the mission and resources to coordinate, develop, implement, and maintain an organization-wide information security program.⁶

Standard: The authority and responsibility for managing the information security program are delegated to KR's Chief Information Security Officer (CISO) and he/she is required to perform or delegate the following information security management responsibilities:

- (a) Establish, document, and distribute security policies and procedures;
- (b) Monitor and analyze security alerts and information;
- (c) Distribute and escalate security alerts to appropriate personnel;
- (d) Establish, document, and distribute security incident response and escalation procedures to ensure timely and effective handling of all situations;
- (e) Administer user accounts, including additions, deletions, and modifications; and
- (f) Monitor and control all access to data.

Supplemental Guidance: None

⁵ HIPAA 164.308(a)(1)(i) & 164.316(a)-(b) | GLBA Sec 6801(b)(1) | PCI DSS (v3.2) 12.1 & 12.1.1 | MA201CMR17 17.03(1), 17.04 & 17.03(2)(b)(2) | NIST Cybersecurity Framework ID.GV-1 & ID.GV-2

⁶ HIPAA 164.308(a)(2) | GLBA Safeguards Rule | PCI DSS (v3.2) 12.5-12.5.5 | MA201CMR17 17.03(2)(a) | OR646A.622(2)(d)(A)(i) | NIST Cybersecurity Framework ID.AM-6 & ID.GV-2

1.2.1.4 RISK MANAGEMENT

Control Objective: The firm implements a risk-assessment process.⁷

Standard: The CISO in conjunction with the asset custodians are required to implement a risk-assessment process that:

- (a) Is performed at least annually and upon significant changes to the environment (e.g., acquisition, merger, relocation);
- (b) Identifies critical assets, threats, and vulnerabilities; and
- (c) Results in a formal risk assessment.

1.2.2 REVIEW OF INFORMATION SECURITY POLICIES

The policies for information security should be reviewed at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy, and effectiveness.⁸

1.2.2.1 INFORMATION SECURITY DOCUMENTATION REVIEW

Control Objective: The firm reviews its information security policies, standards, and procedures at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.

Standard: At least annually, or as business needs exist, the Information Security Program (ISP) will be reviewed for applicability and updated accordingly.

Supplemental Guidance: Updates to the ISP will be announced to employees via management updates or email announcements. Changes will be noted in the [Record of Changes](#) to highlight the pertinent changes from the previous policies, procedures, standards and guidelines.

⁷ PCI DSS (v3.2) 12.2

⁸ ISO/IEC 27002:2013 – 5.1.2

2.0 Information Security Organization Policy

KR shall implement IT security program management controls to provide a foundation for KR's Information Security Management System (ISMS).

Management Intent: The purpose of this policy is for KR to specify the development, implementation, assessment, authorization, and monitoring of the IT security program. The successful implementation of security controls depends on the successful implementation of KR's program-level management controls.

2.1 Internal Organization

The objective of this section is to establish a management framework to initiate and control the implementation and operation of information security within the firm.⁹

2.1.1 INFORMATION SECURITY ROLES AND RESPONSIBILITIES

All information security responsibilities should be defined and allocated.¹⁰

2.1.1.1 ROLES & RESPONSIBILITIES

Control Objective: The firm defines information security responsibilities for all personnel.¹¹

Standard: The specific responsibilities of each of these roles are set out in Appendix E of this document. There are also particular information security responsibilities that must be carried out by existing roles within the firm and these are also set out within this document. The purpose of this section is to allocate the general areas of responsibility within the ISP to the specific information security roles within the firm.

Supplemental Guidance: Information Security roles and responsibilities are defined in [Appendix D: Information Security Roles & Responsibilities](#).

2.1.1.2 POSITION CATEGORIZATION

Control Objective: The firm:¹²

- Assigns a risk designation to all positions;
- Establishes screening criteria for individuals filling those positions; and
- Reviews and revises position risk designations.

Standard: Information Security Steering Group is responsible for assigning risk to job positions. Assigned risk is required to:

- (a) Be consistent with HR policy and guidance;
- (b) Include explicit information security role appointment requirements (e.g., training, responsibilities, etc.); and
- (c) Prevent personnel who do not have access to sensitive data from obtaining access to sensitive data.

Supplemental Guidance: [Appendix D: Information Security Roles & Responsibilities](#) provides a detailed description of IT security roles and responsibilities.

2.1.2 SEGREGATION OF DUTIES

Conflicting duties and areas of responsibility must be segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the firm's assets.¹³

⁹ ISO/IEC 27002:2013 – 6.1

¹⁰ ISO/IEC 27002:2013 – 6.1.1

¹¹ ISO/IEC 27002:2013 – 7.2 | PCI DSS (v3.2) 12.4 & 12.4.1

¹² HIPAA 164.308(a)(3)(i) & (ii) & (A) | NIST Cybersecurity Framework PR.IP-11

¹³ ISO/IEC 27002:2013 – 6.1.2

2.1.2.1 INCOMPATIBLE ROLES

Control Objective: The firm:

- Limits information system developer privileges to change hardware, software, and firmware components and system information within a production/operational environment; and
- Reviews and reevaluates information system developer privileges as necessary.

Standard: KR's management is required to:

- (a) Identify incompatible business roles; and
- (b) Implement steps to remediate incompatible business roles.

Supplemental Guidance: In permissible instances where business functions cannot be fully and appropriately segregated due to specific circumstances, management shall implement mitigating controls to compensate for such situations. Compensating controls in this arena might include read-only access, logs, dual authorization requirements, and documented reviews of input/output. Where adequate segregation cannot be achieved, other compensating controls must be established and documented.

2.1.3 EXTERNAL AUTHORITIES

The firm maintains appropriate contacts with relevant, external authorities.¹⁴

2.1.3.1 CONTACTS WITH AUTHORITIES

Control Objective: The firm identifies appropriate contacts with selected groups and associations within law enforcement and regulatory bodies.¹⁵

Standard: As part of KR's information security response capability, procedures must be in place that specifies when and by whom authorities (e.g., law enforcement, regulatory bodies, supervisory authorities) should be contacted and how identified information security incidents should be reported.

Supplemental Guidance: Contacts with other authorities include, but are not limited to:

- Law enforcement;
- Public utilities; and
- Telecommunication providers.

2.1.4 SPECIAL INTEREST GROUPS

Appropriate contacts with special interest groups or other specialist security forums and professional associations should be maintained.¹⁶

2.1.4.1 CONTACTS WITH SECURITY GROUPS & ASSOCIATIONS

Control Objective: The firm establishes and institutionalizes contact with selected groups and associations within the security community to:¹⁷

- Facilitate ongoing security education and training for organizational personnel;
- Maintain currency with recommended security practices, techniques, and technologies; and
- Share current security-related information including threats, vulnerabilities, and incidents.

Standard: The CISO and his/her designated representatives are responsible for establishing and maintaining formal contact with selected groups and/or associations within the security community.

Supplemental Guidance: Ongoing contact with security groups and associations is of paramount importance in an environment of rapidly changing technologies and threats. Security groups and associations include, but are not limited to, special interest groups, forums, professional associations, news groups, and/or peer groups of security professionals in similar organizations.

¹⁴ ISO/IEC 27002:2013 – 6.1.3

¹⁵ ISO/IEC 27002:2013 – 6.1.3

¹⁶ ISO/IEC 27002:2013 – 6.1.4

¹⁷ HIPAA 164.308(A)(5)(ii) & (ii)(A) | PCI DSS (v3.2) 5.1.2 & 6.1 | NIST Cybersecurity Framework ID.RA-2 & RS.CO-5

2.1.4.2 SECURITY INDUSTRY ALERTS & NOTIFICATION PROCESS

Control Objective: The firm establishes and institutionalizes contact with selected groups and associations within the security community:¹⁸

- To facilitate ongoing security education and training for organizational personnel;
- To stay up to date with the latest recommended security practices, techniques, and technologies; and
- To share current security-related information including threats, vulnerabilities, and incidents.

Standard: KR personnel responsible for incident response operations are required to subscribe to mailing lists or notification services to maintain awareness of security industry alerts.

Supplemental Guidance: There are five different mailing lists to select from the US-CERT subscription website (<https://forms.us-cert.gov/maillists>). However, the most applicable mailing lists are:

- Technical Cyber Security Alerts. Written for system administrators and experienced users, technical alerts provide timely information about current security issues, vulnerabilities, and exploits.
- Cyber Security Bulletins. Bulletins summarize information that has been published about new security issues and vulnerabilities for the week prior. They are published weekly and are written primarily for system administrators and other technical users.
- Cyber Security Alerts. Written for home, corporate, and new users, these alerts are published in conjunction with technical alerts when there are security issues that affect the general public.

Ongoing contact with security groups and associations is of paramount importance in an environment of rapidly changing technologies and threats. Security groups and associations include, for example, special interest groups, forums, professional associations, news groups, and/or peer groups of security professionals in similar organizations.

2.1.5 TELEWORKING

A policy and supporting security measures should be implemented to protect information accessed, processed or stored at teleworking sites.¹⁹

2.1.5.1 TELECOMMUTING

Control Objective: The firm authorizes remote access to information systems for remote workers.

Standard: KR authorizes remote users / teleworkers to connect to the internal network only if the following criteria for the remote information system are met:

- (a) Software patch status is current; and
- (b) Antimalware software is enabled and current.

Supplemental Guidance: None

2.1.5.2 REMOTE ACCESS

Control Objective: The firm:²⁰

- Documents allowed methods of remote access to the information system;
- Establishes usage restrictions and implementation guidance for each allowed remote access method;
- Monitors for unauthorized remote access to the information system;
- Authorizes remote access to the information system prior to connection; and
- Enforces requirements for remote connections to the information system.

Standard: KR's IT security personnel are responsible for:

- (a) Documenting allowed methods of remote access to the information system;
- (b) Establishing usage restrictions and implementation guidance for each allowed remote access method;
- (c) Monitoring for unauthorized remote access to information systems;
- (d) Authorizing remote access to information systems prior to connection;

¹⁸ HIPAA 164.308(A)(5)(ii) & (ii)(A) | PCI DSS (v3.2) 6.2 & 12.4

¹⁹ ISO/IEC 27002:2013 – 6.2.2

²⁰ ISO/IEC 27002:2013 – 6.2.2 | PCI DSS (v3.2) 12.3.8 & 12.3.9 | NIST Cybersecurity Framework PR.AC-3 & PR.PT-4

- (e) Enforcing requirements for remote connections to information systems;
- (f) Using cryptography to protect the confidentiality and integrity of remote access sessions;
- (g) Automatically disconnecting remote access sessions after a period of inactivity; and
- (h) Immediately deactivating vendor and business partner remote access when it is no longer needed.

Supplemental Guidance: Remote access is access to organizational information systems by users (or processes acting on behalf of users) communicating through external networks (e.g., the Internet). Remote access methods include, for example, dial-up, broadband, and wireless. Virtual Private Networks (VPNs), when adequately provisioned with appropriate security controls, are considered internal networks.

3.0 Human Resource Security Policy

KR shall ensure information security best practices are incorporated into Human Resources (HR) personnel management practices.

Management Intent: The purpose of this policy is to ensure Human Resources (HR) personnel management incorporates information security best practices.

3.1 Prior to Employment

The objective is to ensure that employees and contractors understand their responsibilities and are suitable for the roles for which they are considered.²¹

3.1.1 SCREENING

Background verification checks on all candidates for employment should be carried out in accordance with relevant laws, regulations, and ethics and should be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.²²

3.1.1.1 PERSONNEL SCREENING

Control Objective: The firm:²³

- Screens individuals prior to authorizing access to the information system; and
- Rescreens individuals, if necessary, based on organizational concerns.

Standard: KR's Human Resources (HR) department is responsible for screening potential personnel prior to hiring in an effort to minimize the risk of compromise from internal sources.

Supplemental Guidance: Approved methods of screening procedures include:

- Previous employment history verification;
- Criminal history record check;
- Department of Motor Vehicles (DMV) history check;
- Credit history; and
- Personal/professional reference checks.

3.2 During Employment

The objective is to ensure that employees and contractors understand their responsibilities and are suitable for the roles for which they are considered.²⁴

3.2.1 MANAGEMENT RESPONSIBILITIES

Management should require all employees and contractors to apply information security in accordance with the established policies and procedures of the firm.²⁵

3.2.1.1 RULES OF BEHAVIOR

Control Objective: The firm:²⁶

²¹ ISO/IEC 27002:2013 – 7.1

²² ISO/IEC 27002:2013 – 7.1.1

²³ HIPAA 164.308(a)(3)(ii) & (B) | PCI DSS (v3.2) 12.7 | NIST Cybersecurity Framework PR.DS-5 & PR.IP-11

²⁴ ISO/IEC 27002:2013 – 7.2

²⁵ ISO/IEC 27002:2013 – 7.2.1

²⁶ HIPAA 164.310(b) | PCI DSS (v3.2) 4.2, 12.3, 12.3.1, 12.3.2, 12.3.5-6, 12.3.10 & 12.4 | MA201CMR17 17.03(2)(b)(2)

- Develops usage policies for critical technologies (for example, remote access technologies, wireless technologies, removable electronic media, laptops, tablets, personal data/digital assistants (PDAs), e-mail usage and Internet usage) and define proper use of these technologies.
- Verifies that the usage policies require acceptable uses for the technology.
- Verifies that the usage policies require acceptable network locations for the technology.
- Prohibits copy, move, and storage of sensitive data onto local hard drives and removable electronic media, unless explicitly authorized for a defined business need; and
- Establishes end-user messaging technologies restrictions.

Standard: KR's Human Resources (HR) department is responsible for developing usage policies for technologies and defining proper use of these technologies, ensuring:

- (a) Information systems can only be used after explicit approval is given by company management;
- (b) User authentication must be enabled, when technically feasible;
- (c) Acceptable uses of the technologies must be given; and
- (d) Acceptable network locations must be clearly stated.

Supplemental Guidance: An investigation should take place when there is:

- A credible allegation or evidence of unethical or unlawful acts, fraud or gross misconduct, including but not limited to acts which could reasonably form the basis of a claim against KR for unlawful discrimination, harassment or retaliation; or
- A requirement to do so by law, regulation or policy.

Where law enforcement becomes involved in the subject of an internal investigation, KR needs to be prepared to cooperate with authorities consistent with its legal obligations to employees

3.2.2 INFORMATION SECURITY AWARENESS, EDUCATION AND TRAINING

All employees of the firm and, where relevant, contractors should receive appropriate awareness education and training and regular updates in organizational policies and procedures, as relevant for their job function.²⁷

3.2.2.1 INFORMATION SECURITY WORKFORCE

Control Objective: The firm establishes an information security workforce development and improvement program.²⁸

Standard: The CISO and his/her designated representatives are responsible for developing and implementing an information security workforce development and improvement program.

Supplemental Guidance: Information security workforce development and improvement programs are complementary to organizational security awareness and training programs. Information security workforce development and improvement programs focus on developing and institutionalizing core information security capabilities of selected personnel needed to protect organizational operations, assets, and individuals.

Information security workforce development and improvement programs include, for example:

- Defining the knowledge and skill levels needed to perform information security duties and tasks;
- Developing role-based training programs for individuals assigned information security roles and responsibilities; and
- Providing standards for measuring and building individual qualifications for incumbents and applicants for information security-related positions.

3.2.2.2 SECURITY TRAINING

Control Objective: The firm provides role-based security-related training:²⁹

- Before authorizing access to the system or performing assigned duties;
- When required by system changes; and
- Annually thereafter.

²⁷ ISO/IEC 27002:2013 – 7.2.2

²⁸ NIST Cybersecurity Framework PR.AT-1, PR.AT-2, PR.AT-4 & PR.AT-5

²⁹ PCI DSS (v3.2) 12.6.1 & 12.6.2 | MA201CMR17 17.04(8) | OR646A.622(2)(d)(A)(iv) | NIST Cybersecurity Framework PR.AT-2, PR.AT-4 & PR.AT-5

Standard: For information security training:

- (a) KR's Human Resources (HR) department shall ensure initial security training is provided to personnel upon hire; and
- (b) KR's IT security personnel are required to provide training, at least annually, thereafter.

Supplemental Guidance: Methods will vary depending on the role of the personnel and their level of access to sensitive data. For end-user training:

- All users should sign an acknowledgment form stating they have read and understood KR's requirements regarding information security policies, prior to having access to KR information systems or data.
- All new users should attend a security awareness training class within thirty (30) days of, being granted access to any information system;
- All users should undergo at least one (1) hour of security awareness training annually.
- All users should be provided with sufficient training and supporting reference materials to allow them to properly protect KR's information systems and data; and
- KR's management need to develop and maintain a communications process to be able to communicate new Information Security program information, such as an informational security bulletin or email about security items of interest.

Initial orientation and ongoing security training should include the following topics:

- Information security basics
- Company information security policies
- Email policy
- Acceptable usage policy
- Data classification & handling
- Malicious software & spam
- Offsite security / security at home
- Wireless security
- Third party security (outsourced vendors)
- Visitor security procedures
- Incident response procedures
- Business continuity roles and procedures

3.2.2.3 AWARENESS TRAINING FOR SENSITIVE INFORMATION

Control Objective: The firm ensures that every user accessing an information system processing, storing, or transmitting types of sensitive information is formally trained in handling procedures for all of the relevant types of information on the system.³⁰

Standard: KR's management is required to ensure that every user accessing an information system that processes, stores, or transmits sensitive information is formally trained in handling procedures for all of the relevant types of sensitive information.

Supplemental Guidance: None

3.2.2.4 SECURITY TRAINING RECORDS

Control Objective: The firm:³¹

- Documents and monitors individual information system security training activities including basic security awareness training and specific information system security training; and
- Retains individual training records.

Standard: KR requires:

- (a) Personnel to acknowledge in writing or electronically, at least annually, that they have read and understood KR's information security policies; and
- (b) Human Resources (HR) shall maintain a record of the acknowledgment in users' personnel records as evidence of information security awareness and training.

³⁰ PCI DSS (v3.2) 1.5, 2.5, 3.7, 4.3, 5.4, 6.7, 7.3, 8.8, 9.10, 10.9, 11.6, 12.6, 12.6.1, 12.6.2, 12.8.3 & 12.8.5, 12.10.4

³¹ PCI DSS (v3.2) 12.6.2

Supplemental Guidance: Any security bulletins or awareness training information should be archived as evidence of training. If possible, the individuals who received training or distribution list recipients should be documented. A record of the acknowledgment of information security training shall be maintained by Human Resources (HR) as evidence of training.

3.2.2.5 SECURITY AWARENESS

Control Objective: The firm provides basic security awareness training to all information system users (including managers, senior executives, and contractors) as part of initial training for new users, when required by system changes, and thereafter as required.

³²

Standard: KR's IT security personnel are responsible for developing and implementing a formal security awareness program to make all KR users aware of the importance of information security.

Supplemental Guidance: Organizations generally determine the appropriate content of security awareness training and security awareness techniques based on the specific organizational requirements and the information systems to which personnel have authorized access. The content includes a basic understanding of the need for information security and user actions to maintain security and to respond to suspected security incidents.

3.2.2.6 TESTING, TRAINING & MONITORING

Control Objective: The firm: ³³

- Implements a process for ensuring that organizational plans for conducting security testing, training, and monitoring activities associated with organizational information systems:
 - Are developed and maintained; and
 - Continue to be executed in a timely manner;
- Reviews testing, training, and monitoring plans for consistency with the firm's risk management strategy and organization-wide priorities for risk response actions.

Standard: The CISO and his/her designated representatives are responsible for establishing and maintaining a process to conduct security testing, training, and monitoring activities associated with KR's information systems.

Supplemental Guidance: This control ensures that oversight exists for security testing, training, and monitoring activities conducted organization-wide and that those activities are coordinated. Testing, training, and monitoring plans and activities should be informed by current threat and vulnerability assessments.

3.2.2.7 PRACTICAL EXERCISES

Control Objective: The firm includes practical exercises in security awareness training that simulate actual cyber-attacks.

Standard: KR's IT security personnel are responsible for developing and implementing practical exercises in security awareness training that simulate actual cyber-attacks.

Supplemental Guidance: Practical exercises may include, for example, no-notice social engineering attempts to collect information, gain unauthorized access, or simulate the adverse impact of opening malicious email attachments or invoking malicious web links.

3.2.2.8 SECURITY INDUSTRY ALERTS & NOTIFICATION PROCESS

Control Objective: The firm establishes and institutionalizes contact with selected groups and associations within the security community: ³⁴

- To facilitate ongoing security education and training for organizational personnel;

³² HIPAA 164.308(a)(5)(i) & 164.308(a)(5)(ii)(A) | PCI DSS (v3.2) 12.6 | MA201CMR17 17.04(8) & 17.03(2)(b)(1) | NIST Cybersecurity Framework PR.AT-1

³³ NIST Cybersecurity Framework PR.IP-10, DE.DP-1, DE.DP-2, DE.DP-3 & DE.DP-5

³⁴ HIPAA 164.308(A)(5)(ii) & (ii)(A) | PCI DSS (v3.2) 6.2 & 12.4

- To stay up to date with the latest recommended security practices, techniques, and technologies; and
- To share current security-related information including threats, vulnerabilities, and incidents.

Standard: KR personnel responsible for incident response operations are required to subscribe to mailing lists or notification services to maintain awareness of security industry alerts.

Supplemental Guidance: There are five different mailing lists to select from the US-CERT subscription website (<https://forms.us-cert.gov/maillists>). However, the most applicable mailing lists are:

- **Technical Cyber Security Alerts.** Written for system administrators and experienced users, technical alerts provide timely information about current security issues, vulnerabilities, and exploits.
- **Cyber Security Bulletins.** Bulletins summarize information that has been published about new security issues and vulnerabilities for the week prior. They are published weekly and are written primarily for system administrators and other technical users.
- **Cyber Security Alerts.** Written for home, corporate, and new users, these alerts are published in conjunction with technical alerts when there are security issues that affect the general public.

Ongoing contact with security groups and associations is of paramount importance in an environment of rapidly changing technologies and threats. Security groups and associations include, for example, special interest groups, forums, professional associations, news groups, and/or peer groups of security professionals in similar organizations.

3.2.3 DISCIPLINARY PROCESS

There should be a formal and communicated disciplinary process in place to take action against employees who have committed an information security breach.³⁵

3.2.3.1 PERSONNEL SANCTIONS

Control Objective: The firm employs a formal sanctions process for personnel failing to comply with established information security policies and procedures.³⁶

Standard: Human Resources (HR) is required to manage and operate its personnel sanctions process consistent with applicable laws, regulations, policies and standards.

Supplemental Guidance: KR may utilize a tiered structure of sanctions that takes into consideration the magnitude of harm caused by the actions or inactions of the individual under sanction.

3.3 Termination and Change of Employment

The objective is to protect the firm's interests as part of the process of changing or terminating employment.³⁷

3.3.1 TERMINATION OR CHANGE OF EMPLOYMENT RESPONSIBILITIES

Information security responsibilities and duties that remain valid after termination or change of employment should be defined, communicated to the employee or contractor and enforced.

3.3.1.1 PERSONNEL TERMINATION

Control Objective: The firm, upon termination of individual employment:³⁸

- Terminates information system access;
- Conducts exit interviews;
- Retrieves all security-related organizational information system-related property; and
- Retains access to organizational information and information systems formerly controlled by terminated individual.

Standard: KR is required to ensure that upon termination of an individual's employment:

- (a) Information system access accounts are disabled with twenty-four (24) hours of the termination action;

³⁵ ISO/IEC 27002:2013 – 7.2.3

³⁶ HIPAA 164.308(a)(1)(ii)(C) | MA201CMR17 17.03(2)(d) | NIST Cybersecurity Framework PR.IP-11

³⁷ ISO/IEC 27002:2013 – 7.3

³⁸ ISO/IEC 27002:2013 – 7.3.1 | HIPAA 164.308(a)(3)(ii) & (C) | PCI DSS (v3.2) 9.3 | MA201CMR17 17.03(2)(e) | NIST Cybersecurity Framework PR.IP-11

- (b) Exit interviews are conducted, if possible;
- (c) All information system-related property is recovered; and
- (d) All company-owned information the terminated employee was responsible for is identified and accounted for.

Supplemental Guidance: If a user resigns or is terminated, the following should be accomplished as soon as possible, but no longer than twenty-four (24) hours from notification of a change in a user's status:

- The user's privileges and access must be revoked;
- The user's passwords must be changed, or the accounts disabled to preclude access;
- All shared passwords known by the user on all applicable systems must be changed;
- All privileged account passwords known by the user must be changed;
- Incoming mail for the user should be re-directed as directed by the user's supervisor;
- After thirty (30) days, incoming mail should be disabled for the account, unless deemed necessary;
- All files owned by the user should be identified and either archived or changed to a valid user;
- All automated scripts/ batch jobs previously requested or previously submitted should be reviewed; and
- All KR property should be collected, including but not limited to:
 - Keys, lock combinations and identification badges;
 - Sensitive data and documentation;
 - Operator procedures;
 - Program documentation;
 - Company-owned equipment, pagers, notebook computers and tools; and
 - Phone contact lists.

3.3.1.2 HIGH-RISK TERMINATIONS

Control Objective: The firm, upon termination of an individual deemed to be a "high risk" to the firm, ensures for the expedited process of removing the individual's access to organizational information systems and data.

Standard: Human Resources (HR) is required to immediately notify KR's IT security personnel to revoke the user's IDs, privileges, and authorizations for a "high risk" employee or contractor termination.

Supplemental Guidance: The objective of this control is to remove the user's access without delay. If the situation warrants it, a backup or image of the individual's information systems (e.g., workstation, laptop, smart phone, etc.) may be required. If a backup is intended for possible punitive action against the individual, the backup must be in accordance with forensic investigation procedures to ensure chain of custody and unassailable data copies.

3.3.1.3 PERSONNEL TRANSFER

Control Objective: The firm reviews logical and physical access authorizations to information systems/facilities when personnel are reassigned or transferred to other positions within the firm and initiates organization-defined transfer or reassignment actions within an organization-defined time period following the formal transfer action.³⁹

Standard: KR managers are required to:

- (a) Review the logical and physical access authorizations to information systems/facilities when personnel are reassigned or transferred to other positions within the firm; and
- (b) Initiate company-defined transfer or reassignment actions within seven (7) days following the formal transfer action.

Supplemental Guidance: None

³⁹ NIST Cybersecurity Framework PR.IP-11

4.0 Asset Management Policy

KR shall protect its assets and data by ensuring appropriate handling requirements are followed to prevent unauthorized disclosures, regardless if assets or data are being transmitted or stored.

Management Intent: The purpose of this policy is to ensure that assets and data are properly classified (based on its business value) and measures are implemented to protect KR's data from unauthorized disclosure, regardless if it is being transmitted or stored.

4.1 Responsibility for Assets

The objective is to identify assets associated with information and information processing facilities, and an inventory of these assets should be drawn up and maintained.⁴⁰

4.1.1 INVENTORY OF ASSETS

Assets associated with information and information processing facilities should be identified, and an inventory of these assets should be drawn up and maintained.⁴¹

4.1.1.1 INFORMATION SYSTEM INVENTORY

Control Objective: The firm develops and maintains an inventory of its information systems.⁴²

Standard: KR is required to maintain an inventory of its information systems that includes, but is not limited to:

- (a) A list of all such devices and personnel with access;
- (b) A method to accurately and readily determine owner, contact information, and purpose (e.g., labeling, coding, and/or inventorying of devices);
- (c) List of company-approved products; and
- (d) Update the inventory at necessary.

Supplemental Guidance: The inventory should be updated as an integral part of component installations, removals, and information system updates. Without an inventory, some system components could be forgotten, and be inadvertently excluded from applicable configuration standards. Inventory specifications include, for example, manufacturer, device type, model, serial number, and physical location.

4.1.1.2 APPROVED DEVIATIONS

Control Objective: The firm includes assessed component configurations and any approved deviations to currently deployed configurations in the information system component inventory.

Standard: Asset custodians are required to request and document approved deviations to deployed configurations in an information system under their control.

Supplemental Guidance: This control enhancement focuses on configuration settings established by organizations for information system components, the specific components that have been assessed to determine compliance with the required configuration settings, and any approved deviations from established configuration settings.

⁴⁰ ISO/IEC 27002:2013 – 8.1

⁴¹ ISO/IEC 27002:2013 – 8.1.1

⁴² PCI DSS (v3.2) 2.4

4.1.1.3 NETWORK DIAGRAMS

Control Objective: The firm verifies that all components within the authorization boundary of the information system are either inventoried as a part of the system or recognized by another system as a component of that system.⁴³

Standard: Asset custodians and data owners are required to:

- (a) Verify that a current network diagram exists for their environment(s);
- (b) Maintain a current diagram that shows all data flows across systems and networks; and
- (c) Documents all connections, including any wireless networks and hosted services.

Supplemental Guidance: The network diagrams should provide sufficient documentation to describe the high-level design of the network in terms of information systems and implementation details of the security controls employed, with sufficient detail to permit analysis and testing.

data

4.1.1.4 INTRANETS

Control Objective: The firm establishes terms and conditions, consistent with any trust relationships established with other organizations owning, operating, and/or maintaining external information systems, allowing authorized individuals to:⁴⁴

- Access the information system from the external information systems; and
- Process, store, and/or transmit organization-controlled information using the external information systems.

Standard: Non-employee users are authorized to access KR's Intranet only when Non-Disclosure Agreements (NDAs) are on file for each of the authorized, external users.

Supplemental Guidance: This control addresses the use of internal and external information systems for the processing, storage, or transmission of organizational information, including, for example, accessing cloud-based information systems and services (e.g., Infrastructure as a Service (IaaS), Platform as a Service (PaaS), and Software as a Service (SaaS)) from KR information systems.

4.1.2 ACCEPTABLE USE OF ASSETS

Rules for the acceptable use of information and of assets associated with information and information processing facilities should be identified, documented and implemented.⁴⁵

4.1.2.1 RULES OF BEHAVIOR

Control Objective: The firm:⁴⁶

- Develops usage policies for critical technologies (for example, remote access technologies, wireless technologies, removable electronic media, laptops, tablets, personal data/digital assistants (PDAs), e-mail usage and Internet usage) and define proper use of these technologies.
- Verifies that the usage policies require acceptable uses for the technology.
- Verifies that the usage policies require acceptable network locations for the technology.
- Prohibits copy, move, and storage of sensitive data onto local hard drives and removable electronic media, unless explicitly authorized for a defined business need; and
- Establishes end-user messaging technologies restrictions.

Standard: KR's Human Resources (HR) department in conjunction with the ISO is responsible for developing usage policies for technologies and defining proper use of these technologies, ensuring:

- (a) Information systems can only be used after explicit approval is given by company management;
- (b) User authentication must be enabled, when technically feasible;
- (c) Acceptable uses of the technologies must be given; and
- (d) Acceptable network locations must be clearly stated.

⁴³ PCI DSS (v3.2) 1.1.2 & 1.1.3

⁴⁴ NIST Cybersecurity Framework ID.AM-4 & PR.AC-3

⁴⁵ ISO/IEC 27002:2013 – 8.1.3

⁴⁶ HIPAA 164.310(b) | PCI DSS (v3.2) 4.2, 12.3, 12.3.1, 12.3.2, 12.3.5-6, 12.3.10 & 12.4 | MA201CMR17 17.03(2)(b)(2)

Where law enforcement becomes involved in the subject of an internal investigation, KR will be expected to fully cooperate with authorities, consistent with its legal obligations to employees, partners, and customers.

4.1.3 RETURN OF ASSETS

All employees and external party users should return all of the firm's assets in their possession upon termination of their employment, contract or agreement.⁴⁷

4.1.3.1 ASSET COLLECTION

Control Objective: The firm, upon termination of individual employment, ensures for the collection of organization-owned assets prior to the individual's departure.

Standard: The direct manager of a terminated user is responsible for inventorying and accounting for all KR-issued assets, prior to the individual's departure.

Supplemental Guidance: Depending on applicable labor laws, this may require withholding the final paycheck from the terminated individual until the firm-issued assets are returned. Human Resources must be informed of any missing or damaged company assets that were the responsibility of the terminated individual.

4.2 Information Classification

The objective is to ensure that information receives an appropriate level of protection in accordance with its importance to the firm.⁴⁸

4.2.1 CLASSIFICATION OF INFORMATION

Information should be classified in terms of legal requirements, value, criticality and sensitivity to unauthorized disclosure or modification.⁴⁹

4.2.1.1 SECURITY CATEGORIZATION

Control Objective: The firm:⁵⁰

- Categorizes information systems and data in accordance with applicable local, state, and Federal laws;
- Documents the security categorization results (including supporting rationale) in the security plan for information systems; and
- Ensures the security categorization decision is reviewed and approved by the asset owner.

Standard: Based on the System Criticality and Data Sensitivity of a system (see [Appendix D: Baseline Security Categorization Guidelines](#)), asset custodians and data owners are required to:

- (a) Categorize the information system and data; and
- (b) Where applicable, document the security categorization results (including supporting rationale) for the information system.

Supplemental Guidance: Clearly defined authorization boundaries are a prerequisite for effective security categorization decisions. Security categories describe the potential adverse impacts on organizational operations, organizational assets, and individuals if organizational information and information systems are comprised through a loss of confidentiality, integrity, or availability. Security categorization processes carried out by business units, facilitates the development of inventories of information assets mappings to specific information system components where information is processed, stored, or transmitted.

4.2.2 LABELING OF INFORMATION

An appropriate set of procedures for information labeling should be developed and implemented in accordance with the information classification scheme adopted by the firm.⁵¹

⁴⁷ ISO/IEC 27002:2013 – 8.1.4

⁴⁸ ISO/IEC 27002:2013 – 8.2

⁴⁹ ISO/IEC 27002:2013 – 8.2.1

⁵⁰ PCI DSS (v3.2) 9.6.1 | NIST Cybersecurity Framework ID.AM-5, ID.RA-4 & ID.RA-5

⁵¹ ISO/IEC 27002:2013 – 8.2.2

4.2.3 HANDLING OF ASSETS

Procedures for handling assets should be developed and implemented in accordance with the information classification scheme adopted by the firm.⁵²

4.2.3.1 MEDIA TRANSPORTATION

Control Objective: The firm: ⁵³

- Protects and controls digital and non-digital media during transport outside of controlled areas using organization-defined security measures;
- Maintains accountability for information system media during transport outside of controlled areas; and
- Restricts the activities associated with transport of such media to authorized personnel.

Standard: KR users are required to ensure:

- (a) Digital and non-digital media is protected during transport outside of KR-controlled areas using available security measures;
- (b) Management approval approves any and all media that is moved from a secured area;
- (c) Accountability is maintained for information system media during transport outside of KR-controlled areas; and
- (d) Activities associated with transport of such media are restricted to authorized personnel.

Supplemental Guidance: Information system media includes both digital and non-digital media. Non-digital media includes, for example, diskettes, magnetic tapes, removable hard drives, flash drives, compact disks, and digital video disks. Non-digital media includes, for example, paper and microfilm. This control also applies to mobile computing and communications devices with information storage capability (e.g., notebook computers, personal digital assistants, cellular telephones, digital cameras, and audio recording devices) that are transported outside of controlled areas.

4.2.3.2 MEDIA CUSTODIANS

Control Objective: The firm employs an identified custodian throughout the transport of information system media.

Standard: Data owners are required to ensure a dedicated custodian is identified throughout the transport of information system media.

Supplemental Guidance: Custodial responsibilities can be transferred from one individual to another as long as an unambiguous custodian is identified at all times.

4.2.3.3 CRYPTOGRAPHIC PROTECTION (ENCRYPTING DATA IN STORAGE MEDIA)

Control Objective: The firm employs cryptographic mechanisms to protect the confidentiality and integrity of information stored on digital media during transport outside of controlled areas.

Standard: Asset custodians and data owners are required to employ cryptographic mechanisms to protect the confidentiality and integrity of information stored on digital media during transport outside of controlled areas.

Supplemental Guidance: This standard also applies to mobile devices. Mobile devices include

- Portable storage media:
 - USB memory sticks; and
 - External hard disk drives
- Portable computing and communications devices with storage capability:
 - Notebook computers;
 - Personal Digital Assistants (PDAs); and
 - Cellular / smart telephones.

⁵² ISO/IEC 27002:2013 – 8.2.3

⁵³ HIPAA 164.310(d)(1) | PCI DSS (v3.2) 9.6, 9.6.2, 9.6.3 & 9.7 | MA201CMR17 17.03(2)(c) | OR646A.620 | NIST Cybersecurity Framework PR.PT-2

4.3 Media Handling

The objective is to prevent unauthorized disclosure, modification, removal or destruction of information stored on media.⁵⁴

4.3.1 MANAGEMENT OF REMOVABLE MEDIA

Procedures should be implemented for the management of removable media in accordance with the classification scheme adopted by the firm.⁵⁵

4.3.1.1 MEDIA USE

Control Objective: The firm restricts the use of organization-defined types of digital and/or non-digital media on information systems or system components using security safeguards.⁵⁶

Standard: Asset custodians and data owners are required to employ technical and non-technical safeguards to restrict the insecure use of mobile computing and communications devices with information storage capability.

Supplemental Guidance: Information system media includes both digital and non-digital media. This control also applies to mobile computing and communications devices that include notebook computers, personal digital assistants, cellular telephones, digital cameras, and audio recording devices.

4.3.1.2 MEDIA ACCESS

Control Objective: The firm restricts access to types of digital and non-digital media authorized individuals using organization-defined security measures.⁵⁷

Standard: Asset custodians and data owners are required to restrict access to digital and non-digital media to authorized individuals.

Supplemental Guidance: Information system media includes both digital and non-digital media. Digital media includes, for example, diskettes, magnetic tapes, external/removable hard drives, flash drives, compact disks, and digital video disks. Non-digital media includes, for example, paper and microfilm. For media containing information determined by organizations to be in the public domain, to be publicly releasable, or to have limited or no adverse impact on organizations or individuals if accessed by other than authorized personnel, fewer safeguards may be needed. In these situations, physical access controls may provide adequate protection.

4.3.2 DISPOSAL OF MEDIA

Media should be disposed of securely when no longer required, using formal procedures.⁵⁸

4.3.2.1 DATA RETENTION & DISPOSAL

Control Objective: The firm:⁵⁹

- Retains Personally Identifiable Information (PII) for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law;
- Disposes of, destroys, erases, and/or anonymizes the PII, regardless of the method of storage; and
- Uses organization-defined techniques or methods to ensure secure deletion or destruction of PII (including originals, copies, and archived records).

Standard: Data owners are required to:

- (a) Define retention periods for PII; and
- (b) Dispose of, destroy, erase, and/or anonymizes the PII once the PII is no longer necessary for business purposes.

Supplemental Guidance: None

⁵⁴ ISO/IEC 27002:2013 – 8.3

⁵⁵ ISO/IEC 27002:2013 – 8.3.1

⁵⁶ NIST Cybersecurity Framework PR.PT-2

⁵⁷ HIPAA 164.308(a)(4)(ii)(C) | NIST Cybersecurity Framework PR.PT-2

⁵⁸ ISO/IEC 27002:2013 – 8.3.2

⁵⁹ UK Data Protection Act of 1998 (Chapter29-Schedule1-Part1-Principle 5)

4.3.2.2 MEDIA SANITIZATION

Control Objective: The firm: ⁶⁰

- Sanitizes information system media, both digital and non-digital, prior to disposal, release out of organizational control, or release for reuse; and
- Employs sanitization mechanisms with strength and integrity commensurate with the classification or sensitivity of the information.

Standard: Media must be sanitized when it is no longer needed for business or legal reasons. KR asset custodians and data owners are required to destroy information system media that cannot be sanitized, as follows:

- (a) Shred, incinerate, or pulp hardcopy materials so that data cannot be reconstructed; or
- (b) Render data on electronic media unrecoverable so that data cannot be reconstructed.

Supplemental Guidance: This control applies to all digital and non-digital media subject to disposal or reuse to include media found in devices such as scanners, copiers, and printers. The sanitization process removes information from information system media such that the information cannot be retrieved or reconstructed. Sanitization techniques, including clearing, purging, and destruction, prevent the disclosure of information to unauthorized individuals when such media is reused or released for disposal.

4.3.2.3 MEDIA SANITIZATION DOCUMENTATION

Control Objective: The firm tracks, documents, and verifies media sanitization and disposal actions. ⁶¹

Standard: Asset custodians and data owners are required to:

- (a) Track, document, and verify media sanitization and disposal actions;
- (b) Assign one individual or department responsible for coordinating data disposal and reuse of equipment; and
- (c) Train staff members on the security risks associated with the reuse of equipment that stored or processed sensitive data.

Supplemental Guidance: None

⁶⁰ HIPAA 164.310(d)(2)(i) | PCI DSS (v3.2) 9.8, 9.8.1 & 9.8.2 | OR646A.622(2)(d)(C)(i) & 622(2)(d)(C)(iv) | NIST Cybersecurity Framework PR.DS-3 & PR.IP-6

⁶¹ HIPAA 164.310(d)(2)(ii) | PCI DSS (v3.2) 9.7.1

5.0 Access Control Policy

KR shall implement the principle of “least privilege” within logical access control mechanisms so that only authorized users have access to KR’s information systems and data.

Management Intent: The purpose of this policy is to ensure that KR implements the concept of “least privilege” through limiting access to KR’s information systems and data to authorized users only.

5.1 Business Requirements of Access Control

The objective is to limit access to information and information processing facilities.⁶²

5.1.1 ACCESS CONTROL

An access control policy should be established, documented and reviewed based on business and information security requirements.⁶³

5.1.1.1 IDENTIFICATION & AUTHENTICATION

Control Objective: The firm develops, disseminates, reviews & updates:⁶⁴

- A formal, documented identification and authentication policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
- Formal, documented procedures to facilitate the implementation of the identification and authentication policy and associated identification and authentication controls.

Standard: KR is required to document organization-wide identification and authentication controls that, at a minimum, include:

- (a) A formal, documented identification and authentication policy; and
- (b) Processes to facilitate the implementation of the identification and authentication policy, procedures, and associated controls.

Supplemental Guidance: The firm’s risk management strategy is a key factor in establishing identification and authentication controls.

5.1.1.2 ACCESS TO SENSITIVE DATA

Control Objective: The firm limits access to system components and data to only those individuals whose job requires such access.⁶⁵

Standard: Data owners and asset custodians are required to implement administrative and technical measures to limit access to system components and data to only those individuals whose job requires such access. Access limitations include the following:

- (a) Defining access needs for each role, including:
 - 1. System components and data resources that each role needs to access for their job function; and
 - 2. Level of privilege required (e.g., user, administrator, etc.) for accessing resources;
- (b) Restricting access to privileged user IDs to least privileges necessary to perform job responsibilities;
- (c) Assigning access based on individual personnel’s job classification and function; and
- (d) Requiring documented approval by authorized parties specifying required privileges.

Supplemental Guidance: The implement of an automated access control system can be a combination of technology, since all modern computers, payment application, and Point of Sale (POS) software already have built-in systems for user accounts and

⁶² ISO/IEC 27002:2013 – 9.1

⁶³ ISO/IEC 27002:2013 – 9.1.1

⁶⁴ PCI DSS (v3.2) 8.1

⁶⁵ PCI DSS (v3.2) 7.1-7.1.4

privilege controls. Microsoft's PCI DSS Compliance Planning Guide should be referenced for using Active Directory as an automated access control system for Windows-based POS management.⁶⁶

5.1.1.3 ACCESS CONTROL PROCEDURES

Control Objective: The firm develops, disseminates, reviews & updates:⁶⁷

- A formal, documented access control program that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
- Formal, documented procedures to facilitate the implementation of the access control program and associated access controls.

Standard: KR is required to document organization-wide access control controls that, at a minimum, include:

- (a) A formal, documented access control program; and
- (b) Processes to facilitate the implementation of the access control procedures and associated controls.

Supplemental Guidance: None

5.1.2 ACCESS TO NETWORKS AND NETWORK SERVICES

Users should only be provided with access to the network and network services that they have been specifically authorized to use.⁶⁸

5.1.2.1 LEAST FUNCTIONALITY

Control Objective: The firm configures information systems to provide only essential capabilities and specifically prohibits or restricts the use of the following functions, ports, protocols, and/or services.⁶⁹

Standard: KR utilizes the "principle of least functionality," which states that only the minimum functionality necessary to perform an operation should be granted. Asset custodians are required to the following:

- (a) Identifying and removing insecure services, protocols, and ports;
- (b) Enabling only necessary and secure services, protocols, and daemons, as required for the function of the system;
- (c) Implementing security features for any required services, protocols or daemons that are considered to be insecure (e.g., NetBIOS, Telnet, FTP, etc.);
- (d) Verifying services, protocols, and ports are documented and properly implemented by examining firewall and router configuration settings; and
- (e) Removing all unnecessary functionality, such as:
 - i. Scripts;
 - ii. Drivers;
 - iii. Features;
 - iv. Subsystems;
 - v. File systems; and
 - vi. Unnecessary web servers.

Supplemental Guidance: Asset custodians should review functions and services of information systems, to determine which functions and services are candidates for elimination (e.g., Instant Messaging, auto-execute, and file sharing). KR may utilize network scanning tools, intrusion detection and prevention systems, and endpoint protections such as firewalls and host-based intrusion detection systems to identify and prevent the use of prohibited functions, ports, protocols, and services.

5.1.2.2 PREVENT PROGRAM EXECUTION

Control Objective: Information systems employ automated mechanisms to prevent program execution of unauthorized software programs.

⁶⁶ Microsoft's Payment Card Industry Data Security Standard Compliance Planning Guide <http://www.microsoft.com/en-us/download/details.aspx?id=18015>

⁶⁷ HIPAA 164.312(a)(1) | PCI DSS 8.1 & 8.4

⁶⁸ ISO/IEC 27002:2013 – 9.1.2

⁶⁹ PCI DSS (v3.2) 1.1.5, 1.2.1, 2.2.2, 2.2.4 & 2.2.5 | MA201CMR17 17.03(2)(a) | NIST Cybersecurity Framework PR.IP-1

Standard: Asset custodians are required to configuring information systems to employ automated mechanisms to prevent program execution of unauthorized software programs.

Supplemental Guidance: None

5.2 User Access Management

The objective is to ensure authorized user access and to prevent unauthorized access to systems and services.⁷⁰

5.2.1 USER REGISTRATION AND DE-REGISTRATION

A formal user registration and de-registration process should be implemented to enable assignment of access rights.⁷¹

5.2.1.1 USER ID MANAGEMENT

Control Objective: The firm defines and implements policies and procedures to ensure proper user identification management for non-consumer users and administrators on all system components.⁷²

Standard: Asset custodians are required to assign all non-consumer users a unique user identification (ID) before allowing them to access system components. User identification controls include the following:

- (a) Controlling addition, deletion, and modification of user IDs, credentials, and other identifier objects;
- (b) Revoking access for any terminated users within twenty-four (24) hours of employment status change;
- (c) Removing or disabling inactive user accounts that have been inactive for ninety (90) days or more;
- (d) Managing user accounts assigned to vendors that are used to access, support, or maintain system components via remote access:
 - 1. Enabling the accounts only during the time period needed and disabled when not in use; and
 - 2. Monitoring the accounts when in use;
- (e) Limiting repeated access attempts be locked out after not more than six (6) invalid logon attempts;
- (f) Setting lockout durations to a minimum of thirty (30) minutes or until an administrator enables the user ID; and
- (g) Require users to re-authenticate if a session has been idle for more than fifteen (15) minutes to re-activate the terminal or session.

Supplemental Guidance: An example of uniqueness, the difference can be adding a designator to the end of the username, such as a number. Examples include:

- First user in the system named "John Smith": John.Smith or JSMITH
- Second user in the system named "John Smith": John.Smith1 or JSMITH1
- Third user in the system named "John Smith": John.Smith2 or JSMITH2

5.2.1.2 ACCOUNT MANAGEMENT

Control Objective: The firm manages information system accounts, including:⁷³

- Identifying account types (e.g., individual, group, system, application, guest/anonymous, and temporary);
- Establishing conditions for group membership;
- Identifying authorized users of the information system and specifying access privileges;
- Requiring appropriate approvals for requests to establish accounts;
- Establishing, activating, modifying, disabling, and removing accounts;
- Specifically authorizing and monitoring the use of guest/anonymous and temporary accounts;
- Notifying account managers when temporary accounts are no longer required and when information system users are terminated, transferred, or information system usage or need-to-know/need-to-share changes;
- Deactivating accounts that are no longer required;
- Granting access to the system based on a valid access authorization; and
- Reviewing accounts on a regular basis.

⁷⁰ ISO/IEC 27002:2013 – 9.2

⁷¹ ISO/IEC 27002:2013 – 9.2.1

⁷² PCI DSS (v3.2) 8.1, 8.1.1-8.1.8

⁷³ HIPAA 164.312(d) | PCI DSS (v3.2) 8.1.3-8.1.5, 8.2.2, 8.5, 8.5.1, 8.6 & 8.7 | MA201CMR17 17.04(1(a) | NIST Cybersecurity Framework PR.AC-1, PR.AC-4, DE.CM-1 & DE.CM-3

Standard: KR's IT department is responsible for ensuring proper user identification and authentication management for all standard and privileged users on all information systems, as follows:

- (a) Control addition, deletion, and modification of user IDs, credentials, and other identifier objects to ensure authorized use is maintained;
- (b) Verify user identity before issuing initial passwords or performing password resets;
- (c) Set passwords for first-time use and resets to a unique value for each user and change immediately after the first use;
- (d) Immediately revoke access for any terminated users;
- (e) Remove/disable inactive user accounts at least every ninety (90) days;
- (f) Limit repeated access attempts by locking out the user ID after not more than six (6) attempts;
- (g) Set the lockout duration to a minimum of thirty (30) minutes or until administrator enables the user ID;
- (h) If a session has been idle for more than fifteen (15) minutes, require the user to re-authenticate to re-activate the terminal or session;
- (i) Establish and administer accounts in accordance with a role-based access scheme that organizes information system and network privileges into roles;
- (j) Track and monitor role assignments for privileged user accounts;
- (k) Automatically terminate access for temporary and emergency accounts after the accounts are no longer needed;
- (l) Enable accounts used by vendors for remote access only during the time period needed and monitor vendor remote access accounts when in use;
- (m) Minimize the use of group, shared, or generic accounts and passwords;
- (n) Default user IDs and accounts are disabled or removed;
- (o) Service providers with remote access to KR's premises (e.g., for support of POS systems or servers) must use a unique authentication credential (such as a password/phrase) for each customer; and
- (p) Restrict user direct access or queries to databases to database administrators, including.
 - 1. Verify that database and application configuration settings ensure that all user access to, user queries of, and user actions on (e.g., move, copy, delete), the database are through programmatic methods only (e.g., through stored procedures);
 - 2. Verify that database and application configuration settings restrict user direct access or queries to databases to database administrators; and
 - 3. Review database applications and the related application IDs to verify that application IDs can only be used by the applications and not by individual users or other processes.

Supplemental Guidance:

- Access privileges granted to general users should be reviewed by information owners every six (6) months to determine if access rights are commensurate with the user's job duties.
- Evidence of account and privilege reviews that documents the review occurred, who conducted the review, and what action (if any) was taken should be maintained for a period of twelve (12) months.
- Asset custodians and data owners are required to promptly report all changes in user duties or employment status for the User IDs associated with the involved personnel and administrators should promptly revoke all unnecessary access privileges

5.2.2 USER ACCESS PROVISIONING

A formal user access provisioning process should be implemented to assign or revoke access rights for all user types to all systems and services.⁷⁴

5.2.2.1 ACCOUNT PROVISIONING

Control Objective: The firm implements authentication mechanisms, in conjunction with unique IDs, to verify user legitimacy.⁷⁵

Standard: To ensure proper user authentication management for non-consumer users and administrators on all system components, user authentication mechanisms shall:

- (a) Use at least one of the following methods to authenticate all users in addition to assigning a unique ID:
 - 1. Something you know, such as a password or passphrase;
 - 2. Something you have, such as a token device or smart card; or

⁷⁴ ISO/IEC 27002:2013 – 9.2.2

⁷⁵ PCI DSS (v3.2) 8.2-8.2.6

3. Something you are, such as a biometric;
- (b) Use strong cryptography to render all authentication credentials unreadable during transmission and storage;
- (c) Verifying user identity before modifying any authentication credential that includes, but is not limited to:
 1. Performing password resets;
 2. Provisioning new tokens; or
 3. Generating new keys;
- (d) Requiring complex passwords/phrases are used that contains:
 1. A minimum length of at least seven (7) characters; and
 2. Both numeric and alphabetic characters;
- (e) Forcing password/phrase changes at least every ninety (90) days; and
- (f) Prohibiting individuals from submitting a new password/phrase that is the same as any of the last four (4) passwords/phrases he or she has used; and
- (g) Setting passwords/phrases for first-time use and upon reset to a unique value for each user and change immediately after the first use.

Supplemental Guidance: Since one of the first steps a malicious individual will take to compromise a system is to exploit weak or nonexistent passwords, it is important to implement good processes for authentication management. Passwords should never be written down or stored on-line in an unencrypted format.

Users must create passwords that can be easily remembered. One way to do this is to create a password based on a song title, affirmation, or another phrase. For example, the phrase might be: "This May Be One Way To Remember" and the password could be: "TmB1w2R!" or "Tmb1W>r~" or some other variation. NOTE: Do not use either of these examples as passwords!

Strong (good) passwords have the following characteristics:

- Contain both upper- and lower-case characters (e.g., a-z, A-Z)
- Have digits and punctuation characters as well as letters (e.g., 0-9, !@#\$%^&*)
- Eight (8) or more alphanumeric characters.
- Not a word in any language, slang, dialect, or jargon.
- Not based on personal information, names of family, or important calendar dates.

Weak (bad) passwords have the following characteristics:

- Default vendor password
- Contain less than seven (7) characters
- A word found in a dictionary (English or foreign)
- A common usage word such as:
 - Names of family, pets, friends, co-workers, fantasy characters, etc.
 - Computer terms and names, commands, sites, companies, hardware, software.
- The words "KR" or any derivation.
- Birthdays and other personal information such as addresses and phone numbers.
- Word or number patterns (e.g., aaabbb, qwerty, zyxwvuts or 123321)
- Any of the above spelled backward.
- Any of the above preceded or followed by a digit (e.g., secret1 or 1secret)

KR staff may perform password cracking on a periodic or random basis as part of the firm's security testing procedures. If a password is guessed or cracked during one of these events, the user will be required to change it immediately.

5.2.2.2 ROLE-BASED ACCESS CONTROL (RBAC)

Control Objective: Information systems enforce a Role-Based Access Control (RBAC) policy over users and information resources and controls access based upon roles and users authorized to assume such roles.⁷⁶

Standard: KR is required to establish Role-Based Access Control (RBAC) access enforcement that:

- (a) Assigns privileges to individuals based on job classification and function; and
- (b) Restricts access based on a user's need to know and is set to "deny all" unless specifically allowed.

⁷⁶ HIPAA 164.308(a)(4)(ii)(A) & (B) & (C) | PCI DSS (v3.2) 7.1, 7.1.1-7.1.4, 7.2, 7.2.1 & 7.2.3

Supplemental Guidance: RBAC is a type of Discretionary Access Control (DAC).

5.2.3 MANAGEMENT OF PRIVILEGED ACCESS RIGHTS

The allocation and use of privileged access rights should be restricted and controlled.⁷⁷

5.2.3.1 PRIVILEGED COMMANDS & ACCESS

Control Objective: The firm authorizes the execution of privileged commands and access to security-relevant information via remote access only for compelling operational needs and documents the rationale for such access in the security plan for the information system.

Standard: KR authorizes the execution of privileged commands and access to security-relevant information via remote access only for compelling operational needs.

Supplemental Guidance: None

5.2.4 MANAGEMENT OF SECRET AUTHENTICATION INFORMATION OF USERS

The allocation of secret authentication information should be controlled through a formal management process.⁷⁸

5.2.4.1 USER IDENTIFICATION & AUTHENTICATION FOR ORGANIZATIONAL USERS

Control Objective: Information systems uniquely identify and authenticate organizational users or processes to:⁷⁹

- Allow the use of group authenticators only when used in conjunction with an individual/unique authenticator; and
- Require individuals to be authenticated with an individual authenticator prior to using a group authenticator.

Standard: KR is required to assign all users a unique identification (ID) before allowing them to access information systems. In addition to assigning a unique ID, employ at least one of the following methods to authenticate all users:

- (a) Something you know, such as a password or passphrase;
- (b) Something you have, such as a token device or smart card; or
- (c) Something you are, such as a biometric.

Supplemental Guidance: Organizational users include employees or individuals that KR deems to have the equivalent status of employees (e.g., contractors, consultants).

5.2.4.2 IDENTIFIER MANAGEMENT (USERNAMES)

Control Objective: The firm manages information system identifiers for users and devices by:⁸⁰

- Receiving authorization from a designated organizational official to assign a user or device identifier;
- Selecting an identifier that uniquely identifies an individual or device;
- Assigning the user identifier to the intended party or the device identifier to the intended device; and
- Preventing reuse of user or device identifiers.

Standard: KR is required to ensure proper user identification and authentication management for all standard and privileged users on all information systems, as follows:

- (a) Ensure that only authorized users are provided with user IDs;
- (b) Ensure that usernames and service accounts are uniquely named and, in a manner, consistent with organizationally defined guidelines; and
- (c) Require written authorization by a supervisor or manager to receive a user ID.

Supplemental Guidance: Management of individual identifiers is not applicable to shared information system accounts (e.g., guest and anonymous accounts). Typically, individual identifiers are the names of the information system accounts associated with those

⁷⁷ ISO/IEC 27002:2013 – 9.2.3

⁷⁸ ISO/IEC 27002:2013 – 9.2.4

⁷⁹ PCI DSS (v3.2) 8.1.1 & 8.2 | MA201CMR17 17.04(1)(c) & 17.04(2)(b)

⁸⁰ HIPAA 164.312(a)(2)(i) | MA201CMR17 17.04(1)(d)

individuals. Preventing reuse of identifiers implies preventing the assignment of a previously used individual, group, role, or device identifiers to different individuals, groups, roles, or devices.

5.2.4.3 PRIVILEGED ACCOUNT MANAGEMENT

Control Objective: The firm manages information system identifiers for privileged users by:

- Receiving authorization from a designated organizational official to assign a privileged user identifier; and
- Selecting an identifier that uniquely identifies the privileged user;

Standard: KR requires privileged user accounts be:

- (a) A unique account, separate from a standard user account; and
- (b) Used only when necessary for running privileged functions.

Supplemental Guidance: An example of uniqueness, the difference can be adding a designator to the end of the username, such as an "A" for administrator. Examples include:

- Standard user named John Smith: JSMITH1
- Privileged user named John Smith: A.JSMITH1

Security and system administration personnel with elevated privileges have significant access to processes and data in information systems. As such, Security, Network, Systems, and Database Administrators have added responsibilities to ensure the secure operation of any KR system.

Personnel with elevated privileges are expected to:

- Advise the asset owner on matters concerning information security.
- Assist the asset owner in developing security plans, risk assessments, and supporting documentation for the certification and accreditation process.
- Ensure that any changes to any information system that affect contingency and disaster recovery plans are conveyed to the asset custodian responsible for maintaining continuity of operations plans for that information system.
- Ensure that adequate physical and technical safeguards are operational within their areas of responsibility and that access to information and data is restricted to authorized personnel on a need to know basis.
- Verify that users have received appropriate security training before allowing access to any information system.
- Implement applicable security access procedures and mechanisms, incorporate appropriate levels of system auditing, and review audit logs.
- Document and investigate known or suspected security incidents or violations and report them to the CISO.

5.2.4.4 IDENTIFICATION & AUTHENTICATION (NON-ORGANIZATIONAL USERS)

Control Objective: Information systems uniquely identify and authenticate non-organizational users (or processes acting on behalf of non-organizational users).

Standard: Where technically feasible, asset custodians are required to assign non-KR users with unique identifiers in both usernames and email addresses to clarify the user is not directly employed by KR.

Supplemental Guidance: KR should use risk assessments to determine authentication needs and consider scalability, practicality, and security in balancing the need to ensure ease of use for access to federal information and information systems with the need to protect and adequately mitigate risk.

5.2.4.5 SERVICE PROVIDER IDENTIFICATION & AUTHENTICATION (VENDORS)

Control Objective: The firm identifies and authenticates service provider information system services using security safeguards.

Standard: Where technically feasible, asset custodians are required to implement mechanisms to authenticate traffic from external information service providers that connect to KR's networks.

Supplemental Guidance: This control supports service-oriented architectures and other distributed, architectural approaches requiring the identification and authentication of information system services. In such architectures, external services often appear dynamically. Therefore, information systems should be able to determine in a dynamic manner, if external providers and associated services are authentic. Safeguards implemented by organizational information systems to validate provider and service authenticity

include, for example, information or code signing, provenance graphs, and/or electronic signatures indicating or including the sources of services.

5.2.5 REVIEW OF USER ACCESS RIGHTS

Asset owners should review users' access rights at regular intervals.⁸¹

5.2.5.1 PERIODIC REVIEW

Control Objective: The firm:

- Reviews information systems prior to production use to identify unnecessary and non-secure functions, ports, protocols, and services; and
- Disables organization-defined functions, ports, protocols, and services within information systems deemed to be unnecessary or non-secure.

Standard: Asset custodians and data owners are required to:

- (a) Periodically review their information systems to identify non-secure functions, ports, protocols, and services; and
- (b) Disable unnecessary and non-secure functions, ports, protocols, and services.

Supplemental Guidance: The firm can either make a determination of the relative security of the function, port, protocol, and/or service or base the security decision on the assessment of other entities. Bluetooth, FTP, and peer-to-peer networking are examples of less than secure protocols.

5.2.6 REMOVAL OR ADJUSTMENT OF ACCESS RIGHTS

The access rights of all employees and external party users to information and information processing facilities should be removed upon termination of their employment, contract or agreement, or adjusted upon change.⁸²

5.2.6.1 ACCESS ENFORCEMENT

Control Objective: Information systems enforce approved authorizations for logical access to the system in accordance with applicable policy.⁸³

Standard: KR is required to limit access to information systems and sensitive data to only those individuals whose job requires such access.

Supplemental Guidance: Access limitations should include the following:

- Restriction of access rights to privileged user IDs to least privileges necessary to perform job responsibilities;
- Assignment of privileges is based on individual personnel's job classification and function;
- Requirement for a documented approval by authorized parties specifying required privileges; and
- Implementation of an automated access control system.

5.3 User Responsibilities

The objective is to make users accountable for safeguarding their authentication information.⁸⁴

5.3.1 USE OF SECRET AUTHENTICATION INFORMATION

Users should be required to follow the firm's practices in the use of secret authentication information.⁸⁵

⁸¹ ISO/IEC 27002:2013 – 9.2.5

⁸² ISO/IEC 27002:2013 – 9.2.6

⁸³ HIPAA 164.308(a)(4)(i) & (ii) | PCI DSS (v3.2) 7.1, 7.1.1-7.1.4, 7.2, 7.2.1 & 7.2.3 | MA201CMR17 17.04(1)(b) & 17.04(2)(a) | OR646A.622(2)(d)(C)(iii) | NIST Cybersecurity Framework PR.AM-3, PR.AC-4 & PR.PT-3

⁸⁴ ISO/IEC 27002:2013 – 9.3

⁸⁵ ISO/IEC 27002:2013 – 9.3.1

5.3.1.1 INDIVIDUAL CREDENTIALS

Control Objective: The firm ensures authentication mechanisms are used (e.g., passwords, passphrases, physical or logical security tokens, smart cards, certificates, etc.) are assigned.⁸⁶

Standard: Where other authentication mechanisms are used (e.g., physical or logical security tokens, smart cards, certificates, etc.), use of these mechanisms must be assigned as follows:

- (a) Authentication mechanisms must be assigned to an individual account and not shared among multiple accounts.
- (b) Physical and/or logical controls must be in place to ensure only the intended account can use that mechanism to gain access.

Supplemental Guidance: If user authentication mechanisms such as tokens, smart cards, and certificates can be used by multiple accounts, it may be impossible to identify the individual using the authentication mechanism. Having physical and/or logical controls (e.g., a PIN, biometric data, or a password) to uniquely identify the user of the account will prevent unauthorized users from gaining access through the use of a shared authentication mechanism.

5.3.1.2 CREDENTIAL SHARING

Control Objective: The firm does not use group, shared, or generic IDs, passwords, or other generic authentication methods.⁸⁷

Standard: Asset custodians are prohibited from using group, shared, or generic IDs, passwords, or other authentication methods as follows:

- (a) Generic user IDs must be disabled or removed;
- (b) Shared user IDs must not exist for system administration and other critical functions;
- (c) Shared and generic user IDs must not be used to administer any system components; and
- (d) Service providers with remote access to customer premises (e.g., for support of POS systems or servers) must use a unique authentication credential (such as a password/phrase) for each customer.

Supplemental Guidance: If multiple users share the same authentication credentials (e.g., user account and password), it becomes impossible to trace system access and activities to an individual. This, in turn, prevents an entity from assigning accountability for, or having effective logging of, an individual's actions, since a given action could have been performed by anyone in the group that has knowledge of the authentication credentials.

5.4 System and Application Access Control

The objective is to prevent unauthorized access to systems and applications.⁸⁸

5.4.1 INFORMATION ACCESS RESTRICTION

Access to information and application system functions should be restricted in accordance with the access control policy.⁸⁹

5.4.1.1 ACCESS CONTROL LISTS (ACLs)

Control Objective: The firm implements an access control system for systems components with multiple users that restricts access based on a user's need to know, and is set to "deny all," unless specifically allowed.⁹⁰

Standard: Asset custodians are required to ensure systems components are configured to restrict access based on a user's need to know and is set to "deny all" unless specifically allowed. This access control system must include the following:

- (a) Coverage of all system components;
- (b) Assignment of privileges to individuals based on job classification and function (RBAC); and
- (c) Default "deny-all" setting.

⁸⁶ PCI DSS (v3.2) 8.6

⁸⁷ PCI DSS (v3.2) 8.5-8.5.1

⁸⁸ ISO/IEC 27002:2013 – 9.4

⁸⁹ ISO/IEC 27002:2013 – 9.4.1

⁹⁰ PCI DSS (v3.2) 7.2-7.2.3

Supplemental Guidance: Without a mechanism to restrict access based on user's need to know, a user may unknowingly be granted access to data. An access control system automates the process of restricting access and assigning privileges. Additionally, a default "deny-all" setting ensures no one is granted access until and unless a rule is established specifically granting such access.

Vendor manuals should be used to validate setting, since some access control systems are set by default to "allow-all," thereby permitting access unless/until a rule is written to specifically deny it.

5.4.2 SECURE LOG-ON PROCEDURES

Where required by the access control policy, access to systems and applications should be controlled by a secure log-on procedure.⁹¹

5.4.2.1 TRUSTED COMMUNICATIONS PATH

Control Objective: Information systems establish a trusted communications path between the user and the security functions of the system.

Standard: Where technically feasible, information systems must authenticate with Active Directory (AD).

Supplemental Guidance: A trusted path is simply some mechanism that provides confidence that the user is communicating with what the user intended to communicate with, ensuring that attackers can't intercept or modify whatever information is being communicated. The traditional example is a "fake login" program (e.g., a program is written to look like the login screen of a system) where users try to log in, the fake login program can then capture user passwords for later use.

Microsoft's Active Directory provides a trusted path to its login window by requiring the user to press Ctrl+Alt+Del. This key sequence causes a non-maskable interrupt that can only be intercepted by the operating system, thus guaranteeing that the login window cannot be spoofed by any application.

5.4.2.2 DEVICE-TO-DEVICE IDENTIFICATION & AUTHENTICATION

Control Objective: Information systems uniquely identify and authenticate devices before establishing a connection.

Standard: KR is required to use Active Directory (AD) to authenticate devices before establishing network connections using bidirectional authentication between devices that is cryptographically based.

Supplemental Guidance: Organizational devices requiring unique device-to-device identification and authentication may be defined by type, by the device, or by a combination of type/device. Information systems typically use either shared known information (e.g., Media Access Control (MAC) or Transmission Control Protocol/Internet Protocol (TCP/IP) addresses) for device identification or organizational authentication solutions (e.g., Kerberos, IEEE 802.1x and Extensible Authentication Protocol (EAP), Radius server with EAP-Transport Layer Security (TLS) authentication) to identify/authenticate devices on local and/or wide-area networks. Organizations determine the required strength of authentication mechanisms by the security categories of information systems.

5.4.2.3 SYSTEM USE NOTIFICATION (LOGON BANNERS)

Control Objective: Information systems:

- Display an approved system use notification message or banner before granting access to the system that provides privacy and security notices; and
- Retain the notification message or banner on the screen until users take explicit actions to log on to or further access the information system.

Standard: Where technically feasible, system use notifications are required to be presented to users on information systems.

Supplemental Guidance: System use notifications can be implemented using warning banners displayed when individuals log into information systems. System use notifications are only used for access via interactive login interfaces with human users and are not required when interactive login interfaces do not exist.

⁹¹ ISO/IEC 27002:2013 – 9.4.2

5.4.3 PASSWORD MANAGEMENT SYSTEM

Password management systems should be interactive and should ensure quality passwords.⁹²

5.4.3.1 AUTHENTICATOR MANAGEMENT (PASSWORDS)

Control Objective: The firm manages information system authenticators for users and devices by:⁹³

- Verifying, as part of the initial authenticator distribution, the identity of the individual and/or device receiving the authenticator;
- Ensuring that authenticators have sufficient strength of mechanism for their intended use;
- Establishing and implementing administrative procedures for initial authenticator distribution, for lost/compromised or damaged authenticators, and for revoking authenticators;
- Changing default content of authenticators upon information system installation;
- Establishing minimum and maximum lifetime restrictions and reuse conditions for authenticators (if appropriate);
- Changing/refreshing authenticators according to an organization-defined time period by authenticator type;
- Protecting authenticator content from unauthorized disclosure and modification; and
- Requiring users to take, and having devices implement, specific measures to safeguard authenticators.

Standard: KR manages information system accounts (authenticators) for users and devices by the following:

(a) User Accounts:

- i. Password Length: Minimum of eight (8) characters
- ii. Password Reuse: Five (5) (users cannot use any of the last five (5) password he or she have used)
- iii. Password Life:
 1. Maximum: Ninety (90) days
 2. Minimum: One (1) day
- iv. Password Complexity:
 1. Passwords are not a derivative of the user ID
 2. Passwords have at least one (1) lower alpha, one (1) upper alpha, one (1) number, and one (1) special character.
 3. Passwords cannot contain two identical, consecutive characters

(b) Service Accounts:

If technically feasible, the following should be followed:

- i. Password Length: Minimum of eight (8) characters
- ii. Password Reuse: Ten (10) (service accounts cannot use any of the last ten (10) password he or she have used)
- iii. Password Life:
 1. Maximum: Three hundred sixty-five (365) days
 2. Minimum: One (1) day
- iv. Password Complexity:
 1. Passwords are not a derivative of the user ID
 2. Passwords have at least one (1) lower alpha, one (1) upper alpha, one (1) number, and one (1) special character.
 3. Passwords cannot contain two identical, consecutive characters

(c) Password Protection:

- i. Do not use the same password for KR accounts as for other non-KR access (e.g., personal ISP account, online banking, benefits, etc.). Users must not use the same password for various KR access needs and are required to have unique passwords for each account they access.
- ii. Do not share KR passwords with anyone, including administrative assistants or secretaries. All passwords are to be treated as Restricted, Confidential KR information.
- iii. Prohibited password practices:
 1. Do not use default vendor passwords
 2. Do not reveal a password over the phone to anyone for any reason
 3. Do not reveal a password in an e-mail message
 4. Do not reveal a password to a co-worker or supervisor

⁹² ISO/IEC 27002:2013 – 9.4.3

⁹³ HIPAA 164.308(a)(5)(ii)(D) | PCI DSS (v3.2) 8.1.2, 8.2.3, 8.2.4 & 8.2.5 | MA201CMR17 17.04(1)(b)-(e) & 17.04(2)(b)

5. Do not talk about a password in front of others
6. Do not hint at the format of a password (e.g., "my family name")
7. Do not reveal a password on questionnaires or security forms
8. Do not share a password with family members
9. Do not write passwords down and store them anywhere in the user's office
10. Do not store passwords in a file on any information asset without encryption

(d) Compromise:

- i. If an account or password is suspected to have been compromised, report the incident to management and change all passwords immediately.

Supplemental Guidance: Individual authenticators include, for example, passwords, tokens, biometrics, PKI certificates, and key cards. Initial authenticator content is the actual content (e.g., the initial password) as opposed to requirements about authenticator content (e.g., minimum password length). In many cases, developers ship information system components with factory default authentication credentials to allow for initial installation and configuration. Default authentication credentials are often well known, easily discoverable, and present a significant security risk. Information systems support individual authenticator management by organization-defined settings and restrictions for various authenticator characteristics including, for example, minimum password length, password composition, validation time window for time synchronous one-time tokens, and a number of allowed rejections during verification stage of biometric authentication. Specific actions to safeguard authenticators include, for example, maintaining possession of individual authenticators, not loaning or sharing authenticators with others, and reporting lost or compromised authenticators immediately. Authenticator management includes issuing and revoking, when no longer needed, authenticators for temporary access such as that required for remote maintenance. Device authenticators include, for example, certificates and passwords.

Passwords should never be written down or stored on-line in an unencrypted format. Users must create passwords that can be easily remembered. One way to do this is to create a password based on a song title, affirmation, or another phrase. For example, the phrase might be: "This May Be One Way To Remember" and the password could be: "TmB1w2R!" or "Tmb1W>r~" or some other variation. NOTE: Do not use either of these examples as passwords!

Strong (good) passwords have the following characteristics:

- Contain both upper- and lower-case characters (e.g., a-z, A-Z)
- Have digits and punctuation characters as well as letters (e.g., 0-9, !@#\$%^&*)
- Eight (8) or more alphanumeric characters.
- Not a word in any language, slang, dialect, or jargon.
- Not based on personal information, names of family, or important calendar dates.

Weak (bad) passwords have the following characteristics:

- Default vendor password
- Contain less than eight (8) characters
- A word found in a dictionary (English or foreign)
- A common usage word such as:
 - Names of family, pets, friends, co-workers, fantasy characters, etc.
 - Computer terms and names, commands, sites, companies, hardware, software.
- The words "KR" or any derivation.
- Birthdays and other personal information such as addresses and phone numbers.
- Word or number patterns (e.g., aaabbb, qwerty, zyxwvuts or 123321)
- Any of the above spelled backward.
- Any of the above preceded or followed by a digit (e.g., secret1 or 1secret)

KR staff may perform password cracking on a periodic or random basis as part of the firms's security testing procedures. If a password is guessed or cracked during one of these events, the user will be required to change it immediately.

5.4.3.2 VENDOR-SUPPLIED DEFAULTS

Control Objective: The firm changes vendor-supplied defaults before installing a system on the network, including but not limited to passwords, Simple Network Management Protocol (SNMP) strings, and eliminate unnecessary accounts.⁹⁴

Standard: Asset custodians and data owners are required to changes vendor-supplied defaults before installing a system on the network, including but not limited to:

- (a) Passwords;
- (b) Encryption keys;
- (c) Simple Network Management Protocol (SNMP) strings; and
- (d) Removing unnecessary, default accounts.

Supplemental Guidance: None

5.4.3.3 AUTHENTICATOR FEEDBACK

Control Objective: Information systems obscure feedback of authentication information during the authentication process to protect the information from possible exploitation/use by unauthorized individuals.

Standard: Asset custodians and data owners are required to ensure all information systems and applications obscure the visible feedback of authentication information (e.g., passwords) during the authentication process to protect the information from possible exploitation by unauthorized individuals.

Supplemental Guidance: The feedback from information systems does not provide information that would allow unauthorized individuals to compromise authentication mechanisms. Obscuring the feedback of authentication information includes, for example, displaying asterisks when users type passwords into input devices.

5.4.3.4 CRYPTOGRAPHIC MODULE AUTHENTICATION

Control Objective: Information systems use mechanisms for authentication to a cryptographic module that meet the requirements of applicable local, state, and federal laws, as well as non-regulatory requirements that the firm is contractually bound to address.⁹⁵

Standard: Asset custodians and data owners are required to ensure all information systems and applications use strong cryptography to render all passwords unreadable during transmission and storage on all information system components.

Supplemental Guidance: This control reinforces the requirements for organizational information systems implementing cryptographic protections using cryptographic modules. If cryptography is required, information systems are required to authenticate to the associated cryptographic modules implementing the cryptography.

The National Institute of Standards and Technology (NIST) guidance is the authoritative source for selection and implementation of this control based on the security categorization and risk environment of the data and/or information system.

5.4.3.5 RE-AUTHENTICATION

Control Objective: The firm requires users and devices to re-authenticate when circumstances or situations requiring re-authentication.⁹⁶

Standard: Asset custodians and data owners are required to configure information systems to terminate sessions and require users to re-authenticate to re-activate a terminal or session if a session has been idle for more than fifteen (15) minutes.

Supplemental Guidance: In addition to the re-authentication requirements associated with session locks, organizations may require re-authentication of individuals and/or devices in other situations including, for example:

- When authenticators change;
- When roles change;

⁹⁴ PCI DSS (v3.2) 2.1, 2.1.1 & 8.3

⁹⁵ PCI DSS (v3.2) 8.2.1

⁹⁶ PCI DSS (v3.2) 8.1.8

- When security categories of information systems change;
- When the execution of privileged functions occurs;
- After a fixed period of time; or periodically.

5.4.4 USE OF PRIVILEGED UTILITY PROGRAMS

The use of utility programs that might be capable of overriding system and application controls should be restricted and tightly controlled.⁹⁷

5.4.4.1 ACCESS ENFORCEMENT

Control Objective: Information systems enforce approved authorizations for logical access to the system in accordance with applicable policy.⁹⁸

Standard: KR is required to limit access to information systems and sensitive data to only those individuals whose job requires such access.

Supplemental Guidance: Access limitations should include the following:

- Restriction of access rights to privileged user IDs to least privileges necessary to perform job responsibilities;
- Assignment of privileges is based on individual personnel's job classification and function;
- Requirement for a documented approval by authorized parties specifying required privileges; and
- Implementation of an automated access control system.

5.4.4.2 LEAST PRIVILEGE

Control Objective: The firm employs the concept of least privilege, allowing only authorized accesses for users and processes which are necessary to accomplish assigned tasks in accordance with organizational business functions.⁹⁹

Standard: KR follows the "principle of least privilege,"¹⁰⁰ which states that only the minimum access necessary to perform an operation should be granted. Access will be granted only for the minimum:

- (a) Levels of permissions necessary to perform the job function; and
- (b) Time required.

Supplemental Guidance: KR employs the concept of least privilege for specific duties and information systems (including specific functions, ports, protocols, and services). The concept of least privilege is also applied to information system processes, ensuring that the processes operate at privilege levels no higher than necessary to accomplish required organizational missions and/or functions. KR considers the creation of additional processes, roles, and information system accounts as necessary to achieve least privilege. KR also applies least privilege concepts to the design, development, implementation, and operations of information systems.

5.4.5 ACCESS CONTROL TO PROGRAM SOURCE CODE

Access to program source code should be restricted.¹⁰¹

5.4.5.1 SOURCE CODE

Control Objective: The firm obtains the source code for custom-developed applications.

Standard: Developers are required to provide asset owners with source code for custom-developed applications.

⁹⁷ ISO/IEC 27002:2013 – 9.4.4

⁹⁸ HIPAA 164.308(a)(4)(i) & (ii) | PCI DSS (v3.2) 7.1, 7.1.1-7.1.4, 7.2, 7.2.1 & 7.2.3 | MA201CMR17 17.04(1)(b) & 17.04(2)(a) | OR646A.622(2)(d)(C)(iii) | NIST Cybersecurity Framework PR.AM-3, PR.AC-4 & PR.PT-3

⁹⁹ OR646A.622(2)(d)(C)(iii) | NIST Cybersecurity Framework PR.AC-4 & PR.DS-5

¹⁰⁰ Saltzer, Jerome H. & Schroeder, Michael D. "The Protection of Information in Computer Systems." Proceedings of the IEEE 63, 9 (September 1975): 1278-1308.

¹⁰¹ ISO/IEC 27002:2013 – 9.4.5

Supplemental Guidance: Asset owners are responsible for securely maintaining the source code over the SDLC of information systems / applications.

5.4.5.2 LIBRARY PRIVILEGES

Control Objective: The firm limits privileges to change software resident within software libraries.

Standard: Data owners are required to limit privileges to change software archived within software libraries.

Supplemental Guidance: Software libraries include privileged programs.

6.0 Cryptography Policy

KR shall ensure appropriate cryptographic safeguards are in place to protect sensitive business data against loss, unauthorized access, or disclosure.

Management Intent: The purpose of this policy is to ensure the confidentiality of KR's data through implementing appropriate cryptographic technologies to protect information systems and data.

6.1 Cryptographic Controls

The objective is to ensure proper and effective use of cryptography to protect the confidentiality, authenticity and/or integrity of information.¹⁰²

6.1.1 USE OF CRYPTOGRAPHIC CONTROLS

A policy on the use of cryptographic controls for protection of information should be developed and implemented.¹⁰³

6.1.1.1 USE OF CRYPTOGRAPHY

Control Objective: Information systems implement required cryptographic protections using cryptographic modules that comply with applicable local, state, and federal laws, as well as non-regulatory requirements that the firm is contractually bound to address.

¹⁰⁴

Standard: Asset custodians and data owners are required to ensure information systems storing, processing or transmitting sensitive information:

- (a) Employ cryptographic mechanisms;
- (b) Use strong cryptography and security protocols (for example, TLS, IPSEC, SSH, etc.) to safeguard sensitive data during transmission over public or private networks;
- (c) Verify that the proper encryption strength is implemented for the encryption methodology in use, based on documented vendor recommendations and industry-recognized leading practices; and
- (d) Verify that the protocol is implemented to use only secure configurations and does not support insecure versions or configurations.

Supplemental Guidance: This control does not impose any requirements on organizations to use cryptography. Rather, if cryptography is required based on the selection of other controls and subsequently implemented by organizational information systems, the cryptographic modules comply with applicable laws, policies, regulations, standards, and guidance.

The National Institute of Standards and Technology (NIST) guidance is the authoritative source for selection and implementation of this control based on the security categorization and risk environment of the data and/or information system.

6.1.1.2 TRANSMISSION CONFIDENTIALITY

Control Objective: The firm protects the confidentiality of transmitted information.¹⁰⁵

Standard: Asset custodians and data owners are required to employ cryptographic mechanisms to prevent unauthorized disclosure of information during transmission.

Supplemental Guidance: This control applies to both internal and external networks. For distributed systems including, for example, service-oriented architectures, this control applies to end-to-end confidentiality between the system components/services originating the transmitted information and the system components/services receiving the transmitted information. Organizations relying on commercial service providers offering transmission services as commodity items rather than as fully dedicated services may find it difficult to obtain the necessary assurances regarding the implementation of needed security controls for transmission

¹⁰² ISO/IEC 27002:2013 – 10.1

¹⁰³ ISO/IEC 27002:2013 – 10.1.1

¹⁰⁴ HIPAA 164.312(e)(2)(ii) | PCI DSS (v3.2) 2.2.3 & 4.1 | NIST Cybersecurity Framework PR.DS-5

¹⁰⁵ HIPAA 164.312(e)(1) & 164.312(e)(2)(i) | MA201CMR17 17.04(3) | OR646A.622(2)(d)(C)(iii)

confidentiality. When it is infeasible or impractical to obtain the necessary security controls and assurances of control effectiveness through appropriate contracting vehicles, organizations implement appropriate compensating security controls or explicitly accept the additional risk.

The National Institute of Standards and Technology (NIST) guidance is the authoritative source for selection and implementation of this control based on the security categorization and risk environment of the information and/or information system.

6.1.1.3 NON-LOCAL MAINTENANCE CRYPTOGRAPHIC PROTECTION

Control Objective: The firm employs cryptographic mechanisms to protect the integrity and confidentiality of non-local maintenance and diagnostic communications.¹⁰⁶

Standard: Asset custodians are required to use technologies that incorporate strong encryption for non-console administrative access.

Supplemental Guidance: KR should use technologies such as SSH, VPN, or TLS for web-based management and other non-console administrative access to protect the integrity and confidentiality of non-local maintenance and diagnostic communications.

6.1.1.4 ENCRYPTING DATA AT REST

Control Objective: Information systems protect the confidentiality and integrity of information at rest.¹⁰⁷

Standard: Asset custodians and data owners are required to protect sensitive information by:

- (a) Employing cryptographic mechanisms to prevent unauthorized disclosure and modification of information at rest unless otherwise protected by alternative physical measures.
 - i. If disk encryption is used (rather than file- or column-level database encryption), logical access must be managed independently of native operating system access control mechanisms (for example, by not using local user account databases);
- (b) Rendering sensitive data unreadable anywhere it is stored; and
- (c) Not tying user accounts to decryption keys.

Supplemental Guidance: This control addresses the confidentiality and integrity of information at rest and covers user information and system information. Information at rest refers to the state of information when it is located on storage devices as specific components of information systems. System-related information requiring protection includes, for example, configurations or rule sets for firewalls, gateways, intrusion detection/prevention systems, filtering routers, and authenticator content. Organizations may employ different mechanisms to achieve confidentiality and integrity protections. Organizations may also employ other security controls including, for example, secure off-line storage in lieu of online storage when adequate protection of information at rest cannot otherwise be achieved.

6.1.1.5 NON-CONSOLE ADMINISTRATIVE ACCESS

Control Objective: The firm encrypts all non-console administrative access using strong cryptography.¹⁰⁸

Standard: Asset custodians are responsible for developing configuration standards to ensure all non-console administrative access is encrypting using strong cryptography using technologies such as SSH, VPN, or TLS for web-based management and other non-console administrative access.

Supplemental Guidance: Examples of insecure services, protocols, or ports include but are not limited to:

- File Transfer Protocol (FTP);
- Telnet; and
- Post Office Protocol 3 (POP3).

¹⁰⁶ PCI DSS (v3.2) 2.3

¹⁰⁷ HIPAA 164.312(a)(2)(iv) | PCI DSS (v3.2) 3.4 & 3.4.1 | MA201CMR17 17.04(5) | OR646A.622(2)(d)(C)(iii) | NIST Cybersecurity Framework PR.DS-1

¹⁰⁸ PCI DSS (v3.2) 2.3

6.1.2 KEY MANAGEMENT

A policy on the use, protection and lifetime of cryptographic keys should be developed and implemented through their whole lifecycle.¹⁰⁹

6.1.2.1 KEY MANAGEMENT PROCESSES

Control Objective: The firm documents and implements key management processes and procedures for cryptographic keys used for encryption of data.¹¹⁰

Standard: Asset custodians are required to document and implement key management processes and procedures for cryptographic keys used for encryption of data that includes the following:

- (a) Procedures for the generation, distribution, and storage of keys:
 - 1. Generation of strong cryptographic keys;
 - 2. Prevention of unauthorized substitution of cryptographic keys;
 - 3. Distribution of cryptographic keys using secure methods; and
 - 4. Secure storage of cryptographic keys;
- (b) Changing cryptographic keys that have reached the end of their cryptoperiod:
 - 1. After a defined period of time has passed and/or after a certain amount of ciphertext has been produced by a given key;
 - 2. As defined by the associated application vendor or key owner; or
 - 3. Based on industry-recognized leading practices and guidelines (e.g., NIST Special Publication 800-57).
- (c) Retiring or replacing keys when the integrity of the key has been weakened or the keys are suspected of being compromised:
 - 1. Retiring or replacing may be performed by archiving, destruction, and/or revocation of keys.
 - 2. Keys should be considered compromised by the departure of an employee with knowledge of a clear-text key.
- (d) Split knowledge and dual control, if manual, clear-text cryptographic key management operations are used. If applicable, these operations require procedures that require two or three people, each knowing only their own key component, to reconstruct the whole key; and
- (e) Requiring cryptographic key custodians to formally acknowledge that they understand and accept their key-custodian responsibilities.

Supplemental Guidance: Numerous industry standards for key management are available from various resources including NIST, which can be found at <http://csrc.nist.gov>.

¹⁰⁹ ISO/IEC 27002:2013 – 10.1.2

¹¹⁰ PCI DSS (v3.2) 3.6-3.6.8

7.0 Physical and Environmental Security Policy

KR shall ensure physical access controls are in place to limit physical access to authorized personnel and provide appropriate environmental controls to protect both data and information systems from environmental hazards.

Management Intent: The purpose of this policy is to minimize risk to KR information systems and data by addressing applicable physical security and environmental concerns.

7.1 Secure Areas

The objective is to prevent unauthorized physical access, damage and interference to the firm's information and information processing facilities.¹¹¹

7.1.1 PHYSICAL SECURITY PERIMETER

Security perimeters should be defined and used to protect areas that contain either sensitive or critical information and information processing facilities.¹¹²

7.1.1.1 PHYSICAL ACCESS AUTHORIZATIONS

Control Objective: The firm:¹¹³

- Develops and keeps current a list of personnel with authorized access to the facility where the information system resides (except for those areas within the facility officially designated as publicly accessible);
- Issues authorization credentials; and
- Reviews and approves the access list and removes from the access list personnel no longer requiring access.

Standard: KR is required to:

- (a) Develop and keeps current a list of personnel with authorized access to its facilities, except for those areas within the facility officially designated as publicly accessible;
- (b) Issue authorization credentials for physical access; and
- (c) Review and approve the access list and remove from the access list personnel no longer requiring access.

Supplemental Guidance: This control applies to organizational employees and visitors. Individuals (e.g., employees, contractors, and others) with permanent physical access authorization credentials are not considered visitors. Authorization credentials include, for example, badges, identification cards, and smart cards. Organizations determine the strength of authorization credentials needed (including the level of forge-proof badges, smart cards, or identification cards) consistent with standards, policies, and procedures. This control only applies to areas within facilities that have not been designated as publicly accessible.

7.1.1.2 ROLE-BASED PHYSICAL ACCESS

Control Objective: The firm authorizes physical access to the facility where the information system resides, based on the position or role of a user.¹¹⁴

Standard: KR is required to authorize physical access to its facilities based on position or role.

Supplemental Guidance: KR should restrict physical access to information systems that process sensitive information to authorized personnel with the appropriate roles and access authorizations. Roles for physical access include, but are not limited to:

- Employees
- Contractors
- Vendors
- Partners

¹¹¹ ISO/IEC 27002:2013 – 11.1

¹¹² ISO/IEC 27002:2013 – 11.1.1

¹¹³ HIPAA 164.310(a)(2)(ii) | PCI DSS (v3.2) 9.2 | NIST Cybersecurity Framework PR.AC-2

¹¹⁴ HIPAA 164.310(a)(2)(iii)

- Guests
- Maintenance Personnel
- Cleaning / Janitorial

7.1.1.3 RESTRICT UNESCORTED ACCESS

Control Objective: The firm restricts unescorted access to the facility where the information system resides to personnel with required security clearances, formal access authorizations, and validated the need for access.¹¹⁵

Standard: KR is required to restrict physical access to the information systems equipment and records storage.

Supplemental Guidance: None

7.1.1.4 PHYSICAL ACCESS CONTROL

Control Objective: The firm:¹¹⁶

- Enforces physical access authorizations for all physical access points (including designated entry/exit points) to the facility where the information system resides (excluding those areas within the facility officially designated as publicly accessible);
- Verifies individual access authorizations before granting access to the facility;
- Controls entry to the facility containing the information system using physical access devices and/or guards;
- Controls access to areas officially designated as publicly accessible in accordance with the firm's assessment of risk;
- Secures keys, combinations, and other physical access devices; and
- Changes combinations and keys and when keys are lost, combinations are compromised, or individuals are transferred or terminated.

Standard: KR is required to:

- (a) Use video cameras and/or access control mechanisms to limit and monitor physical access to the facility and information systems;
- (b) Enforce physical access authorizations for all physical access points (including designated entry/exit points) to company-owned or operated facilities;
- (c) Verify individual access authorizations before granting access to the facility;
- (d) Control access to areas based on the physical security zone requirements;
- (e) Secure keys, combinations, and other physical access devices; and
- (f) Change combinations and keys and when keys are lost, when combinations are compromised, or when individuals are transferred or terminated.

Supplemental Guidance: This control applies to organizational employees and visitors. Individuals (e.g., employees, contractors, and others) with permanent physical access authorization credentials are not considered visitors. Organizations determine the types of facility guards needed including, for example, professional physical security staff or other personnel such as administrative staff or information system users. Physical access devices include, for example, keys, locks, combinations, and card readers. Safeguards for publicly accessible areas within organizational facilities include, for example, cameras, monitoring by guards, isolating selected information systems/components in secured areas. Components of information systems (e.g., workstations, computer terminals) may be located in areas designated as publicly accessible with organizations safeguarding access to such devices.

7.1.1.5 LOCKABLE PHYSICAL CASINGS

Control Objective: The firm uses lockable physical casings to protect organization-defined information system components from unauthorized physical access.

Standard: KR is required to protect sensitive information systems from physical tampering or alteration of hardware components by utilizing lockable physical casings.

Supplemental Guidance: Lockable physical casings are primarily associated with rack-mounted hardware.

¹¹⁵ PCI DSS (v3.2) 9.3

¹¹⁶ HIPAA 164.310(a)(2)(iv) | PCI DSS (v3.2) 9.1, 9.1.1, 9.1.2 & 9.2 | MA201CMR17 17.03(2)(g) | OR646A.622(2)(d)(C)(ii) | NIST Cybersecurity Framework PR.AC-2, DE.CM-2, DE.CM-7 & DE.DP-3

7.1.1.6 ACCESS CONTROL FOR TRANSMISSION MEDIUM

Control Objective: The firm controls physical access to information system distribution and transmission lines within organizational facilities.¹¹⁷

Standard: KR management is required to limit physical access to transmission medium to only authorized personnel.

Supplemental Guidance: Physical security safeguards applied to information system distribution and transmission lines help prevent accidental damage, disruption, and physical tampering. Transmission medium includes but are not limited to:

- Publicly accessible network jacks;
- Wireless Access Points (WAPs)
- Border protection devices (including firewalls & routers);
- Networking/communications hardware; and
- Telecommunication lines.

Protective measures to control physical access to information system distribution and transmission lines include:

- Locked wiring closets;
- Disconnected or locked spare jacks; and
- Protection of cabling by conduit or cable trays.

7.1.1.7 ACCESS CONTROL FOR OUTPUT DEVICES

Control Objective: The firm controls physical access to information system output devices to prevent unauthorized individuals from obtaining the output.¹¹⁸

Standard: Physical access to information system output devices must be limited to authorized personnel to prevent unauthorized individuals from obtaining access to unsecured data.

Supplemental Guidance: Controlling physical access to output devices includes, for example, placing output devices in locked rooms or other secured areas and allowing access to authorized individuals only; and placing output devices in locations that can be monitored by organizational personnel. Transmission medium includes but are not limited to:

- Printers;
- Plotters;
- Facsimile (Fax) machines; and
- Photocopiers.

7.1.1.8 MONITORING PHYSICAL ACCESS

Control Objective: The firm:¹¹⁹

- Monitors physical access to the information system to detect and respond to physical security incidents;
- Reviews physical access logs; and
- Coordinates results of reviews and investigations with the firm's incident response capability.

Standard: KR is responsible for:

- (a) Investigating and responding to detected physical security incidents;
- (b) Performing security checks at the physical boundary of the facility or information system for unauthorized exfiltration of information or information system components;
- (c) Using video cameras and/or access control mechanisms to monitor individual physical access to sensitive areas;
- (d) Reviewing collected data and correlate with other entries; and
- (e) Retaining physical access data for at least three (3) months, unless otherwise restricted by law.

Supplemental Guidance: None

¹¹⁷ PCI DSS (v3.2) 9.1.2 & 9.1.3 | OR646A.622(2)(d)(C)(ii) | NIST Cybersecurity Framework PR.AC-2

¹¹⁸ OR646A.622(2)(d)(C)(ii) | NIST Cybersecurity Framework PR.AC-2

¹¹⁹ HIPAA 164.310(c) | OR646A.622(2)(d)(C)(ii) | PCI DSS (v3.2) 9.1 & 9.1.1 | NIST Cybersecurity Framework PR.AC-2, DE.CM-7, RS.AN-1 & RS.CO-3

7.1.1.9 VISITOR CONTROL

Control Objective: The firm controls physical access to the information system by authenticating visitors before authorizing access to the facility where the information system resides other than areas designated as publicly accessible.¹²⁰

Standard: Visitors to KR are required to:

- (a) Be escorted while in KR facilities;
- (b) Receive authorization before they can enter areas where sensitive data is processed or maintained; and

Supplemental Guidance: None

7.1.2 PHYSICAL ENTRY CONTROLS

Secure areas should be protected by appropriate entry controls to ensure that only authorized personnel are allowed access.¹²¹

7.1.2.1 FACILITY ENTRY CONTROLS

Control Objective: The firm implements appropriate facility entry controls to limit and monitor physical access.¹²²

Standard: Asset custodians are required to implement appropriate facility entry controls to limit and monitor physical access to systems, including but not limited to:

- (a) Using video cameras and/or access control mechanisms to monitor individual physical access to sensitive areas. Review collected data and correlate with other entries:
 - 1. Video surveillance footage must be readily accessible for at least three (3) months, unless otherwise restricted by law; and
- (b) Restricting physical access to publicly accessible network jacks, by either:
 - 1. Preventing physical access to the network jack; or
 - 2. Disconnecting unused or publicly accessible network jacks at the patch panel;
- (c) Restricting physical access to Wireless Access Points (WAPs), gateways, handheld devices, networking/communications hardware, and telecommunication lines.

Supplemental Guidance: Access control mechanisms may be as simple as a sign-in sheet to monitor individual access to sensitive areas, if video surveillance capabilities are not available.

7.1.3 SECURING OFFICES, ROOMS AND FACILITIES

Physical security for offices, rooms, and facilities should be designed and applied.¹²³

7.1.3.1 PHYSICAL ACCESS CONTROLS TO SENSITIVE AREAS

Control Objective: The firm implements physical access controls for onsite personnel to sensitive areas.¹²⁴

Standard: KR's Human Resources (HR) department is responsible for controlling physical access for onsite personnel to the sensitive areas as follows:

- (a) Access must be authorized and based on individual job function.
- (b) Access is revoked immediately upon termination, and all physical access mechanisms, such as keys, access cards, etc., are returned or disabled.

Supplemental Guidance: Controlling physical access helps ensure that only authorized personnel with a legitimate business need are granted access. When personnel leave the firm, all physical access mechanisms should be returned or disabled promptly (as soon as possible) upon their departure, to ensure personnel cannot gain physical access once their employment has ended.

¹²⁰ PCI DSS (v3.2) 9.4.2 & 9.4.3 | OR646A.622(2)(d)(C)(ii)

¹²¹ ISO/IEC 27002:2013 – 11.1.2

¹²² PCI DSS (v3.2) 9.1-9.1.3

¹²³ ISO/IEC 27002:2013 – 11.1.3

¹²⁴ PCI DSS (v3.2) 9.3

7.1.3.2 PHYSICALLY SECURE ALL MEDIA

Control Objective: The firm implements procedures to physically secure all media.¹²⁵

Standard: Asset custodians are required to physically secure all media, as follows:

- (a) Store media back-ups in a secure location, preferably an off-site facility, such as:
 - 1. An alternate or backup site; or
 - 2. A commercial storage facility; and
- (b) Review the backup facility's security at least annually.

Supplemental Guidance: Controls for physically securing media are intended to prevent unauthorized persons from gaining access to data on any type of media. Data is susceptible to unauthorized viewing, copying, or scanning if it is unprotected while it is on removable or portable media, printed out, or left on someone's desk. Media includes but is not limited to computers, removable electronic media, paper receipts, paper reports, and faxes.

7.1.4 PROTECTING AGAINST EXTERNAL AND ENVIRONMENTAL THREATS

Physical protection against natural disasters, malicious attack or accidents should be designed and applied.¹²⁶

7.1.4.1 RISK ASSESSMENT

Control Objective: The firm:¹²⁷

- Conducts an annual assessment of risk, including the likelihood and magnitude of harm, from the unauthorized access, use, disclosure, disruption, modification, or destruction of the information system and the information it processes, stores, or transmits;
- Documents risk assessment results in an organization-approved format; and
- Reviews risk assessment results.

Standard: At least once per year or upon significant changes to the networks, KR is required to conduct a formal information security risk assessment for the corporate network that, at the very least, covers the following:

- (a) Identifies:
 - i. Critical assets;
 - ii. Potential natural and man-made threats;
 - iii. Vulnerabilities;
- (b) Documents known vulnerabilities in a formal risk assessment; and
- (c) Assesses current information security controls affecting the confidentiality, integrity, and availability of critical data.

Supplemental Guidance: Risk assessments take into account threats, vulnerabilities, likelihood, and impact to organizational operations and assets, individuals, and other organizations based on the operation and use of information systems. Risk assessments also take into account risk from external parties (e.g., service providers, contractors operating information systems on behalf of the firm, individuals accessing organizational information systems, outsourcing entities).

Risk assessments (formal or informal) can be conducted at all three tiers in the risk management hierarchy (e.g., organization level, mission/business process level, or information system level). Risk assessments can play an important role in security control selection processes particularly during the application of tailoring guidance, which includes security control supplementation.

7.1.4.2 RISK RANKING

Control Objective: The firm will establish a process to identify and assign a risk ranking to newly discovered security vulnerabilities. Risk rankings should be based on industry-recognized leading practices.¹²⁸

Standard: Asset custodians and data owners are required to rank vulnerabilities according to the National Vulnerability Database (NVD) Common Vulnerability Scoring System Support (CVSS) system.

¹²⁵ PCI DSS (v3.2) 9.5-9.5.1

¹²⁶ ISO/IEC 27002:2013 – 11.1.4

¹²⁷ HIPAA 164.308(a)(1)(ii)(A) & (B) | GLBA Safeguards Rule | PCI DSS (v3.2) 12.2 | MA201CMR17 17.03(2)(b) | OR646A.622(2)(A)(ii) | NIST Cybersecurity Framework ID.RA-1, ID.RA-3, ID.RA-4, ID.RA-5, PR.IP-12, DE.AE-4 & RS.MI-3

¹²⁸ National Vulnerability Database (NVD) Common Vulnerability Scoring System (CVSS) <http://nvd.nist.gov/cvss.cfm>

Supplemental Guidance: The NVD provides severity rankings of "Low," "Medium," and "High" in addition to the numeric CVSS scores.

- Vulnerabilities are labeled "Low" severity if they have a CVSS base score of 0.0-3.9.
- Vulnerabilities will be labeled "Medium" severity if they have a base CVSS score of 4.0-6.9.
- Vulnerabilities will be labeled "High" severity if they have a CVSS base score of 7.0-10.0.

7.1.4.3 SECURITY INDUSTRY ALERTS & NOTIFICATION PROCESS

Control Objective: The firm establishes and institutionalizes contact with selected groups and associations within the security community:¹²⁹

- To facilitate ongoing security education and training for organizational personnel;
- To stay up to date with the latest recommended security practices, techniques, and technologies; and
- To share current security-related information including threats, vulnerabilities, and incidents.

Standard: KR personnel responsible for incident response operations are required to subscribe to mailing lists or notification services to maintain awareness of security industry alerts.

Supplemental Guidance: There are five different mailing lists to select from the US-CERT subscription website (<https://forms.us-cert.gov/maillists>). However, the most applicable mailing lists are:

- Technical Cyber Security Alerts. Written for system administrators and experienced users, technical alerts provide timely information about current security issues, vulnerabilities, and exploits.
- Cyber Security Bulletins. Bulletins summarize information that has been published about new security issues and vulnerabilities for the week prior. They are published weekly and are written primarily for system administrators and other technical users.
- Cyber Security Alerts. Written for home, corporate, and new users, these alerts are published in conjunction with technical alerts when there are security issues that affect the general public.

Ongoing contact with security groups and associations is of paramount importance in an environment of rapidly changing technologies and threats. Security groups and associations include, for example, special interest groups, forums, professional associations, news groups, and/or peer groups of security professionals in similar organizations.

7.1.4.4 THREAT ANALYSIS & FLAW REMEDIATION

Control Objective: The firm requires that information system developers and integrators create a Security Test and Evaluation (ST&E) plan and implement the plan under the witness of an independent party.¹³⁰

Standard: Asset custodians and data owners are required to:

- (a) Address new threats and vulnerabilities on an ongoing basis and ensures these applications are protected against known attacks by either of the following methods:
 - i. Reviewing applications via manual or automated application vulnerability security assessment tools or methods, at least annually and after any changes; or
 - ii. Installing an application firewall.
- (b) Verify that public-facing web applications are reviewed (using either manual or automated vulnerability security assessment tools or methods), as follows:
 - i. At least annually;
 - ii. After any changes;
 - iii. By an organization that specializes in application security;
 - iv. That all vulnerabilities are corrected; and
 - v. That the application is re-evaluated after the corrections

Supplemental Guidance: Applications may deviate significantly from the functional and design specifications created during the requirements and design phases of the system development life cycle. Therefore, threat and vulnerability analyses of information technology products and information systems prior to delivery are critical to the effective operation of those products and systems.

¹²⁹ HIPAA 164.308(A)(5)(ii) & (ii)(A) | PCI DSS (v3.2) 6.2 & 12.4

¹³⁰ PCI DSS (v3.2) 6.6

Threat and vulnerability analyses at this phase of the life cycle help ensure that design or implementation changes have been accounted for and that any new vulnerabilities created as a result of those changes have been reviewed and mitigated.

7.1.5 WORKING IN SECURE AREAS

Procedures for working in secure areas should be designed and applied.¹³¹

7.1.5.1 WORKSTATION SECURITY

Control Objective: The firm requires protection of workstations to restrict access to authorized users.

Standard: KR requires the following workplace security precautions:

- (a) Physical media must be properly disposed of, in accordance with document destruction policies;
- (b) All work areas must be cleared of all media containing sensitive data and hard copy information when not occupied;
- (c) Filing cabinets, lockable drawers / overhead cabinets, storage rooms, and any other storage unit containing sensitive data will be locked when not in use; and
- (d) Whiteboards, dry-erase boards, cork boards, writing tablets, and similar common shared work areas will be sanitized (e.g., erased, removed, or shredded) when not in use.

Supplemental Guidance: Physical security zones should be used to determine which areas are more vulnerable to unauthorized use, theft, or viewing of data and appropriate physical safeguards should be implemented.

7.1.6 DELIVERY AND LOADING AREAS

Access points such as delivery and loading areas and other points where unauthorized persons could enter the premises should be controlled and, if possible, isolated from information processing facilities to avoid unauthorized access.¹³²

7.1.6.1 DELIVERY & REMOVAL

Control Objective: The firm authorizes, monitors, and controls types of information system components entering and exiting the facility and maintains records of those items.¹³³

Standard: Information systems are prohibited from being removed from KR facilities without prior, management authorization.

Supplemental Guidance: Effectively enforcing authorizations for entry and exit of information system components may require restricting access to delivery areas and possibly isolating the areas from the information system and media libraries.

Prior to the removal of the information system, the following information needs to be captured:

- Make / model / serial # of the asset
- Owner of the asset
- Reason the asset is being removed from the facility
- Company and name of representative removing the asset
- Estimated return date for the asset, if applicable

7.2 Equipment

The objective is to prevent loss, damage, theft or compromise of assets and interruption to the firm's operations.¹³⁴

7.2.1 EQUIPMENT SITING AND PROTECTION

Equipment should be sited and protected to reduce the risks from environmental threats and hazards, and opportunities for unauthorized access.¹³⁵

¹³¹ ISO/IEC 27002:2013 – 11.1.5

¹³² ISO/IEC 27002:2013 – 11.1.6

¹³³ OR646A.622(2)(d)(C)(ii) | NIST Cybersecurity Framework PR.DS-3

¹³⁴ ISO/IEC 27002:2013 – 11.2

¹³⁵ ISO/IEC 27002:2013 – 11.2.1

7.2.1.1 LOCATION OF INFORMATION SYSTEM COMPONENTS

Control Objective: The firm positions information system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.¹³⁶

Standard: Asset custodians and data owners are required to:

- (a) Plan the location where information systems reside with regard to physical and environmental hazards; and
- (b) Consider the physical and environmental hazards in its risk mitigation strategy.

Supplemental Guidance: Physical and environmental hazards include, for example, flooding, fire, tornados, earthquakes, hurricanes, acts of terrorism, vandalism, electromagnetic pulse, electrical interference, and other forms of incoming electromagnetic radiation. In addition, organizations consider the location of physical entry points where unauthorized individuals, while not being granted access, might nonetheless be in close proximity to information systems and therefore, increase the potential for unauthorized access to organizational communications (e.g., through the use of wireless sniffers or microphones).

7.2.1.2 MEDIA STORAGE

Control Objective: The firm:¹³⁷

- Physically controls and securely stores digital and non-digital media within controlled areas using organization-defined security measures; and
- Protects information system media until the media are destroyed or sanitized using approved equipment, techniques, and procedures.

Standard: KR users are required to:

- (a) Store media back-ups in a secure location, preferably an off-site facility, such as an alternate or backup site, or a commercial storage facility;
- (b) Review the location's security at least annually;
- (c) Physically secure all media;
- (d) Maintain strict control over the storage and accessibility of media; and
- (e) Maintain strict control over the internal or external distribution of any kind of media, including the following:
 - i. Classify media so the sensitivity of the data can be determined.
 - ii. Send the media by secured courier or another delivery method that can be accurately tracked.

Supplemental Guidance: Information system media includes both digital and non-digital media. Digital media includes, for example:

- Portable electronic devices (e.g., laptops, tablets, smartphones, etc.);
- Magnetic tapes;
- External/removable hard drives;
- Flash drives; and
- CDs/DVDs.

7.2.2 SUPPORTING UTILITIES

Equipment should be protected from power failures and other disruptions caused by failures in supporting utilities.¹³⁸

7.2.2.1 AUTOMATIC VOLTAGE CONTROLS

Control Objective: The firm employs automatic voltage controls for critical information system components.

Standard: Asset custodians are required to employ automatic voltage controls for critical information system components.

Supplemental Guidance: Automatic voltage controls may take the form of Uninterruptable Power Supply (UPS) units or built-in voltage regulating systems, native to the electrical distribution system of the facility.

¹³⁶ NIST Cybersecurity Framework PR.IP-5

¹³⁷ HIPAA 164.310(d)(2)(iv) | PCI DSS (v3.2) 9.5, 9.5.1, 9.6, 9.6.1, 9.6.2, 9.7 & 9.9 | MA201CMR17 17.03(2)(c) | OR646A.620 & 622(2)(d)(C)(i) | NIST Cybersecurity Framework PR.PT-2

¹³⁸ ISO/IEC 27002:2013 – 11.2.2

7.2.2.2 EMERGENCY SHUTOFF

Control Objective: The firm: ¹³⁹

- Provides the capability of shutting off power to the information system or individual system components in emergency situations;
- Places emergency shutoff switches or devices in close proximity to information systems or system components to facilitate safe and easy access for personnel; and
- Protects emergency power shutoff capability from unauthorized activation.

Standard: In data center environments, asset custodians are required to:

- (a) Provide the capability of shutting off power to information systems in emergency situations;
- (b) Place emergency shutoff switches or devices in close proximity to information systems or system components to facilitate safe and easy access for personnel; and
- (c) Protect emergency power shutoff capability from unauthorized activation.

Supplemental Guidance: This control applies to facilities containing concentrations of information system resources including, for example, data centers, server rooms, and mainframe computer rooms. This control applies to facilities containing concentrations of information system resources, such as data centers, server rooms, and mainframe computer rooms.

7.2.2.3 EMERGENCY POWER

Control Objective: The firm provides a long-term alternate power supply for the information system that is self-contained and not reliant on external power generation. ¹⁴⁰

Standard: In data center environments, asset custodians are required to provide for a long-term alternate power supply for critical information systems that is capable of maintaining minimally required operational capability in the event of an extended loss of the primary power source.

Supplemental Guidance: Long-term alternate power supplies for the information system may be either manually or automatically activated.

7.2.2.4 EMERGENCY LIGHTING

Control Objective: The firm employs and maintains automatic emergency lighting for the information system that activates in the event of a power outage or disruption and that covers emergency exits and evacuation routes within the facility. ¹⁴¹

Standard: In data center environments, asset custodians are required to provide emergency lighting for all areas within the facility supporting essential missions and business functions.

Supplemental Guidance: None

7.2.2.5 FIRE PROTECTION

Control Objective: The firm employs and maintains fire suppression and detection devices/systems for the information system that are supported by an independent energy source. ¹⁴²

Standard: In data center environments, asset custodians are required to ensure that its facilities undergo annual fire marshal inspections and promptly resolve identified deficiencies.

Supplemental Guidance: Fire suppression and detection devices/systems include, for example, sprinkler systems, handheld fire extinguishers, fixed fire hoses, and smoke detectors.

¹³⁹ NIST Cybersecurity Framework PR.IP-5

¹⁴⁰ NIST Cybersecurity Framework ID.BE-4

¹⁴¹ NIST Cybersecurity Framework PR.IP-5

¹⁴² NIST Cybersecurity Framework PR.IP-5

7.2.2.6 FIRE DETECTION DEVICES

Control Objective: The firm employs fire detection devices/systems for the information system that activate automatically and notify organizational personnel and emergency responders in the event of a fire.

Standard: In data center environments, asset custodians are required to employ fire detection devices that activate automatically and notify organizational personnel and emergency responders in the event of a fire.

Supplemental Guidance: None

7.2.2.7 FIRE SUPPRESSION DEVICES

Control Objective: The firm employs fire suppression devices/systems for the information system that provide automatic notification of any activation to organizational personnel and emergency responders.

Standard: In data center environments, asset custodians are required to employ an automatic fire suppression capability for its critical information systems when the facility is not staffed on a continuous basis.

Supplemental Guidance: None

7.2.2.8 TEMPERATURE & HUMIDITY CONTROLS

Control Objective: The firm:¹⁴³

- Maintains temperature and humidity levels within the facility where the information system resides; and
- Monitors temperature and humidity levels.

Standard: In data center environments, asset custodians are required to employ temperature and humidity monitoring that provides an alarm or notification of changes potentially harmful to personnel or equipment.

Supplemental Guidance: Temperature and humidity controls typically apply to facilities containing concentrations of information system resources, for example, data centers, server rooms, and mainframe computer rooms.

7.2.2.9 WATER DAMAGE PROTECTION

Control Objective: The firm protects the information system from damage resulting from water leakage by providing master shutoff valves that are accessible, working properly, and known to key personnel.¹⁴⁴

Standard: In data center environments, asset custodians are required to employ mechanisms that, without the need for manual intervention, protect information systems from water damage in the event of a water leak.

Supplemental Guidance: Isolation valves can be employed in lieu of master shutoff valves to shut off water supplies in specific areas of concern, without affecting entire organizations.

7.2.3 CABLING SECURITY

Power and telecommunications cabling carrying data or supporting information services should be protected from interception, interference or damage.¹⁴⁵

7.2.3.1 POWER EQUIPMENT & POWER CABLING

Control Objective: The firm protects power equipment and power cabling for the information system from damage and destruction.

¹⁴⁶

¹⁴³ NIST Cybersecurity Framework PR.IP-5

¹⁴⁴ NIST Cybersecurity Framework PR.IP-5

¹⁴⁵ ISO/IEC 27002:2013 – 11.2.3

¹⁴⁶ NIST Cybersecurity Framework ID.BE-4 & PR.AC-2

Standard: Asset custodians are required to protect power equipment and power cabling from damage, tampering, and destruction.

Supplemental Guidance: None

7.2.4 EQUIPMENT MAINTENANCE

Equipment should be correctly maintained to ensure its continued availability and integrity.¹⁴⁷

7.2.4.1 CONTROLLED MAINTENANCE

Control Objective: The firm:¹⁴⁸

- Schedules, performs, documents, and reviews records of maintenance and repairs on information system components in accordance with manufacturer or vendor specifications and/or organizational requirements;
- Controls all maintenance activities, whether performed on site or remotely and whether the equipment is serviced on site or removed to another location;
- Requires explicit management approval for the removal of the information system or system components from organizational facilities for off-site maintenance or repairs;
- Sanitizes equipment to remove all information from associated media prior to removal from organizational facilities for off-site maintenance or repairs; and
- Checks all potentially impacted security controls to verify that the controls are still functioning properly following maintenance or repair actions.

Standard: Asset custodians are required to:

- (a) Schedule, perform, document, and review records of maintenance and repairs on information systems in accordance with manufacturer or vendor specifications and company requirements;
- (b) Control all maintenance activities, whether performed on site or remotely and whether the equipment is serviced on site or removed to another location;
- (c) Require explicit management approval for the removal of the information systems or system components from company facilities for off-site maintenance or repairs;
- (d) Sanitize equipment to remove all information from associated media prior to removal from company facilities for off-site maintenance or repairs; and
- (e) Check all potentially impacted security controls to verify that the controls are still functioning properly following maintenance or repair actions.

Supplemental Guidance: This control addresses the information security aspects of the information system maintenance program and applies to all types of maintenance to any system component (including applications) conducted by any local or non-local entity (e.g., in contract, warranty, in-house, software maintenance agreement). System maintenance also includes those components not directly associated with information processing and/or data/information retention such as scanners, copiers, and printers.

7.2.4.2 MAINTENANCE ACTIVITIES

Control Objective: The firm produces up-to-date, accurate, complete, and available records of all maintenance and repair actions. This includes needed, in-process, and completed maintenance activities.

Standard: For critical information systems, asset custodians are required to keep maintenance records for information systems that include:

- (a) Date and time of maintenance;
- (b) Name of the individual performing the maintenance;
- (c) Name of escort, if necessary;
- (d) A description of the maintenance performed; and
- (e) A list of equipment removed or replaced (including identification numbers, if applicable).

Supplemental Guidance: None

¹⁴⁷ ISO/IEC 27002:2013 – 11.2.4

¹⁴⁸ NIST Cybersecurity Framework PR.MA-1

7.2.4.3 MAINTENANCE TOOLS

Control Objective: The firm approves controls, monitors the use of, and maintains on an ongoing basis, information system maintenance tools.¹⁴⁹

Standard: Asset custodians are required to inspect all maintenance tools carried into KR facilities by maintenance personnel for obvious improper modifications or indications that proper maintenance is not being performed.

Supplemental Guidance: This control addresses security-related issues associated with maintenance tools used specifically for diagnostic and repair actions on organizational information systems. Maintenance tools can include hardware, software, and firmware items. Maintenance tools can include, for example, hardware/software diagnostic test equipment and hardware/software packet sniffers.

7.2.4.4 TIMELY MAINTENANCE

Control Objective: The firm obtains maintenance support and/or spare parts for information systems and/or key information technology components within an organization-defined time period.

Standard: Asset custodians and data owners are required to obtain maintenance support and spare parts for critical information systems and key information technology components within defined Service Level Agreements (SLAs).

Supplemental Guidance: Firms specify the information system components that result in increased risk to organizational operations and assets, individuals, or other organizations when the security functionality provided by those components is not operational. Security-critical components include, for example, firewalls, guards, gateways, routers, intrusion detection and prevention systems, audit repositories, authentication servers, and intrusion prevention systems.

7.2.5 REMOVAL OF ASSETS

Equipment, information or software should not be taken off-site without prior authorization.¹⁵⁰

7.2.6 SECURITY OF EQUIPMENT AND ASSETS OFF-PREMISES

Security should be applied to off-site assets taking into account the different risks of working outside the firm's premises.¹⁵¹

7.2.6.1 MEDIA DISTRIBUTION

Control Objective: The firm maintains strict control over the internal or external distribution of any kind of media.¹⁵²

Standard: KR's asset custodians and data owners are required to maintain strict control over the internal or external distribution of media, including the following:

- (a) Classifying media in accordance with [Appendix A: Data Classification & Handling Guidelines](#) so the sensitivity of the data can be determined;
- (b) Sending sensitive media by secured courier or another delivery method that can be accurately tracked; and
- (c) Ensuring prior management approval for any and all media that is moved from a secured area (including when media is distributed to individuals).

Supplemental Guidance: [Appendix A: Data Classification & Handling Guidelines](#) covers the topics of data classification and handling in greater detail.

7.2.7 SECURE DISPOSAL OR RE-USE OF EQUIPMENT

All items of equipment containing storage media should be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.¹⁵³

¹⁴⁹ NIST Cybersecurity Framework PR.MA-1

¹⁵⁰ ISO/IEC 27002:2013 – 11.2.5

¹⁵¹ ISO/IEC 27002:2013 – 11.2.6

¹⁵² PCI DSS (v3.2) 9.6-9.6.3

¹⁵³ ISO/IEC 27002:2013 – 11.2.7

7.2.7.1 MEDIA DESTRUCTION

Control Objective: The firm destroys media when it is no longer needed for business or legal reasons.¹⁵⁴

Standard: Data owners and asset custodians are required to sanitize media when it is no longer needed for business or legal reasons. Asset custodians are required to destroy media that cannot be sanitized, as follows:

- (a) Shred, incinerate, or pulp hardcopy materials so that data cannot be reconstructed; or
 1. Secure storage containers must be used for data that is waiting to be destroyed.
- (b) Render data on electronic media unrecoverable so that data cannot be reconstructed.

Supplemental Guidance: Data destruction may be performed in-house or it may be outsourced to a qualified data destruction vendor. Examples of methods for securely destroying electronic media include secure wiping, degaussing, or physical destruction (such as grinding or shredding hard disks).

7.2.8 UNATTENDED USER EQUIPMENT

Users should ensure that unattended equipment has appropriate protection.¹⁵⁵

7.2.8.1 DEVICE STORAGE IN AUTOMOBILES

Control Objective: The firm requires protection of mobile information systems away from organizational premises.

Standard: When traveling with KR-issued laptops and mobile devices, users are required to:

- (a) Lock the device(s) in the trunk of a user's automobile; or
- (b) Maintain physical control and not leave the device(s) in the automobile.

Supplemental Guidance: A KR laptop or other mobile device must never be left in the passenger compartment of an unattended vehicle. The primary concern with storage in a vehicle's trunk is damage due to extreme temperature. The average storage temperature range for laptop computers is -40 degrees Fahrenheit to +140 degrees Fahrenheit, so if the trunk exceeds this temperature range, the device should not be left in the vehicle for risk of damage to both the device and the automobile.

7.2.9 CLEAR DESKS AND CLEAR SCREENS

A clear desk policy for papers and removable storage media and a clear screen policy for information processing facilities should be adopted.¹⁵⁶

7.2.9.1 WORKPLACE SECURITY

Control Objective: The firm requires protection of workstations to restrict access to authorized users.

Standard: KR requires the following workplace security precautions:

- (a) Physical media must be properly disposed of, in accordance with document destruction policies;
- (b) All work areas must be cleared of all media containing sensitive data when not occupied;
- (c) Filing cabinets, lockable drawers / overhead cabinets, storage rooms, and any other storage unit containing sensitive data will be locked when not in use; and
- (d) Whiteboards, dry-erase boards, cork boards, writing tablets, and similar common shared work areas will be sanitized (e.g., erased, removed, or shredded) when not in use.

Supplemental Guidance: Physical security zones should be used to determine which areas are more vulnerable to unauthorized use, theft, or viewing of data and appropriate physical safeguards should be implemented.

¹⁵⁴ PCI DSS (v3.2) 9.8-9.8.2

¹⁵⁵ ISO/IEC 27002:2013 – 11.2.8

¹⁵⁶ ISO/IEC 27002:2013 – 11.2.9

8.0 Operations Security Policy

KR shall implement and maintain appropriate layers of safeguards to protect information systems from possible threats.

Management Intent: The purpose of this policy is to ensure the confidentiality, integrity, and availability of KR's data through implementing appropriate technologies to protect information systems and data.

8.1 Operational Procedures and Responsibilities

The objective is to ensure correct and secure operations of information processing facilities.¹⁵⁷

8.1.1 DOCUMENTED OPERATING PROCEDURES

Operating procedures should be documented and made available to all users who need them.¹⁵⁸

8.1.1.1 OPERATIONAL SECURITY (OPSEC)

Control Objective: The firm employs organization-defined operations security safeguards to protect key organizational information throughout the System Development Life Cycle (SDLC).

Standard: KR's management is required to:

- (a) Perform reviews at least bi-annually to confirm personnel are following security policies and operational procedures.
Reviews must cover the following processes:
 1. Firewall ruleset reviews;
 2. Applying configuration standards to new systems;
 3. Responding to security alerts; and
 4. Change management processes;
- (b) Maintain documentation of the quarterly review process to include:
 1. Documenting results of the reviews; and
 2. Review and sign-off of results by personnel assigned responsibility for the compliance program.

Supplemental Guidance: Operations security (OPSEC) is a systematic process by which potential adversaries can be denied information about the capabilities and intentions of organizations by identifying, controlling, and protecting generally unclassified information that specifically relates to the planning and execution of sensitive organizational activities. The OPSEC process involves five steps:

- Identification of critical information (e.g., the security categorization process);
- Analysis of threats;
- Analysis of vulnerabilities;
- Assessment of risks; and
- The application of appropriate countermeasures.

8.1.1.2 SYSTEM SECURITY PLANS

Control Objective: The firm develops a functional architecture for identifying and maintaining key architectural information on each critical information system that, at a minimum, includes:¹⁵⁹

- External interfaces, the information being exchanged across the interfaces, and the protection mechanisms associated with each interface;
- User roles and the access privileges assigned to each role;
- Unique security requirements;
- Types of information processed, stored, or transmitted by information systems and any specific protection needs in accordance with applicable local, state and Federal laws; and

¹⁵⁷ ISO/IEC 27002:2013 – 12.1

¹⁵⁸ ISO/IEC 27002:2013 – 12.1.1

¹⁵⁹ NIST Cybersecurity Framework PR.IP-7 & DE.DP-5

- Restoration priority of information or information system services.

Standard: Asset custodians and data owners are required to document key architectural information on each critical information system that, at a minimum, includes:

- (a) External interfaces, the information being exchanged across the interfaces, and the protection mechanisms associated with each interface;
- (b) User roles and the access privileges assigned to each role;
- (c) Unique security requirements;
- (d) Types of information processed, stored, or transmitted by information systems and any specific protection needs in accordance with applicable local, state and Federal laws; and
- (e) Restoration priority of information or information system services.

Supplemental Guidance: Security plans relate security requirements to a set of security controls and control enhancements. Security plans also define the intent of the security controls and control enhancements with regard to meeting those security requirements but do not provide descriptions of the specific design or implementation of the controls/enhancements. Security plans contain sufficient information (including the specification of parameter values for assignment/selection statements in security controls and control enhancements either explicitly or by reference) to enable a design and implementation that is unambiguously compliant with the intent of the plans and subsequent determinations of risk to organizational operations and assets, individuals, and other organizations if the plan is implemented as intended.

Effective security plans make extensive use of references to policies, standards, procedures, and additional documents (e.g., design and implementation specifications) where more detailed information is contained. This reduces the documentation requirements associated with security programs and maintains security-related information in other management and operational areas related to enterprise architecture and system development life cycle activities. For example, security plans typically do not contain detailed contingency/incident response plan information but instead provide explicitly or by reference, sufficient information in order to define what needs to be accomplished by those plans.

8.1.2 CHANGE MANAGEMENT

Changes to the firm, business processes, information processing facilities and systems that affect information security should be controlled.¹⁶⁰

8.1.2.1 SECURITY IMPACT ANALYSIS FOR CHANGES

Control Objective: The firm analyzes changes to information systems to determine potential security impacts prior to change implementation.¹⁶¹

Standard: From a test environment, asset custodians are required to test proposed changes to assess the security functions of an information system to verify that those functions are:

- (a) Implemented correctly;
- (b) Operating as intended; and
- (c) Producing the desired outcome with regard to meeting the security requirements for the system.

Supplemental Guidance: Security impact analysis may include, for example, reviewing security plans to understand security control requirements and reviewing system design documentation to understand control implementation and how specific changes might affect the controls. The analysis process should include a review of the following:

- Separate development/test and production environments;
- Separation of duties between development/test and production environments;
- Production data (live data) are not used for testing or development; and
- Removal of test data and accounts before production systems become active.

8.1.3 CAPACITY MANAGEMENT

The use of resources should be monitored, tuned and projections made of future capacity requirements to ensure the required system performance.¹⁶²

¹⁶⁰ ISO/IEC 27002:2013 – 12.1.2

¹⁶¹ PCI DSS (v3.2) 6.4, 6.4.5, 6.4.5.1-6.4.5.4 | NIST Cybersecurity Framework PR.IP-1 & PR.IP-3

¹⁶² ISO/IEC 27002:2013 – 12.1.3

8.1.3.1 CAPACITY MANAGEMENT

Control Objective: The firm allocates additional capacity to reduce the likelihood of such capacity being exceeded.¹⁶³

Standard: Asset custodians and data owners are required to allocate sufficient processing and storage capacity to reduce the likelihood of such capacity being exceeded.

Supplemental Guidance: Asset owners must consider the types of auditing to be performed and the audit processing requirements when allocating audit storage capacity. Allocating sufficient audit storage capacity reduces the likelihood of such capacity being exceeded and resulting in the potential loss or reduction of auditing capability.

8.1.4 SEPARATION OF DEVELOPMENT, TESTING AND OPERATIONAL ENVIRONMENTS

Development, testing, and operational environments should be separated to reduce the risks of unauthorized access or changes to the operational environment.¹⁶⁴

8.1.4.1 SEPARATE DEVELOPMENT & TEST ENVIRONMENTS

Control Objective: The firm maintains a baseline configuration for development and test environments that is managed separately from the operational baseline configuration.¹⁶⁵

Standard: Asset custodians are required to maintain and manage baseline configurations for development and test environments separately from its production baseline configurations.

Supplemental Guidance: Establishing separate baseline configurations for development, testing, and operational environments help protect information systems from unplanned/unexpected events related to development and testing activities). Separate baseline configurations allow organizations to apply the configuration management that is most appropriate for each type of configuration. For example, management of operational configurations typically emphasizes the need for stability, while management of development/test configurations requires greater flexibility. This control enhancement requires separate configurations but not necessarily separate physical environments.

¹⁶³ NIST Cybersecurity Framework PR.DS-4 & PR.PT-1

¹⁶⁴ ISO/IEC 27002:2013 – 12.1.4

¹⁶⁵ PCI DSS (v3.2) 6.4.1

8.2 Protection from Malware

The objective is to ensure that information and information processing facilities are protected against malware.¹⁶⁶

8.2.1 CONTROLS AGAINST MALWARE

Detection, prevention, and recovery controls to protect against malware should be implemented, combined with appropriate user awareness.¹⁶⁷

8.2.1.1 ANTIMALWARE MECHANISMS

Control Objective: The firm ensures that anti-malware mechanisms are actively running and cannot be disabled or altered by users, unless specifically authorized by management on a case-by-case basis for a limited time period.¹⁶⁸

Standard: Asset custodians are required to ensure the KR-approved anti-malware software is actively running and cannot be disabled or altered by users, unless specifically authorized by management on a case-by-case basis for a limited time period.

Supplemental Guidance: Anti-malware that continually runs and is unable to be altered will provide persistent security against malware. Use of policy-based controls on all systems to ensure anti-malware protections cannot be altered or disabled will help prevent system weaknesses from being exploited by malicious software. Additional security measures may also need to be implemented for the period of time during which anti-malware protection is not active (e.g., disconnecting the unprotected system from the Internet while the anti-virus protection is disabled, and running a full scan after it is re-enabled).

8.2.1.2 ANTIMALWARE INSTALLATION

Control Objective: The firm deploys anti-malware software on systems commonly affected by malicious software.

Standard: Asset custodians are required to:¹⁶⁹

- (a) Deploy the KR-approved anti-malware software on all systems capable of running anti-malware software, including, but not limited to:
 - 1. Workstations;
 - 2. Servers;
- (b) Ensure that the KR-approved anti-malware software is capable of detecting, removing, and protecting against all known types of malware; and
- (c) Perform periodic evaluations to identify and evaluate evolving malware threats on information systems considered to be not commonly affected by malware, in order to confirm whether such information systems continue to not require anti-malware software.
- (d) Ubuntu / Linux machines are not required to have anti-virus installed.

Supplemental Guidance: Systems not capable of running anti-malware software should have a documented business justification as to why anti-malware software cannot be run and what compensating controls are in place to minimize the risk associated with the lack of anti-malware software on that system.

Typically, mainframes, mid-range computers (such as AS/400) and similar systems may not currently be commonly targeted or affected by malware. However, industry trends for malware can change quickly, so it is important for organizations to be aware of new malware that might affect their systems. For example, by monitoring vendor security notices and anti-malware newsgroups to determine whether their systems might be coming under threat from new and evolving malware.

Trends in malware should be included in the identification of new security vulnerabilities, and methods to address new trends should be incorporated into KR's configuration standards and protection mechanisms as needed

¹⁶⁶ ISO/IEC 27002:2013 – 12.2

¹⁶⁷ ISO/IEC 27002:2013 – 12.2.1

¹⁶⁸ PCI DSS (v3.2) 5.3

¹⁶⁹ PCI DSS (v3.2) 5.1-5.1.2

8.2.1.3 ANTIMALWARE SIGNATURE UPDATES

Control Objective: The firm ensures that anti-malware mechanisms are current, actively running, and generating audit logs.¹⁷⁰

Standard: Asset custodians are required to ensure the KR-approved anti-malware software is:

- (a) Kept current with updates from the anti-malware vendor;
- (b) Actively running on systems, the anti-malware software is deployed to; and
- (c) Generating audit logs.

Supplemental Guidance: Even the best anti-malware solutions are limited in effectiveness if they are not maintained and kept current with the latest security updates, signature files, or malware protections. Audit logs provide the ability to monitor virus and malware activity and anti-malware reactions. Thus, it is imperative that anti-malware solutions be configured to generate audit logs and that these logs be managed.

Anti-malware test files from the European Institute for Computer Antivirus Research (EICAR) should be downloaded (<http://www.eicar.org/85-0-Download.html>) and copied to either a CD/DVD or write-protected USB.

- This CD/DVD or USB should be inserted into systems to test that anti-malware software is running “on demand” scans and detects the presence of the EICAR test file; and
- Logs should be checked to verify the EICAR test file was detected and logged.

8.2.1.4 MALWARE PROTECTION PROCEDURES

Control Objective: The firm ensures that security policies and operational procedures for protecting systems against malware are documented, in use, and known to all affected parties.¹⁷¹

Standard: Data owners and asset custodians are required to ensure that the procedures for protecting systems against malware are kept current and disseminated to all pertinent parties.

Supplemental Guidance: Personnel need to be aware of and following security policies and operational procedures to ensure systems are protected from malware on a continuous basis.

8.3 Backup

The objective is to protect against loss of data.¹⁷²

8.3.1 INFORMATION BACKUP

Backup copies of information, software and system images should be taken and tested regularly in accordance with an agreed backup policy.¹⁷³

8.3.1.1 INFORMATION SYSTEM BACKUP

Control Objective: The firm:¹⁷⁴

- Conducts backups of user-level information contained in the information systems;
- Conducts backups of system-level information contained in the information systems;
- Conducts backups of information system documentation including security-related documentation; and
- Protects the confidentiality and integrity of backup information at the storage location.

Standard: Asset custodians and data owners are responsible for:

- (a) Conducting backups of user-level information contained in information systems;
- (b) Conducting backups of system-level information contained in information systems;
- (c) Conducting backups of information system documentation including security-related documentation; and
- (d) Protecting the confidentiality and integrity of backup information at the storage location.

¹⁷⁰ PCI DSS (v3.2) 5.2

¹⁷¹ PCI DSS (v3.2) 5.4

¹⁷² ISO/IEC 27002:2013 – 12.3

¹⁷³ ISO/IEC 27002:2013 – 12.3.1

¹⁷⁴ HIPAA 164.308(a)(7)(ii)(A) | NIST Cybersecurity Framework PR.IP-4

Supplemental Guidance: Information system backups reflect the requirements in contingency plans as well as other organizational requirements for backing up information. It is necessary for orderly and efficient data backup and restoration. The individual responsible for data backups should fully document the following items for each generated data backup:

- Date of data backup;
- Type of data backup (e.g., differential, incremental, full, or copy);
- Generation (e.g., grandfather / father / son);
- Individual responsible for data backup;
- Extent of data backup (e.g., files/directories);
- Data media on which the operational data are stored;
- Data media on which the backup data are stored;
- Data backup hardware and software with version number(s);
- Data backup parameters (e.g., type of data backup etc.); and
- Storage location of backup copies.

Selecting the appropriate backup technology is a management decision. The level of risk will determine the level of data backup technologies and redundancies required. Regardless of the available technology solution, the following methods of data backup may be used:

Data Backup Methods:

- **Full:** A full backup is a backup of every file on a file system, whether that file has changed or not. The alternatives to a full backup are incremental backup and differential backup. A full backup takes longer to accomplish and requires the most storage space on the backup media, but it also provides the quickest restore times. A full backup should be performed weekly on production systems, along with daily differential or incremental backups. A full backup should also be performed before any major planned changes to a system.
- **Incremental:** An incremental backup image is a copy of all database data that has changed since the most recent, successful, full backup operation. This is also known as a cumulative backup image, because a series of incremental backups taken over time will each have the contents of the previous incremental backup image. The predecessor of an incremental backup image is always the most recent successful full backup of the same object.
- **Differential (Delta):** A delta, or incremental delta, backup image is a copy of all database data that has changed since the last successful backup (full) of the data in question. This is also known as a differential, or non-cumulative, backup image. The predecessor of a delta backup image is the most recent full backup.

Depending on the available technology solution, the following procedures will be used:

Tape / Removable Hard Disk Drive (HDD) Cartridge Backups

The most commonly used tape / Hard Disk Drive (HDD) cartridge (tape) rotation schedule is called “Grandfather / Father / Son” (GFS). This rotation scheme operates on a five-day work week principle:

- “Son” tapes are for daily backups;
- “Father” tapes are for weekly backups; and
- “Grandfather” is for monthly backups

The monthly and annual tapes should be archived for storage. Daily and weekly tapes should be replaced every 6 months, due to wear and tear. The following steps show how to perform a simple GFS rotation method using 20 tapes:

- Obtain 20 tapes and label them as follows:
 - 4 daily tapes (sons) labeled “MONDAY” through “THURSDAY”
 - 4 weekly tapes (fathers) labeled “WEEK 1” through “WEEK 4”
 - 12 monthly tapes (grandfathers) labeled with the month and year
- If a full backup exceeds the capacity of one tape, create tape sets
- Beginning on a Friday, perform a full backup on the “WEEK 1” tape. Store the Week tapes off-site.
- Beginning on the following Monday, perform daily differential or incremental backups on the “MONDAY” through “THURSDAY” tapes. Store the daily backup tapes off-site.
- On Friday, perform another full backup on the “WEEK 2” tape.
- Continue with this rotation method until the last business day of the month.

- On the last business day (no matter what the day of the week it is), perform a full backup on the first monthly (grandfather) tape. Label the tape with the current date and store it off-site.

Continuous Data Protection (CDP) Backups

Continuous Data Protection (CDP), also called continuous backup or disk-to-disk (D2D), refers to backup of computer data by automatically saving a copy of every change made to that data, essentially capturing every version of the data that the user saves. It allows the user or administrator to restore data to any point in time.

CDP backups should be used in conjunction with archiving backups, such as tape or HDD cassette backups. This rationale is due to the need to have archived “snapshots” of the data in case the current and CDP data become corrupted.

Internet-Based Backups

The preferred method for data backups is through utilizing both a local copy of a backup, be it tape, HDD cassette, or CDP device, as well as an automated Internet-based data backup provider. Internet-based backups help eliminate human error associated with manually producing tape backups and can be scheduled each day, without human intervention.

Just as with traditional tape backups, care must be taken to ensure all data is captured in the backup set. Data not selected to be transmitted off-site will not be backed up remotely, so regular testing is required regardless of the backup technology used.

8.3.1.2 INFORMATION SYSTEM RECOVERY & RECONSTITUTION

Control Objective: The firm provides for the recovery and reconstitution of information systems to a known state after a disruption, compromise, or failure.¹⁷⁵

Standard: KR’s IT department is required to provide for the recovery and reconstitution of systems to a known state after a disruption, compromise, or failure. This includes but is not limited to:

- Conducting backups;
- Maintaining backup solutions and media; and
- Periodically testing backup solutions to validate that successful recovery is possible.

Supplemental Guidance: Recovery is executing information system contingency plan activities to restore organizational missions/business functions. Reconstitution takes place following recovery and includes activities for returning organizational information systems to fully operational states. Recovery and reconstitution operations reflect mission and business priorities, recovery point/time and reconstitution objectives, and established organizational metrics consistent with contingency plan requirements. Reconstitution includes the deactivation of any interim information system capabilities that may have been needed during recovery operations. Reconstitution also includes assessments of fully restored information system capabilities, reestablishment of continuous monitoring activities, potential information system reauthorizations, and activities to prepare the systems against future disruptions, compromises, or failures.

8.3.1.3 TRANSACTION RECOVERY

Control Objective: The firm implements transaction recovery for information systems that are transaction-based.

Standard: For critical systems, asset custodians and data owners are required to provide for transaction recovery of information systems that are transaction-based.

Supplemental Guidance: Transaction-based information systems include, for example, database management systems and transaction processing systems. Mechanisms supporting transaction recovery include, for example, transaction rollback and transaction journaling.

8.3.1.4 FAILOVER CAPABILITY

Control Objective: The firm provides real-time or near-real-time failover capability for information systems.

¹⁷⁵ HIPAA 164.308(a)(7)(ii)(B) | NIST Cybersecurity Framework RS.RP-1 & RC.RP-1

Standard: For critical systems, asset custodians and data owners are required to provide real-time or near-real-time failover capability for critical information systems.

Supplemental Guidance: None

8.3.1.5 INFORMATION SYSTEM IMAGING

Control Objective: The firm provides the capability to reimage information system components from configuration-controlled and integrity-protected disk images representing a secure, operational state for the components.

Standard: KR's IT department is required to provide the capability to re-image information systems from configuration-controlled and integrity-protected disk images representing a secure, operational state for the system.

Supplemental Guidance: The process of re-imaging should be used since it has several key benefits, including:

- Fast recovery time for a complete OS;
- Ability to load one image on multiple like-systems; and
- Reduces troubleshooting by being able to quickly reload an OS, while keeping data intact.

8.3.1.6 BACKUP & RESTORATION HARDWARE PROTECTION

Control Objective: The firm protects backup and restoration hardware and software.

Standard: For critical systems, asset custodians and data owners are required to provide for backup and restoration hardware and software.

Supplemental Guidance: None

8.4 Logging and Monitoring

The objective is to record events and generate evidence.¹⁷⁶

8.4.1 EVENT LOGGING

Event logs recording user activities, exceptions, faults and information security events should be produced, kept and regularly reviewed.¹⁷⁷

8.4.1.1 AUTOMATED AUDIT TRAILS

Control Objective: The firm utilizes automated audit trails for system components to reconstruct events.¹⁷⁸

Standard: Asset custodians are required to implement automated audit trails for all system components to reconstruct the following events:

- (a) All individual user accesses to data;
- (b) All actions taken by any individual with root or administrative privileges;
- (c) Access to all audit trails;
- (d) Invalid logical access attempts;
- (e) Use of and changes to identification and authentication mechanisms, including but not limited to:
 1. Creation of new accounts and elevation of privileges; and
 2. All changes, additions, or deletions to accounts with root or administrative privileges;
- (f) Initialization, stopping, or pausing of the audit logs; and
- (g) Creation and deletion of system-level objects.

¹⁷⁶ ISO/IEC 27002:2013 – 12.4

¹⁷⁷ ISO/IEC 27002:2013 – 12.4.1

¹⁷⁸ PCI DSS (v3.2) 10.2-10.2.7

Supplemental Guidance: Generating audit trails of suspect activities alerts the system administrator, sends data to other monitoring mechanisms (like intrusion detection systems), and provides a history trail for post-incident follow-up. Logging of the following events enables an organization to identify and trace potentially malicious activities.

8.4.1.2 AUDIT TRAIL CONTENT

Control Objective: The firm follows best practices for logging audit trail entries.¹⁷⁹

Standard: Asset custodians are required to configure systems to record at least the following audit trail entries for all system components for each event:

- (a) User identification;
- (b) Type of event;
- (c) Date and time;
- (d) Success or failure indication;
- (e) Origination of event; and
- (f) Identity or name of affected data, system component, or resource.

Supplemental Guidance: By recording these details for the auditable events at PCI DSS requirement 10.2, a potential compromise can be quickly identified, and with sufficient detail to know who, what, where, when, and how.

8.4.1.3 LOG REVIEW

Control Objective: The firm implements a process to review logs and security events for all system components to identify anomalies or suspicious activity.¹⁸⁰

Standard: Data owners and asset custodians are required to develop and implement a process to review logs and security events for all system components to identify anomalies or suspicious activity that includes:

- (a) Reviewing the following:
 1. All security events;
 2. Logs of all system components that store, process, or transmit data, or that could impact the security of data;
 3. Logs of all critical system components; and
 4. Logs of all servers and system components that perform security functions. This includes, but is not limited to:
 - i. Firewalls
 - ii. Intrusion Detection Systems (IDS)
 - iii. Intrusion Prevention Systems (IPS)
 - iv. Authentication servers (e.g., Active Directory domain controllers)
- (b) Reviewing logs of all other system components periodically based on KR's policies and risk management strategy, as determined by KR's annual risk assessment; and
- (c) Following up exceptions and anomalies identified during the review process;
- (d) Developing processes for the timely detection and reporting of failures of critical security control systems, including but not limited to failure of:
 1. Firewalls;
 2. IDS/IPS;
 3. FIM;
 4. Anti-malware;
 5. Physical access controls;
 6. Logical access controls;
 7. Audit logging mechanisms; and
 8. Segmentation controls (if used); and
- (e) Responding to failures of any critical security controls in a timely manner. Processes for responding to failures in security controls must include:
 1. Restoring security functions;
 2. Identifying and documenting the duration (date and time start to end) of the security failure;

¹⁷⁹ PCI DSS (v3.2) 10.3-10.3.6

¹⁸⁰ PCI DSS (v3.2) 10.6-10.6.3 & 10.8-10.8.1

3. Identifying and documenting cause(s) of failure, including root cause, and documenting remediation required to address root cause;
4. Identifying and addressing any security issues that arose during the failure;
5. Performing a risk assessment to determine whether further actions are required as a result of the security failure;
6. Implementing controls to prevent cause of failure from reoccurring; and
7. Resuming monitoring of security controls.

Supplemental Guidance: Many breaches occur over days or months before being detected. Checking logs daily minimizes the amount of time and exposure of a potential breach. Regular log reviews by personnel or automated means can identify and proactively address unauthorized access to the data environment.

The log review process does not have to be manual. The use of log harvesting, parsing, and alerting tools can help facilitate the process by identifying log events that need to be reviewed.

8.4.1.4 LINKING ACCESS TO INDIVIDUAL USERS

Control Objective: The firm implements audit trails for linking access to system components to individual users.¹⁸¹

Standard: Asset custodians are required to implement auditing of systems and applications that allow access to system components to be linked to individual users.

Supplemental Guidance: It is critical to have a process or system that links user access to system components accessed. This system generates audit logs and provides the ability to trace back suspicious activity to a specific user.

8.4.2 PROTECTION OF LOG INFORMATION

Logging facilities and log information should be protected against tampering and unauthorized access.¹⁸²

8.4.2.1 SECURING AUDIT TRAILS

Control Objective: The firm secures audit trails so logs cannot be altered.¹⁸³

Standard: Asset custodians are required to secure audit trails so the logs cannot be altered. Securing audit trails includes the following:

- (a) Limiting viewing of audit trails to those with a job-related need;
- (b) Protecting audit trail files from unauthorized modifications;
- (c) As close to real-time as possible, backup or transfer audit trail files to a centralized log server or media that is difficult to alter;
- (d) Writing logs for external-facing technologies onto a secure, centralized, internal log server or media device; and
- (e) Using File Integrity Monitoring (FIM) or change detection software on logs to ensure that existing log data cannot be changed without generating alerts.

Supplemental Guidance: File Integrity Monitoring (FIM) or change detection software should be configured not to alert when new data is being added to logs. Otherwise normal log traffic will generate change alerts on the log files.

8.4.2.2 RETENTION OF AUDIT TRAIL HISTORY

Control Objective: The firm retains audit trail history.¹⁸⁴

Standard: Data owners and asset custodians are required to retain audit trail history for at least one (1) year, with a minimum of three (3) months immediately available for analysis.

Supplemental Guidance: Logs are considered “immediately available” for analysis if the logs can be:

¹⁸¹ PCI DSS (v3.2) 10.1

¹⁸² ISO/IEC 27002:2013 – 12.4.2

¹⁸³ PCI DSS (v3.2) 10.5-10.5.5

¹⁸⁴ PCI DSS (v3.2) 10.7

- Accessed online;
- Readily recovered from archived media; or
- Restorable from back-up.

8.4.3 ADMINISTRATOR AND OPERATOR LOGS

System administrator and system operator activities should be logged, and the logs protected and regularly reviewed.¹⁸⁵

8.4.3.1 PRIVILEGED FUNCTIONS LOGGING

Control Objective: The firm includes execution of privileged functions in the events to be audited.¹⁸⁶

Standard: KR is required to establish a process for linking all access to information systems, including administrative privileged accounts (e.g., root or administrator) to each individual user.

Supplemental Guidance: None

8.4.4 CLOCK SYNCHRONIZATION

The clocks of all relevant information processing systems within an organization or security domain should be synchronized to a single reference time source.¹⁸⁷

8.4.4.1 NETWORK TIME PROTOCOL (NTP)

Control Objective: The firm utilizes time-synchronization technology to synchronize all critical system clocks.¹⁸⁸

Standard: Network Time Protocol (NTP) is KR's official method of synchronizing all system clocks and times and ensure that the following is implemented for acquiring, distributing, and storing time:

- (a) Asset custodians are responsible for configuring KR's NTP servers so that they are receiving time from industry-accepted time sources; and
- (b) Asset owners must ensure NTP on their systems is configured properly and validate the following:
 1. Systems are configured to synchronize time with KR's NTP servers;
 2. Information systems have the correct and consistent time; and
 3. Time data is protected from unauthorized modification.

Supplemental Guidance: Time is commonly expressed in Coordinated Universal Time (UTC), a modern continuation of Greenwich Mean Time (GMT), or local time with an offset from UTC. NTP is an Internet standard protocol which enables client computers to maintain system time synchronization to the US Naval Observatory (USNO) Master Clocks in Washington, DC and Colorado Springs, CO.¹⁸⁹ Official NIST or USNO Internet Time Service (ITS) that can to be used for system time synchronization include, but are not limited to:

- time.nist.gov 192.43.244.18 [primary]; and
- time-nw.nist.gov 131.107.13.100 [alternate]

8.5 Control of Operational Software

The objective is to ensure the integrity of operational systems.¹⁹⁰

8.5.1 INSTALLATION OF SOFTWARE ON OPERATIONAL SYSTEMS

Procedures should be implemented to control the installation of software on operational systems.¹⁹¹

¹⁸⁵ ISO/IEC 27002:2013 – 12.4.3

¹⁸⁶ PCI DSS (v3.2) 10.2 & 10.2.1-10.2.7

¹⁸⁷ ISO/IEC 27002:2013 – 12.4.4

¹⁸⁸ PCI DSS (v3.2) 10.4-10.4.3

¹⁸⁹ <http://tycho.usno.navy.mil/ntp.html>

¹⁹⁰ ISO/IEC 27002:2013 – 12.5

¹⁹¹ ISO/IEC 27002:2013 – 12.5.1

8.5.1.1 ACCESS RESTRICTION FOR CHANGE

Control Objective: The firm defines documents, approves, and enforces access restrictions associated with changes to information systems.¹⁹²

Standard: Asset custodians are required to configure information systems to prevent the installation of software and hardware components by non-administrators through limiting the actions that users are capable of performing.

Supplemental Guidance: Any changes to the hardware, software, and/or firmware components of information systems can potentially have significant effects on the overall security of the systems. Therefore, KR permits only qualified and authorized individuals to access information systems for purposes of initiating changes, including upgrades and modifications.

8.6 Technical Vulnerability Management

The objective is to prevent exploitation of technical vulnerabilities.¹⁹³

8.6.1 MANAGEMENT OF TECHNICAL VULNERABILITIES

Information about technical vulnerabilities of information systems being used should be obtained in a timely fashion, the firm's exposure to such vulnerabilities evaluated and appropriate measures taken to address the associated risk.¹⁹⁴

8.6.1.1 SOFTWARE PATCHING

Control Objective: The firm ensures that all system components and software are protected from known vulnerabilities by having the latest vendor-supplied security patches installed.¹⁹⁵

Standard: Asset custodians are required to ensure that:

- (a) All system components and software are protected from known vulnerabilities by having the latest vendor-supplied security patches installed;
- (b) security patches are installed within ninety (90) days of the vendor's release data except during tax season in which patches will be not be deployed unless it is approved by the managing partner.
- (c) Office updates are being deployed twice a year, January and July. This applies to servers and workstations/laptops.
- (d) DC are updated once a year. Complementary controls to prevent the exploitation of a vulnerability includes (firewall at the server level, IDS / IPS monitoring)
- (e) RAS laptops security updates will be pulled at least once a month. Operating system updates will be done at least once a year when DC are updated.

Supplemental Guidance: KR is allowed to apply a risk-based approach to prioritize its patch installations. For example, by prioritizing critical infrastructure (e.g., public-facing devices and systems, databases) higher than less-critical internal devices, this helps ensure high-priority systems and devices are addressed within one month and still allows for addressing less critical devices and systems within three months.

8.6.1.2 VULNERABILITY SCANNING

Control Objective: The firm implements a process for running internal and external network vulnerability scans at least quarterly and after any significant change in the network.¹⁹⁶

Standard: Asset custodians are required to perform the following vulnerability scanning-related activities:

- (a) Perform quarterly internal vulnerability scans and rescans as needed. Scans must be performed by qualified personnel;
- (b) Perform quarterly external vulnerability scans.
- (c) Perform internal and external scans, and rescans as needed, after any significant change. Scans must be performed by qualified personnel.

¹⁹² NIST Cybersecurity Framework PR.IP-1

¹⁹³ ISO/IEC 27002:2013 – 12.6

¹⁹⁴ ISO/IEC 27002:2013 – 12.6.1

¹⁹⁵ PCI DSS (v3.2) 6.2

¹⁹⁶ PCI DSS (v3.2) 11.2-11.2.3

Supplemental Guidance: A “quarter” is defined as a ninety (90) day period and a “significant change” in the network includes, but is not limited to:

- New system component installations;
- Changes in network topology;
- Firewall rule modifications; and
- Major product upgrades.

8.6.1.3 PENETRATION TESTING

Control Objective: The firm implements a methodology for penetration testing.

Standard: Asset custodians are required to implement a methodology for penetration testing that includes the following:

- (a) Coverage of all applicable requirements:
 1. Process is based on industry-accepted penetration testing approaches (e.g., NIST SP 800-115);
 2. Includes coverage for the entire perimeter and critical systems;
 3. Includes testing from both inside and outside the network;
 4. Includes testing to validate any segmentation and scope-reduction controls;
 5. Defines network-layer penetration tests to include components that support network functions, as well as operating systems;
 6. Includes review and consideration of threats and vulnerabilities experienced in the last twelve (12) months; and
 7. Specifies retention of penetration testing results and remediation activities results.
- (b) Internal and External penetration testing must be performed at least annually and after any significant infrastructure or application upgrade or modification. Examples include, but are not limited to:
 1. An operating system upgrade;
 2. A sub-network added to the environment; or
 3. A web server added;
 4. An operating system upgrade;
 5. A sub-network added to the environment; or
 6. A web server added;
- (c) Exploitable vulnerabilities found during penetration testing must be corrected and testing shall be repeated to verify the corrections; and
- (d) If segmentation is used to isolate data from other networks, penetration tests must be performed at least annually and after any changes to segmentation controls/methods to verify that the segmentation methods are operational and effective, and isolate all out-of-scope systems from in-scope systems.

Supplemental Guidance: None

8.6.1.4 VULNERABILITY RANKING

Control Objective: The firm implements a process to identify and assign a risk ranking to newly discovered security vulnerabilities using reputable outside sources for security vulnerability information.¹⁹⁷

Standard: Asset custodians are required to rank vulnerabilities according to the National Vulnerability Database (NVD) Common Vulnerability Scoring System Support (CVSS) system.

Supplemental Guidance: The NVD provides severity rankings of "Low," "Medium," and "High" in addition to the numeric CVSS scores.¹⁹⁸

- Vulnerabilities are labeled "Low" severity if they have a CVSS base score of 0.0-3.9.
- Vulnerabilities will be labeled "Medium" severity if they have a base CVSS score of 4.0-6.9.
- Vulnerabilities will be labeled "High" severity if they have a CVSS base score of 7.0-10.0.

¹⁹⁷ PCI DSS (v3.2) 6.1

¹⁹⁸ National Vulnerability Database (NVD) Common Vulnerability Scoring System (CVSS) <http://nvd.nist.gov/cvss.cfm>

8.6.1.5 VULNERABILITY REMEDIATION

Control Objective: The firm address new threats and vulnerabilities on an ongoing basis and ensure public-facing web applications are protected against known attacks.¹⁹⁹

Standard: Asset custodians are required to address public-facing web application threats and vulnerabilities by either of the following methods:

- (a) Reviewing public-facing web applications via manual or automated application vulnerability security assessment tools or methods:
 - 1. At least annually; and
 - 2. After any changes to the public facing website
- (b) Installing an automated technical solution that detects and prevents web-based attacks (e.g., a web-application firewall) in front of public-facing web applications, to continually check all traffic.

Supplemental Guidance: Public-facing web applications are primary targets for attackers, and poorly coded web applications provide an easy path for attackers to gain access to sensitive data and systems. The requirement for reviewing applications or installing web-application firewalls is intended to reduce the number of compromises on public-facing web applications due to poor coding or application management practices.

- Manual or automated vulnerability security assessment tools or methods review and/or test the application for vulnerabilities
- Web-application firewalls filter and block nonessential traffic at the application layer. Used in conjunction with a network-based firewall, a properly configured web-application firewall prevents application-layer attacks if applications are improperly coded or configured.

An organization that specializes in “application security” can be either a third-party company or an internal team/department, as long as the reviewers specialize in application security and can demonstrate independence from the development team.

8.6.2 RESTRICTIONS ON SOFTWARE INSTALLATION

Rules governing the installation of software by users should be established and implemented.²⁰⁰

8.6.2.1 USER-INSTALLED SOFTWARE

Control Objective: The firm enforces explicit rules governing the installation of software by users.²⁰¹

Standard: Software installation is permitted only by authorized system administrators. The circumvention of security controls and/or installation of pirated software by a user, is strictly prohibited.

Supplemental Guidance: If provided the necessary privileges, users may have the ability to install software in organizational information systems. However, to maintain control over the types of software installed, KR has identified permitted and prohibited software installations. Permitted software installations may include, for example, updates and security patches to existing software. Prohibited software installations may include, for example, software with unknown or suspect software that KR considers potentially malicious.

8.6.2.2 UNAUTHORIZED INSTALLATION ALERTS

Control Objective: The information system alerts personnel or roles when the unauthorized installation of software is detected.

Standard: Where technically feasible, alerting is required to be configured to notify appropriate asset custodians or IT security personnel when the unauthorized installation of software is detected.

Supplemental Guidance: None

¹⁹⁹ PCI DSS (v3.2) 6.6

²⁰⁰ ISO/IEC 27002:2013 – 12.6.2

²⁰¹ NIST Cybersecurity Framework DE.CM-3

8.6.2.3 PROHIBIT INSTALLATION WITHOUT PRIVILEGED STATUS

Control Objective: The information system prohibits user installation of software without explicitly-assigned privileged status.

Standard: Software installation is permitted only by authorized system administrators.

Supplemental Guidance: Privileged status can be obtained, for example, by serving in the role of system administrator.

8.7 Information Systems Audit Considerations

The objective is to minimize the impact of audit activities on operational systems.²⁰²

8.7.1 INFORMATION SYSTEMS AUDIT CONTROLS

Audit requirements and activities involving verification of operational systems should be carefully planned and agreed to minimize disruptions to business processes.²⁰³

8.7.1.1 SECURITY-RELATED ACTIVITY PLANNING

Control Objective: The firm plans and coordinates security-related activities affecting information systems before conducting such activities in order to reduce the impact on organizational operations (e.g., mission, functions, image, and reputation), organizational assets, and individuals.²⁰⁴

Standard: Asset custodians and data owners are responsible for reviewing and revising the security of their information system(s) on an annual basis, or as otherwise necessary. The review process should consider, but not be limited to, the following activities:

- (a) Scope, impact, and urgency of any new threat(s) to KR;
- (b) Upcoming business initiatives and their potential security risk(s);
- (c) Mergers or acquisitions that have occurred and their potential security risk(s);
- (d) New technologies that have been introduced to KR's computing environment;
- (e) Anticipated technologies that may be introduced into KR's computing environment;
- (f) Planned system conversions; and
- (g) Industry trends and recent releases of industry-recognized leading practice controls and benchmarks.

Supplemental Guidance: The proposed security-related activity plan should be reviewed and vetted by management business representatives and technology representatives. Additionally, validation of the strategy by an independent assessor should be considered.

²⁰² ISO/IEC 27002:2013 – 12.7

²⁰³ ISO/IEC 27002:2013 – 12.7.1

²⁰⁴ MA201CMR17 17.03(2)(b)(i)

9.0 Communications Security Policy

KR shall employ industry-recognized leading practice principles that promote efficient and effective information security protections within information systems and the network.

Management Intent: The purpose of this policy is to ensure sufficient mechanisms are in place to protect the confidentiality and integrity of KR's communications.

9.1 Network Security Management

The objective is to ensure the protection of information in networks and its supporting information processing facilities.²⁰⁵

9.1.1 NETWORK CONTROLS

Networks should be managed and controlled to protect information in systems and applications.²⁰⁶

9.1.1.1 FIREWALL & ROUTER CONFIGURATIONS

Control Objective: The firm establishes firewall and router configuration standards that follow industry-recognized leading practices.²⁰⁷

Standard: Asset custodians are required to establish firewall and router configuration standards that include the following:

- (a) Asset custodians are required to establish and maintaining a formal process for approving and testing all network connections and changes to both firewall and router configurations;
- (b) Asset custodians are required to establish and maintaining detailed network diagrams. Network diagrams must:
 - 1. Document all connections to data, including any wireless networks;
 - 2. Be reviewed annually; and
 - 3. Be updated as the network changes to reflect the current architecture in place;
- (b) Asset custodians are required to establish and maintaining detailed data flow diagrams that show all data flows across systems and networks;
- (c) A firewall is required to be installed at each Internet connection and KR's internal networks;
- (d) All network devices must have a documented description of any applicable groups, roles, and responsibilities associated with the device to support configuration management and review processes;
- (e) A documented business justification is required for all services, protocols, and ports allowed through the firewall(s), including documentation of security features implemented for those protocols considered to be insecure; and
- (f) Firewall and router rule sets must be reviewed at least once every six (6) months and the review must cover:
 - 1. Validation of Access Control Lists (ACLs); and
 - 2. Vulnerability management (e.g., validating software and firmware is current).

Supplemental Guidance: Examples of insecure services, protocols, or ports include but are not limited to:

- File Transfer Protocol (FTP)
- Hypertext Transfer Protocol (HTTP)
- Telnet
- Post Office Protocol (POP3)
- Internet Message Access Protocol (IMAP)

9.1.1.2 SAFEGUARDING DATA OVER OPEN NETWORKS

Control Objective: The firm uses strong cryptography and security protocols to safeguard sensitive data during transmission over open, public networks.²⁰⁸

²⁰⁵ ISO/IEC 27002:2013 – 13.1

²⁰⁶ ISO/IEC 27002:2013 – 13.1.1

²⁰⁷ PCI DSS (v3.2) 1.1-1.1.7

²⁰⁸ PCI DSS (v3.2) 4.1-4.1.1

Standard: To safeguard sensitive data during transmission, asset custodians are required to ensure the following:

- (a) Only trusted keys and certificates are accepted;
- (b) Strong cryptography and security protocols are used to safeguard sensitive data during transmission over open, public networks. Examples of technologies that support this requirement include, but are not limited to:
 1. Transportation Security Layer (TLS);
 2. IP Security (IPSEC);
 3. Secure Shell (SSH); and
 4. Secure File Transfer Protocol (SFTP) / File Transfer Protocol - Secure (FTP-S); and
- (c) Wireless networks transmitting sensitive data or connected to sensitive networks, use industry-recognized leading practices (e.g., IEEE 802.11i) to implement strong encryption for authentication and transmission.

Supplemental Guidance: Examples of open, public networks that are in scope of the PCI DSS include but are not limited to:

- The Internet;
- Wireless technologies;
- Global System for Mobile communications (GSM); and
- General Packet Radio Service (GPRS).

9.1.1.3 TRANSMITTING SENSITIVE DATA

Control Objective: The firm prohibits the transmission of unprotected sensitive data by end-user messaging technologies. ²⁰⁹

Standard: KR's prohibits the transmissions of unencrypted sensitive data by end-user messaging technologies.

Supplemental Guidance: Examples of end-user messaging technologies include, but are not limited to:

- Electronic mail (e-mail);
- Instant messaging (IM);
- Chat; and
- Short Message Service (SMS)

9.1.1.4 ROGUE WIRELESS DETECTION

Control Objective: The firm implements processes to test for the presence of Wireless Access Points (WAPs) and detect and identify all authorized and unauthorized wireless access points. ²¹⁰

Standard: Asset custodians are required to implement a process to test for the presence of Wireless Access Points (WAPs) that includes:

- (a) Detecting and identifying all authorized and unauthorized wireless access points at least once every ninety (90) days;
- (b) Maintaining an inventory of authorized WAPs including a documented business justification; and
- (c) Implementing incident response procedures in the event unauthorized WAPs are detected.

Supplemental Guidance: Detection methods must be sufficient to detect and identify both authorized and unauthorized devices. Methods that may be used in the rogue WAPs (802.11) detection process includes, but are not limited to:

- Wireless network scans,
- Physical/logical inspections of system components and infrastructure,
- Network Access Control (NAC); or
- Wireless Intrusion Detection Systems (IDS) / Intrusion Prevention Systems (IPS)

9.1.1.5 INTRUSION DETECTION & PREVENTION SYSTEMS

Control Objective: The firm utilizes intrusion-detection and/or intrusion-prevention techniques to detect and/or prevent intrusions into the network. ²¹¹

Standard: Asset custodians are required to utilize Intrusion Detection Systems (IDS) and/or Intrusion Prevention Systems (IPS) to:

²⁰⁹ PCI DSS (v3.2) 4.2

²¹⁰ PCI DSS (v3.2) 11.1-11.1.2

²¹¹ PCI DSS (v3.2) 11.4

- (a) Prevent intrusions into the network;
- (b) Monitor all traffic at the perimeter of the network, as well as at critical points in the network;
- (c) Alert personnel to suspected compromises within the network; and
- (d) Keep all intrusion-detection and prevention engines, baselines, and signatures up to date.

Supplemental Guidance: Intrusion detection and/or intrusion prevention techniques (such as IDS/IPS) compare the traffic coming into the network with known “signatures” and/or behaviors of thousands of compromise types (hacker tools, Trojans, and other malware), and send alerts and/or stop the attempt as it happens. Without a proactive approach to unauthorized activity detection, attacks on (or misuse of) computer resources could go unnoticed in real time. Security alerts generated by these techniques should be monitored so that the attempted intrusions can be stopped.

9.1.2 SECURITY OF NETWORK SERVICES

Security mechanisms, service levels and management requirements of all network services should be identified and included in network services agreements, whether these services are provided in-house or outsourced.²¹²

9.1.2.1 RESTRICTING CONNECTIONS

Control Objective: The firm builds firewall and router configurations that restrict connections between untrusted networks and internal systems.²¹³

Standard: Asset custodians are required to deploy and configure of firewalls and routers in order to restrict connections between untrusted networks and any system components within the network by the following means:

- (a) Implementing Access Control Lists (ACLs) and other applicable filters to restrict the inbound and outbound traffic to only that which is necessary, as defined by a business justification;
- (b) Securing and synchronizing router and firewall configuration files; and
- (c) Positioning perimeter firewalls between wireless networks and internal networks.

Supplemental Guidance: Not all firewalls and routers have the functionality for the running configuration to be different than the configuration loaded at startup. However, if the functionality exists, the startup configuration must be synchronized with the correct running configuration so that a reboot of the device will not degrade network security.

9.1.3 SEGREGATION IN NETWORKS

Groups of information services, users and information systems should be segregated on networks.²¹⁴

9.1.3.1 SECURITY FUNCTION ISOLATION

Control Objective: Information system configurations isolate security functions from non-security functions.²¹⁵

Standard: Asset custodians and data owners are required to implement isolation techniques to prevent functions that require different security levels from co-existing on the same server. Isolation techniques include, but are not limited to:

- (a) Implement only one primary function per server to prevent functions that require different security levels from co-existing on the same server;
- (b) Firewall and router configurations need be configured to restrict connections between untrusted networks and any system components in KR’s trusted, internal network;
- (c) Firewall need be installed at all connections from an internal to any other internal or external network;
- (d) Demilitarized Zones (DMZs) need to be implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports;
- (e) Servers which access external networks or are accessed from external networks need to be logically isolated from the private Intranet;
- (f) Networks need to be segregated or divided into separate logical domains, so access between domains can be controlled by means of secure devices;
- (g) Switched network technology need to be utilized, when possible, to prevent eavesdropping, session stealing, or other exploits based on the accessibility of network traffic;

²¹² ISO/IEC 27002:2013 – 13.1.2

²¹³ PCI DSS (v3.2) 1.2-1.2.3

²¹⁴ ISO/IEC 27002:2013 – 13.1.3

²¹⁵ PCI DSS (v3.2) 1.2, 1.3.1, 2.2.1 & 11.3.4

- (h) Trust relationships should be strictly avoided between information resources with different risk profiles; and
- (i) Information resources with higher protection requirements for confidentiality should not have a trusted relationship with a system that has lower protection requirements.

Supplemental Guidance: The information system isolates security functions from non-security functions by means of an isolation boundary (implemented via partitions and domains) that controls access to and protects the integrity of the hardware, software, and firmware that perform those security functions. An “untrusted network” is any network that is external to the networks belonging to the entity under review, and/or which is out of the entity's ability to control or manage. Information systems restrict access to security functions through the use of access control mechanisms and by implementing least privilege capabilities.

9.1.3.2 LAYERED DEFENSES

Control Objective: The firm implements security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers.²¹⁶

Standard: KR is required to use a Defense-in-Depth (DiD) architecture to protect the Confidentiality, Integrity, and Availability of information systems and data, placing information systems that contain sensitive data in an internal network zone, segregated from the DMZ and other untrusted networks.

Supplemental Guidance: The implementation of layered structures with minimized interactions among security functions and non-looping layers (e.g., lower-layer functions do not depend on higher-layer functions) further enables the isolation of security functions and management of complexity.

9.1.3.3 APPLICATION PARTITIONING

Control Objective: Information system configurations separate user functionality (including user interface services) from information system management functionality.²¹⁷

Standard: Where technically feasible, physically or logically separate user interface services (e.g., public Web pages) are required to be implemented separately from storage and management services (e.g., administrative or database management). Separation may be accomplished through the use of one or more of the following:

- (a) Network segmentation;
- (b) Different computers;
- (c) Different central processing units;
- (d) Different instances of the operating system;
- (e) Different network addresses; or
- (f) Other methods as appropriate.

Supplemental Guidance: Information system management functionality includes, for example, functions necessary to administer databases, network components, workstations, or servers, and typically requires privileged user access. The separation of user functionality from information system management functionality is either physical or logical. Organizations implement separation of system management-related functionality from user functionality by using different computers, different central processing units, different instances of operating systems, different network addresses, virtualization techniques, or combinations of these or other methods, as appropriate. This type of separation includes, for example, web administrative interfaces that use separate authentication methods for users of any other information system resources. Separation of system and user functionality may include isolating administrative interfaces on different domains and with additional access controls.

²¹⁶ PCI DSS (v3.2) 1.3.7

²¹⁷ PCI DSS (v3.2) 11.3.4

9.2 Information Transfer

The objective is to maintain the security of information transferred within an organization and with any external entity.²¹⁸

9.2.1 INFORMATION TRANSFER POLICIES AND PROCEDURES

Formal transfer policies, procedures, and controls should be in place to protect the transfer of information through the use of all types of communication facilities.²¹⁹

9.2.1.1 DIRECT INTERNET ACCESS

Control Objective: The firm prohibits direct public access to the Internet and internal systems.²²⁰

Standard: Asset custodians are required to establish and manage firewall and router configuration standards to prohibit direct public access to the Internet and any system component on internal networks that includes, but is not limited to:

- (a) Demilitarized Zones (DMZ) are required to be implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports;
- (b) Inbound Internet traffic shall be limited to IP addresses within the DMZ;
- (c) Implement anti-spoofing measures to detect and block forged source IP addresses from entering the network;
- (d) Unauthorized outbound traffic from the CDE to the Internet are prohibited;
- (e) Stateful inspection (dynamic packet filtering) must be implemented;
- (f) System components that store data must be placed within an internal network zone, segregated from the DMZ and other untrusted networks; and
- (g) Private IP addresses and routing information are prohibited from being disclosed to unauthorized parties.

Supplemental Guidance: A stateful firewall keeps track of the state of network connections (such as TCP streams or UDP communication) and is able to hold significant attributes of each connection in memory. These attributes are collectively known as the state of the connection and may include such details as the IP addresses and ports involved in the connection and the sequence numbers of the packets traversing the connection. Stateful inspection monitors incoming and outgoing packets over time, as well as the state of the connection, and stores the data in dynamic state tables. This cumulative data is evaluated, so that filtering decisions would not only be based on administrator-defined rules, but also on the context that has been built by previous connections as well as previous packets belonging to the same connection.

Methods to obscure IP addressing may include, but are not limited to:

- Network Address Translation (NAT)
- Placing servers containing data behind proxy servers/firewalls,
- Removal or filtering of route advertisements for private networks that employ registered addressing, or
- Internal use of RFC1918 address space instead of registered addresses.

9.2.2 AGREEMENTS ON INFORMATION TRANSFER

Agreements should address the secure transfer of business information between the firm and external parties.²²¹

9.2.2.1 ACCESS AGREEMENTS FOR INFORMATION TRANSFER

Control Objective: The firm:²²²

- Ensures that individuals requiring access to organizational information and information systems sign appropriate access agreements prior to being granted access; and
- Reviews/updates the access agreements.

Standard: KR is required to ensure that access to information with special protection measures is granted only to individuals who:

- (a) Have a valid access authorization; and
- (b) Satisfy personnel security criteria.

²¹⁸ ISO/IEC 27002:2013 – 13.2

²¹⁹ ISO/IEC 27002:2013 – 13.2.1

²²⁰ PCI DSS (v3.2) 1.3-1.3.7

²²¹ ISO/IEC 27002:2013 – 13.2.2

²²² HIPAA 164.308(a)(4)(i) | NIST Cybersecurity Framework PR.DS-5 & PR.IP-11

Supplemental Guidance: This NDA should be maintained on file in accordance with document retention guidelines. Prior to granting any access to KR information systems or data, a Non-Disclosure Agreement (NDA) need to be signed by the employee, contractor, service provider or partner requiring access.

9.2.3 ELECTRONIC MESSAGING

The information involved in electronic messaging should be appropriately protected.²²³

9.2.3.1 TRANSMISSION CONFIDENTIALITY

Control Objective: The firm protects the confidentiality of transmitted information.²²⁴

Standard: Asset custodians and data owners are required to employ cryptographic mechanisms to prevent unauthorized disclosure of information during transmission.

Supplemental Guidance: This control applies to both internal and external networks. For distributed systems including, for example, service-oriented architectures, this control applies to end-to-end confidentiality between the system components/services originating the transmitted information and the system components/services receiving the transmitted information. Organizations relying on commercial service providers offering transmission services as commodity items rather than as fully dedicated services may find it difficult to obtain the necessary assurances regarding the implementation of needed security controls for transmission confidentiality. When it is infeasible or impractical to obtain the necessary security controls and assurances of control effectiveness through appropriate contracting vehicles, organizations implement appropriate compensating security controls or explicitly accept the additional risk.

The National Institute of Standards and Technology (NIST) guidance is the authoritative source for selection and implementation of this control based on the security categorization and risk environment of the information and/or information system.

9.2.3.2 AD-HOC TRANSFERS

Control Objective: The firm employs a technology-based method for securely exchanging large files with external parties.

Standard: Unscheduled, infrequent and one-time file transfers that contain sensitive data are required to be performed through encrypted transport protocols.

Supplemental Guidance: Encrypted transport protocols may include Secure FTP or HTTPS. Examples include DropBox, Box and Google Drive for secure, large file transfer to unique recipients.

9.2.3.3 COMMUNICATIONS TECHNOLOGIES

Control Objective: The firm establishes usage restrictions and implementation guidance for communications technologies based on the potential to cause damage to information systems, if used maliciously.

Standard: Human Resources (HR) is responsible for establishing usage restrictions and implementation guidance for the following communications technologies based on the potential to cause damage to information systems, if used maliciously:

- (a) Electronic Mail (email);
- (b) Instant Messaging (IM);
- (c) Voice Over Internet Protocol (VOIP);
- (d) Analog Lines (Plain Old Telephone Service (POTS)); and
- (e) Facsimile (Fax) Machines (analog & digital).

Supplemental Guidance: None

²²³ ISO/IEC 27002:2013 – 13.2.3

²²⁴ HIPAA 164.312(e)(1) & 164.312(e)(2)(i) | MA201CMR17 17.04(3) | OR646A.622(2)(d)(C)(iii)

9.2.3.4 INTRANETS

Control Objective: The firm establishes terms and conditions, consistent with any trust relationships established with other organizations owning, operating, and/or maintaining external information systems, allowing authorized individuals to:²²⁵

- Access the information system from the external information systems; and
- Process, store, and/or transmit organization-controlled information using the external information systems.

Standard: Non-employee users are authorized to access KR's Intranet only when Non-Disclosure Agreements (NDAs) are on file for each of the authorized, external users.

Supplemental Guidance: This control addresses the use of internal and external information systems for the processing, storage, or transmission of organizational information, including, for example, accessing cloud-based information systems and services.

9.2.4 CONFIDENTIALITY OR NON-DISCLOSURE AGREEMENTS (NDAs)

Requirements for confidentiality or non-disclosure agreements reflecting the firm needs for the protection of information should be identified, regularly reviewed and documented.²²⁶

9.2.4.1 BUSINESS PARTNER CONTRACTS

Control Objective: If the firm permits a business partner to create, receive, maintain, or transmit sensitive information on the firm behalf, the firm obtains satisfactory assurances from the business associate that appropriate safeguards are in place and enforced.²²⁷

Standard: KR is required to maintain written and executed agreements with service providers to ensure:

- (a) Appropriate management, operational and technical control safeguards are in place to ensure the confidentiality, integrity and availability of KR's sensitive data the business associate creates, receives, maintains, or transmits; and
- (b) Service providers acknowledge in writing that they are responsible for the security of KR data (e.g., data) that the service provider possesses or otherwise stores, processes, or transmits on behalf of KR, or to the extent that they could impact the security of KR data environment.

Procedures: Agreements, contracts, and other arrangements should specify:

- All sensitive information will be held in strict confidence and accessed only for the explicit business purpose of the contract;
- The service provider must be compliant with and maintain compliance with the protective conditions outlined in the contract;
- The service provider is liable to protect all sensitive information it stores and/or accesses;
- In the event of a security breach, due to its actions or inactions, the service provider shall bear all responsibility and expenses associated with the response to the security breach;
- The service provider must return or destroy all sensitive data received from KR, upon completion or termination of the contract;
- Any violation of the service provider's security posture amounts to a material breach of contract and entitles KR to immediately terminate the contract without penalty;
- The right to audit the service provider's security posture and compliance is authorized at any time; and
- The contract's protective requirements shall survive any termination agreement.

Supplemental Guidance: Business unit management should periodically review and reevaluate the list of business partners to determine who has access to sensitive data in order to assess whether the list is complete and current.

A business partner is not in compliance with information security requirements if the business partner knew of or knows of a pattern of activity or practice of the business partner that constituted a material breach or violation of its obligation under the contract or other arrangement, unless the business partner took reasonable steps to cure the breach or end the violation, as applicable, and, if such steps were unsuccessful.

²²⁵ NIST Cybersecurity Framework ID.AM-4 & PR.AC-3

²²⁶ ISO/IEC 27002:2013 – 13.2.4

²²⁷ HIPAA 164.308(b)(1), 164.314(a)(1)(i)-(ii), 164.314(a)(1)(ii)(A)-(B), 164.314(a)(2)(i)(A)-(D), 164.314(a)(2)(ii)(A)-(D), 164.314(a)(2)(ii)(1)-(2) | PCI DSS (v3.2) 2.6

9.2.4.2 THIRD-PARTY PERSONNEL SECURITY

Control Objective: The firm: ²²⁸

- Establishes personnel security requirements including security roles and responsibilities for third-party providers;
- Documents personnel security requirements; and
- Monitors provider compliance.

Standard: KR is required to ensure third-party personnel access is granted only to individuals who:

- (a) Have a valid access authorization;
- (b) Satisfy associated personnel security criteria;
- (c) Have read, understand, and signed a Non-Disclosure Agreement (NDA); and
- (d) Have read, understand, and signed an acknowledgment that he or she understands and will abide by KR's policies, procedures, standards, and guidelines.

Supplemental Guidance: None

9.2.4.3 MONITORING FOR INFORMATION DISCLOSURE

Control Objective: The firm monitors for evidence of unauthorized exfiltration or disclosure of organizational information. ²²⁹

Standard: Management and corporate communications personnel are required to periodically perform Internet searches of key terminology applicable to business operations for an indication of information leakage.

Supplemental Guidance: Open source information includes, for example, social networking sites and Internet-based web pages.

²²⁸ NIST Cybersecurity Framework ID.AM-6, ID.GV-2, PR.AT-3 & PR.IP-11

²²⁹ MA201CMR17 17.04(3) | NIST Cybersecurity Framework PR.PT-1 & DE.CM-3

10.0 System Acquisition, Development and Maintenance Policy

KR shall ensure that application and system development employ adequate security measures during all phases of the System Development Life Cycle (SDLC) to ensure security-related risks are identified and remediated appropriately.

Management Intent: The purpose of this policy is to ensure that information systems employ a System Development Life Cycle (SDLC), where the security of systems and services are assessed throughout their operational life to reduce risks to KR.

10.1 Security Requirements of Information Systems

The objective is to ensure that information security is an integral part of information systems across the entire lifecycle. This also includes the requirements for information systems which provide services over public networks.²³⁰

10.1.1 INFORMATION SECURITY REQUIREMENTS ANALYSIS AND SPECIFICATION

The information security related requirements should be included in the requirements for new information systems or enhancements to existing information systems.²³¹

10.1.1.1 SECURE CONFIGURATIONS

Control Objective: The firm develops configuration standards for all system components that are consistent with industry-accepted system hardening standards.²³²

Standard: Asset custodians are required to develop configuration standards for all system components that are consistent with industry-accepted system hardening standards. This process of pre-production hardening systems includes, but is not limited to:

- (a) Verifying that system configuration standards are:
 1. Updated as new vulnerability issues are identified;
 2. Applied when new systems are configured;
 3. Consistent with industry-accepted hardening standards;
- (b) Implementing only one primary function per server to prevent functions that require different security levels from co-existing on the same server (e.g., web servers, database servers, and DNS should be implemented on separate servers);
- (c) Enforcing least functionality, which includes but is not limited to:
 1. Allowing only necessary and secure services, protocols, and daemons;
 2. Removing all unnecessary functionality, which includes but is not limited to:
 - i. Scripts;
 - ii. Drivers;
 - iii. Features;
 - iv. Subsystems;
 - v. File systems; and
 - vi. Unnecessary web servers
- (d) Implementing security features for any required services, protocols or daemons that are considered to be insecure, which includes but is not limited to using secured technologies such as Secure Shell (SSH), Secure File Transfer Protocol (S-FTP), Transport Layer Security (TLS), or IPSec VPN to protect insecure services such as NetBIOS, file-sharing, Telnet, and FTP;
- (e) Verifying system security parameters are configured to prevent misuse; and
- (f) Documenting the functionality present on information systems.

Supplemental Guidance: [Appendix K: System Hardening](#) contains the approved baseline configurations. Baseline configurations should be based on industry-recognized leading practices. Sources of approved baseline configurations are:

- Microsoft Security Configuration Wizard
- Center for Internet Security (CIS)
- Defense Information Security Agency (DISA) Security Technical Implementation Guides (STIGs)²³³

²³⁰ ISO/IEC 27002:2013 – 14.1

²³¹ ISO/IEC 27002:2013 – 14.1.1

²³² PCI DSS (v3.2) 2.2-2.2.5

²³³ DISA STIGs official site: <http://iase.disa.mil/stigs/index.html>

If virtualization technologies are used, verify that only one primary function is implemented per virtual system component or device.

10.1.2 SECURING APPLICATION SERVICES ON PUBLIC NETWORKS

The information involved in application services passing over public networks should be protected from fraudulent activity, contract dispute and unauthorized disclosure and modification.²³⁴

10.1.3 PROTECTING APPLICATION SERVICES TRANSACTIONS

The information involved in application service transactions should be protected to prevent incomplete transmission, misrouting, unauthorized message alteration, unauthorized disclosure, unauthorized message duplication or replay.²³⁵

10.1.3.1 TRANSMISSION INTEGRITY

Control Objective: The firm protects the integrity of transmitted information.²³⁶

Standard: Asset custodians and data owners are required to prevent unauthorized disclosure of information during transmission, ensuring information systems transmitting sensitive information:

- (a) Employ cryptographic mechanisms;
- (b) Use strong cryptography and security protocols (for example, TLS, IPSEC, SSH, etc.) to safeguard sensitive data during transmission over public or private networks;
 - i. Examples of public networks include, but are not limited to:
 - 1. The Internet;
 - 2. Wireless technologies;
 - 3. Global System for Mobile communications (GSM); and
 - 4. General Packet Radio Service (GPRS).
 - ii. Examples of private networks include, but are not limited to:
 - 1. Local Area Networks (LAN); and
 - 2. Virtual Private Network (VPN).
- (c) Verify that the proper encryption strength is implemented for the encryption methodology in use, based on documented vendor recommendations and industry-recognized leading practices; and
- (d) Verify that the protocol is implemented to use only secure configurations and does not support insecure versions or configurations. For TLS implementations:
 - i. Verify that HTTPS appears as a part of the browser Universal Record Locator (URL); and
 - ii. Verify that no sensitive data is required when HTTPS does not appear in the URL.

Supplemental Guidance: This control applies to both internal and external networks. For distributed systems including, for example, service-oriented architectures, this control applies to end-to-end integrity between the system components/services originating the transmitted information and the system components/services receiving the transmitted information. Organizations relying on commercial service providers offering transmission services as commodity items rather than as fully dedicated services may find it difficult to obtain the necessary assurances regarding the implementation of needed security controls for transmission integrity. When it is infeasible or impractical to obtain the necessary security controls and assurances of control effectiveness through appropriate contracting vehicles, KR may implement appropriate compensating security controls or explicitly accept the additional risk.

The National Institute of Standards and Technology (NIST) guidance is the authoritative source for selection and implementation of this control based on the security categorization and risk environment of the data and/or information system.

10.2 Security in Development and Support Processes

The objective is to ensure that information security is designed and implemented within the development lifecycle of information systems.²³⁷

²³⁴ ISO/IEC 27002:2013 – 14.1.2

²³⁵ ISO/IEC 27002:2013 – 14.1.3

²³⁶ HIPAA 164.312(e)(2)(i) | PCI DSS (v3.2) 4.1 | NIST Cybersecurity Framework PR.DS-2 & PR.DS-5

²³⁷ ISO/IEC 27002:2013 – 14.2

10.2.1 SECURE DEVELOPMENT

Rules for the development of software and systems should be established and applied to developments within the firm.²³⁸

10.2.1.1 APPLICATION DEVELOPMENT

Control Objective: The firm develops all internal and external software applications in accordance with industry-recognized leading practices.²³⁹

Standard: Data owners and asset custodians are required to ensure that internal and external developers:

- (a) Develop software applications in accordance with industry-recognized leading practices;
- (b) Incorporate information security throughout the software development lifecycle;
- (c) Remove custom application accounts, user IDs, and passwords before applications become active or are released to customers; and
- (d) Review custom code prior to release to production or customers in order to identify any potential coding vulnerability (using either manual or automated process) to include at least the following:
 - 1. Code changes must be reviewed by individuals other than the originating code author, and by individuals knowledgeable about code review techniques and secure coding practices;
 - 2. Code reviews must ensure code is developed according to secure coding guidelines;
 - 3. Appropriate corrections must be implemented prior to release; and
 - 4. Code-review results must be reviewed and approved by management prior to release.

Supplemental Guidance: Secure coding guidelines are based on the Open Web Application Security Project (OWASP) guide.²⁴⁰

10.2.2 SYSTEM CHANGE CONTROL PROCEDURES

Changes to systems within the development lifecycle should be controlled by the use of formal change control procedures.²⁴¹

10.2.2.1 CHANGE CONTROL

Control Objective: The firm follows change control processes and procedures for all changes to system components.²⁴²

Standard: KR's asset custodians are required to follow change control processes and procedures for all changes to system components:

- (a) Utilize separate environments for development/testing/staging and production;
- (b) Utilize a separation of duties between development/testing/staging and production environments;
- (c) Prohibit the use of production data (e.g., live PANs) for testing or development;
- (d) Remove test data and accounts before production systems become active / goes into production;
- (e) Develop change control procedures for the implementation of security patches and software modifications, which includes, but is not limited to the following:
 - 1. Documentation of impact;
 - 2. Documented change approval by authorized parties;
 - 3. Functionality testing to verify that the change does not adversely impact the security of the system; and
 - 4. Back-out procedures; and
- (f) Upon completion of significant change, all relevant compliance requirements must be implemented on all new or changed systems and networks, and documentation updated as applicable.

Supplemental Guidance: Without properly documented and implemented change controls, security features could be inadvertently or deliberately omitted or rendered inoperable, processing irregularities could occur, or malicious code could be introduced.

10.2.2.2 SECURE CODING PRINCIPLES

Control Objective: The firm develops applications based on secure coding principles.²⁴³

²³⁸ ISO/IEC 27002:2013 – 14.2.1

²³⁹ PCI DSS (v3.2) 6.3-6.3.2

²⁴⁰ Open Web Application Security Project (OWASP) Guide <https://www.owasp.org>

²⁴¹ ISO/IEC 27002:2013 – 14.2.2

²⁴² PCI DSS (v3.2) 6.4-6.4.6

²⁴³ PCI DSS (v3.2) 6.5-6.5.10

Standard: Data owners and asset custodians are required to address common coding vulnerabilities in the software development process by ensuring the following:

- (a) At least annually, developers are properly trained in current, secure coding techniques, including:
 - 1. How to avoid common coding vulnerabilities, and
 - 2. Understanding how sensitive data is handled in memory
- (b) Applications are developed based on secure coding guidelines:
 - 1. Injection flaws, particularly SQL injection:
 - i. OS Command Injection;
 - ii. LDAP and XPath injection flaws, and
 - iii. Other forms of injection flaws;
 - 2. Buffer overflow;
 - 3. Insecure cryptographic storage;
 - 4. Insecure communications;
 - 5. Improper error handling;
 - 6. All “High” vulnerabilities identified in the vulnerability identification process Cross-site scripting (XSS);
 - 7. Improper access control, including but not limited to:
 - i. Insecure direct object references,
 - ii. Failure to restrict URL access; and
 - iii. Directory traversal;
 - 8. Cross-site request forgery (CSRF); and
 - 9. Broken authentication and session management.

Supplemental Guidance: Secure coding guidelines are based on the Open Web Application Security Project (OWASP) guide.²⁴⁴

10.2.3 TECHNICAL REVIEW OF APPLICATIONS AFTER OPERATING PLATFORM CHANGES

When operating platforms are changed, business critical applications should be reviewed and tested to ensure there is no adverse impact on organizational operations or security.²⁴⁵

10.2.3.1 TEST, VALIDATE & DOCUMENT CHANGES

Control Objective: The firm tests, validates, and documents change to information systems before implementing the changes on the operational system.

Standard: Asset custodians and data owners are required to test configuration changes, wherever it is possible, to test a configuration, prior to deploying in the production environment and once again after the change is implemented.

Supplemental Guidance: If it is not technically or logistically feasible to test a configuration change, compensating control should be identified and implemented in order to mitigate any negative impact to the production environment from an adverse change event. Compensating controls can include, but is not limited to:

- Images of systems;
- Backups of configurations;
- Viable backout plan;
- After-hours implementation; and
- Pilot/test group rollouts.

10.2.3.2 SECURITY FUNCTIONALITY VERIFICATION

Control Objective: Information systems are verified to correctly process security functions when anomalies are discovered.

Standard: Asset custodians are required to test security-related tools (e.g., antivirus software) to ensure information systems provide notification of failed events.

Supplemental Guidance: After major changes or software upgrades, it is recommended to test security-related tools to ensure the change did not disable the functionality of the security tool. An example of security functionality verification is the European Institute

²⁴⁴ Open Web Application Security Project (OWASP) Guide <https://www.owasp.org>

²⁴⁵ ISO/IEC 27002:2013 – 14.2.3

of Computer Anti-virus Research (EICAR) Standard Anti-Virus Test File, which is used to ensure antimalware software is properly detecting and removing threats.

10.2.4 RESTRICTIONS ON CHANGES TO SOFTWARE PACKAGES

Modifications to software packages should be discouraged, limited to necessary changes and all changes should be strictly controlled.²⁴⁶

10.2.4.1 LIBRARY PRIVILEGES

Control Objective: The firm limits privileges to change software resident within software libraries.

Standard: Data owners are required to limit privileges to change software archived within software libraries.

Supplemental Guidance: Software libraries include privileged programs.

10.2.5 SECURE SYSTEM ENGINEERING PRINCIPLES

Principles for engineering secure systems should be established, documented, maintained and applied to any information system implementation efforts.²⁴⁷

10.2.5.1 SECURE SYSTEM ENGINEERING PRINCIPLES

Control Objective: The firm applies industry-recognized leading practices engineering principles in the specification, design, development, implementation, and modification of information systems.²⁴⁸

Standard: Asset custodians are required to implement configuration standards for all system components that address known security vulnerabilities and are consistent with industry-accepted system hardening standards ([Appendix K: System Hardening](#)).

Supplemental Guidance: KR applies security engineering principles primarily to new development information systems or systems undergoing major upgrades. For legacy systems, security engineering principles must be applied to system upgrades and modifications to the extent feasible, given the current state of hardware, software, and firmware within those systems. Security engineering principles include, for example:

- Developing layered protections;
- Establishing sound security policy, architecture, and controls as the foundation for design;
- Incorporating security requirements into the system development life cycle;
- Delineating physical and logical security boundaries;
- Ensuring system developers are trained on how to build secure software;
- Tailoring security controls to meet organizational and operational needs;
- Performing threat modeling to identify use cases, threat agents, attack vectors, and attack patterns as well as compensating controls and design patterns needed to mitigate risk; and
- Reducing risk to acceptable levels, thus enabling informed risk management decisions.

Sources of industry-accepted system hardening standards include, but are not limited to:

- Center for Internet Security (CIS);
- International Organization for Standardization (ISO);
- SysAdmin Audit Network Security (SANS) Institute; and
- National Institute of Standards Technology (NIST)

10.2.5.2 PORTS, PROTOCOLS & SERVICES DOCUMENTATION

Control Objective: The firm requires developers of information systems, components, and services to identify early in the system development life cycle, the functions, ports, protocols, and services intended for organizational use.

²⁴⁶ ISO/IEC 27002:2013 – 14.2.4

²⁴⁷ ISO/IEC 27002:2013 – 14.2.5

²⁴⁸ PCI DSS (v3.2) 2.2 | NIST Cybersecurity Framework PR.IP-2

Standard: Developers are required to provide asset custodians and with documentation describing the functions, ports, protocols, and services necessary for the information system or application to function on KR's network.

Supplemental Guidance: This control enhancement enables KR to maintain on-going situational awareness of the functions, ports, protocols, and services that are being employed in the information system. This includes functions, ports, protocols, and services that are part of distributed information systems, for example, service-oriented architectures or cloud-based information systems. Such information can be useful when the need arises to understand the tradeoffs involved in blocking specific ports, protocols, or services or when requiring external service providers to do so.

10.2.6 SECURE DEVELOPMENT ENVIRONMENT

Organizations should establish and appropriately protect secure development environments for system development and integration efforts that cover the entire system development lifecycle.²⁴⁹

10.2.6.1 DEVELOPMENT ENVIRONMENTS

Control Objective: The firm maintains a segmented network to ensure a secure development environment.

Standard: KR is required to:

- (a) Appropriately segment development networks from production networks; and
- (b) Secure its development environments for system development and integration efforts.

Supplemental Guidance: None

10.2.7 OUTSOURCED DEVELOPMENT

The firm should supervise and monitor the activity of outsourced system development.²⁵⁰

10.2.7.1 EXTERNAL SERVICE PROVIDERS

Control Objective: If the firm outsources IT-related activities, the firm:²⁵¹

- Conducts an organizational assessment of risk prior to the acquisition or outsourcing of services;
- Maintains and implements policies and procedures to manage service providers (e.g., Software-as-a-Service (SaaS), Web hosting companies, collocation providers, or email providers), through observation, review of policies and procedures, and review of supporting documentation. Including:
 - Maintaining a list of service providers.
 - Maintaining a written agreement that includes an acknowledgment that the service providers are responsible for the security of data the service providers possess.
 - Ensuring there is an established process for engaging service providers including proper due diligence prior to engagement.
- Maintains a program to monitor service providers' control compliance status at least annually.
- Requires that providers of external information system services comply with organizational information security requirements and employ appropriate security controls in accordance with local, state and Federal laws, as well as all applicable regulatory requirements;
- Defines and documents oversight and user roles and responsibilities with regard to external information system services; and
- Conducts an organizational assessment of risk prior to the acquisition or outsourcing of services.

Standard: Asset custodians and data owners are required to:

- (a) Maintain a comprehensive list of service providers, including all applicable Service Level Agreements (SLAs);
- (b) Require that providers of external information systems comply with KR information security requirements and employ appropriate security controls in accordance with local, state and Federal laws, as well as all applicable regulatory requirements;

²⁴⁹ ISO/IEC 27002:2013 – 14.2.6

²⁵⁰ ISO/IEC 27002:2013 – 14.2.7

²⁵¹ MA201CMR17 17.03(2)(f)(1) | OR646A.622(2)(d)(A)(v) | PCI DSS (v3.2) 12.8.2 & 12.8.4 | NIST Cybersecurity Framework ID.AM-4, PR.AT-3 & DE.CM-6

- (c) Maintain a written agreement that includes an acknowledgment that the service providers are responsible for the security of data the service providers possess;
- (d) Define oversight responsibilities with regard to external information system services;
- (e) Perform a review of the service provided for acceptable service levels;
- (f) Conduct a risk assessment outsourcing of services; and
- (g) Monitor security control compliance by external service providers.

Supplemental Guidance: External information system services are services that are implemented outside of the authorization boundaries of KR's control. This includes services that are used by, but not a part of, KR's network. For services external to KR, a chain of trust requires that KR establish and retain a level of confidence that each participating provider in the potentially complex consumer-provider relationship provides adequate protection for the services rendered. External information system services documentation includes service providers, end user security roles and responsibilities, and service-level agreements. Service-level agreements define expectations of performance for security controls, describe measurable outcomes, and identify remedies and response requirements for identified instances of noncompliance.

10.2.8 SYSTEM SECURITY TESTING

Testing of security functionality should be carried out during development.²⁵²

10.2.8.1 USE OF LIVE DATA

Control Objective: The firm approves, documents, and controls the use of live data in development and test environments for the information system, system component, or information system service.²⁵³

Standard: The following "live" production data is prohibited from use in testing or development:

- (a) Personally, Identifiable Information (PII); and
- (b) Primary Account Numbers (PANs)

Supplemental Guidance: The use of live data in preproduction environments can result in significant risk to KR. KR can minimize such risk by using test or dummy data during the development and testing of information systems, information system components, and information system services.

10.2.8.2 TEST DATA INTEGRITY

Control Objective: The firm documents its processes to ensure the integrity of test through existing security controls.

Standard: Developers, in conjunction with KR's IT security personnel, are responsible for implementing appropriate mechanisms to protect the integrity of test data.

Supplemental Guidance: None

10.2.8.3 INFORMATION OUTPUT HANDLING & RETENTION

Control Objective: The firm handles and retains both information within and output from information systems in accordance with applicable statutory, regulatory and contractual requirements.²⁵⁴

Standard: KR is required to design, implement and maintain a data retention program for the systematic retention and destruction of physical and digital documents based on statutory and regulatory record-keeping requirements and practical business needs that include:

- (a) Limiting data storage amount and retention time to that which is required for legal, regulatory, and business requirements;
- (b) Processes for secure deletion of data when no longer needed;
- (c) Specific retention requirements for data; and
- (d) A quarterly process (automatic or manual) for identifying and securely deleting stored sensitive data that exceeds defined retention requirements.

²⁵² ISO/IEC 27002:2013 – 14.2.8

²⁵³ PCI DSS (v3.2) 6.4 & 6.4.3 | MA201CMR17 17.03(2)(d)(B)(i)

²⁵⁴ PCI DSS (v3.2) 3.1 & 10.7 | OR646A.622(2)(C)(i) & (iv)

Supplemental Guidance: The retention of data (e.g., paper documents, backup tapes, email messages and other media) not otherwise necessary to conduct business is both expensive and inefficient. Unnecessary retention could leave KR open to potential legal challenges on grounds based on the outdated and irrelevant material. Retention periods are based primarily on current Federal record-keeping requirements, state statutes of limitation, and industry-recognized leading practices for document retention. Security controls shall be tailored accordingly so that cost-effective controls can be applied commensurate with the risk and sensitivity of the data and information system.

11.0 Supplier Relationships Policy

KR shall assess service providers to determine if IT security controls are effective. KR must ensure service providers implement mechanisms to identify and remediate deficiencies or vulnerabilities on an ongoing basis, in order to ensure the continued effectiveness of IT security controls.

Management Intent: The purpose of this policy is to ensure that risk associated with outsourced service provider relationships are minimized or eliminated. As service providers' people, technology and practices evolve over time, KR must ensure the appropriate levels of due care and due diligence are applied to validate IT security controls are effective.

11.1 Information Security in Supplier Relationships

The objective is to ensure the protection of the firm's assets that is accessible by suppliers.²⁵⁵

11.1.1 INFORMATION SECURITY POLICY FOR SUPPLIER RELATIONSHIPS

Information security requirements for mitigating the risks associated with supplier's access to the firm's assets should be agreed with the supplier and documented.²⁵⁶

11.1.1.1 SERVICE PROVIDER MANAGEMENT

Control Objective: The firm maintains and implements policies and procedures to manage service providers with whom data is shared, or that could affect the security of data.²⁵⁷

Standard: Asset custodians are required to maintain and implement policies and procedures to manage service providers that include, but is not limited to:

- (a) Maintaining a list of service providers;
- (b) Maintaining a written agreement that includes an acknowledgment that the service providers are responsible for the security of data the service providers possess or otherwise store, process or transmit on behalf of KR, or to the extent that they could impact the security of KR;
- (c) Ensures there is an established process for engaging service providers, including proper due diligence prior to engagement;
- (d) Maintaining a program to monitor service providers' compliance status at least annually; and
- (e) Maintaining information about which requirements are managed by each service provider, and which are managed by KR.

Supplemental Guidance: If the entity shares data with service providers (e.g., backup tape storage facilities, web hosting companies, or security service providers), the process of due diligence should include:

- Direct observations;
- Reviews of policies and procedures; and
- Reviews of supporting documentation.

11.1.1.2 SYSTEM DEVELOPMENT LIFE CYCLE (SDLC)

Control Objective: The firm:²⁵⁸

- Manages information systems using a System Development Life Cycle (SDLC) methodology that includes information security considerations; and
- Defines and documents information system security roles and responsibilities throughout the SDLC.

Standard: For all significant development and/or acquisitions, asset custodians and data owners are required to:

- (a) Manage information systems using a System Development Life Cycle (SDLC) that includes information security considerations; and
- (b) Define and document information security roles and responsibilities throughout the SDLC.

²⁵⁵ ISO/IEC 27002:2013 – 15.1

²⁵⁶ ISO/IEC 27002:2013 – 15.1.1

²⁵⁷ PCI DSS (v3.2) 12.8

²⁵⁸ NIST Cybersecurity Framework PR.IP-2

Supplemental Guidance: The level of detail required in security-related documentation is based on the security category or classification level of the information system and the degree to which organizations depend on the stated security capability to meet overall risk response expectations, as defined in the firm's risk management strategy.

11.1.1.3 ACQUISITION PROCESS

Control Objective: The firm includes the following requirements and/or specifications, explicitly or by reference, in information system acquisitions based on an assessment of risk:²⁵⁹

- Security functional requirements/specifications;
- Security-related documentation requirements; and
- Developmental and evaluation-related security requirements.

Standard: Asset custodians and data owners are required to take security requirements into account when purchasing information systems or outsourcing solutions.

Supplemental Guidance: None

11.1.1.4 COMMERCIAL OFF-THE-SHELF (COTS) SECURITY SOLUTIONS

Control Objective: The firm employs only Commercial Off-the-Shelf (COTS) information security products.

Standard: KR is required to use only Commercial Off-the-Shelf (COTS) products for information security requirements.

Supplemental Guidance: COTS information security products used to protect sensitive information by cryptographic means may be required to use approved key management.

11.1.1.5 FUNCTIONAL PROPERTIES OF SECURITY CONTROLS

Control Objective: The firm requires, in acquisition documents, that vendors/contractors provide information describing the functional properties of the security controls to be employed within information systems, information system components, or information system services in sufficient detail to permit analysis and testing of the controls.

Standard: Vendors are required to provide documentation describing the functional properties of the security controls employed within information systems, information system components, or information system services in sufficient detail to permit analysis and testing of the controls.

Supplemental Guidance: Functional properties of security controls describe the functionality (e.g., security capability, functions, and mechanisms) visible at the interfaces of the controls and specifically exclude functionality and structures internal to the operation of the controls. The purpose of this control enhancement is to ensure that development processes produce a design that increases the likelihood of greater security strength. In contrast, the purpose of SA-05 is to ensure that documentation is available to facilitate organizational understanding of testing, implementation, and/or operational issues associated with deployed security controls.

11.1.2 ADDRESSING SECURITY WITHIN SUPPLIER AGREEMENTS

All relevant information security requirements should be established and agreed with each supplier that may access, process, store, communicate, or provide IT infrastructure components for, the firm's information.²⁶⁰

²⁵⁹ NIST Cybersecurity Framework PR.IP-2 & DE.CM-6

²⁶⁰ ISO/IEC 27002:2013 – 15.1.2

11.1.2.1 SERVICE PROVIDER ACCOUNTABILITY

Control Objective: The firm ensures service providers acknowledge in writing that they are responsible for the security of sensitive data the service provider possesses or otherwise stores, processes, or transmits on behalf of the firm, or to the extent that they could impact the security of the firm's data.²⁶¹

Standard: Service providers are required to acknowledge in writing to KR that they are responsible for the security of sensitive data that possess or otherwise store, process, or transmit on behalf of KR, or to the extent that the service provider could impact the security of KR.

Supplemental Guidance: None

²⁶¹ PCI DSS (v3.2) version 3.0 Requirements 12.9

12.0 Information Security Incident Management Policy

KR shall maintain an IT security incident handling capability that includes adequate preparation, detection, analysis, containment, recovery, and reporting activities.

Management Intent: The purpose of this policy is to establish and maintain a capability to guide KR's response when cyber-security incidents occur.

12.1 Management of Information Security Incidents and Improvements

The objective is to ensure a consistent and effective approach to the management of information security incidents, including communication on security events and weaknesses.²⁶²

12.1.1 RESPONSIBILITIES AND PROCEDURES

Management responsibilities and procedures should be established to ensure a quick, effective and orderly response to information security incidents.²⁶³

12.1.1.1 INCIDENT RESPONSE

Control Objective: The firm ensures an incident response capability exists and is prepared to respond immediately to potential cybersecurity incidents.²⁶⁴

Standard: KR is required to:

- (a) Implement an Incident Response (IR) capability that is prepared to respond immediately to potential cybersecurity incidents.
- (b) Create an IR plan that is capable of being implemented in the event of a system breach. Ensure the plan addresses the following, at a minimum:
 - 1. Roles, responsibilities, and communication and contact strategies in the event of a compromise including notification of the payment brands, at a minimum;
 - 2. Specific incident response procedures;
 - 3. Business recovery and continuity procedures;
 - 4. Data backup processes;
 - 5. Analysis of legal requirements for reporting compromises;
 - 6. Coverage and responses of all critical system components; and
 - 7. Reference or inclusion of incident response procedures from the payment brands.
- (c) Test the IR plan at least annually;
- (d) Designate IR personnel to be available on a 24/7 basis to respond to alerts;
- (e) Provide appropriate training to staff with security breach response responsibilities;
- (f) Include alerts from security monitoring systems, including but not limited to:
 - 1. Intrusion Detection Systems (IDS);
 - 2. Intrusion Prevention Systems (IPS);
 - 3. Firewalls; and
 - 4. File Integrity Monitoring (FIM) systems; and
- (g) Develop a process to modify and evolve the incident response plan according to lessons learned and to incorporate industry developments.

Supplemental Guidance: National Institute of Standards and Technology (NIST) guidance for incident response best practices can be referenced at:

- Computer Security Incident Handling Guide
 - (<http://csrc.nist.gov/publications/nistpubs/800-61rev2/SP800-61rev2.pdf>)
- Guide to Integrating Forensic Techniques into Incident Response

²⁶² ISO/IEC 27002:2013 – 16.1

²⁶³ ISO/IEC 27002:2013 – 16.1.1

²⁶⁴ PCI DSS (v3.2) 12.10-12.10.6

- (<http://csrc.nist.gov/publications/nistpubs/800-86/SP800-86.pdf>)

12.1.1.2 INCIDENT RESPONSE TRAINING

Control Objective: The firm:

- Trains personnel in their incident response roles and responsibilities with respect to information systems; and
- Provides refresher training.

Standard: KR management and IT staff are required to incorporate simulated events into incident response training to facilitate effective response by personnel in crisis situations.

Supplemental Guidance: Incident response training provided by organizations is linked to the assigned roles and responsibilities of organizational personnel to ensure the appropriate content and level of detail is included in such training. For example, regular users may only need to know who to call or how to recognize an incident on the information system; system administrators may require additional training on how to handle/remediate incidents; and incident responders may receive more specific training on forensics, reporting, system recovery, and restoration. Incident response training includes user training in the identification and reporting of suspicious activities, both from external and internal sources.

12.1.2 REPORTING INFORMATION SECURITY EVENTS

Information security events should be reported through appropriate management channels as quickly as possible.²⁶⁵

12.1.2.1 INCIDENT REPORTING

Control Objective: The firm:²⁶⁶

- Requires personnel to report suspected security incidents to organizational incident response personnel within organization-defined time-periods; and
- Reports security incident information to designated authorities.

Standard: Users are responsible for reporting information system weaknesses, deficiencies, and/or vulnerabilities associated with reported security incidents to KR's IT security personnel.

Supplemental Guidance: The intent of this control is to address both specific incident reporting requirements within an organization and the formal incident reporting requirements for federal agencies and their subordinate organizations. The types of security incidents reported, the content and timeliness of the reports and the designated reporting authorities reflect applicable laws, policies, regulations, standards, and guidance.

If a breach occurs, breach notification procedures should occur without unreasonable delay, except:

- When a law enforcement agency has determined that notification will impede a criminal investigation; or
- In order to discover the complete scope of the breach and restore the integrity of the system.

In terms of incident reporting, the definition of a security breach is when an individual's unencrypted Personally Identifiable Information (PII) is reasonably believed to have been acquired by an unauthorized person or process. Good faith acquisition of PII by an authorized user or authorized agent for KR purposes does not constitute a security breach, provided that the PII is not used or subject to further unauthorized disclosure.

12.1.3 REPORTING INFORMATION SECURITY WEAKNESSES

Employees and contractors using the firm's information systems and services should be required to note and report any observed or suspected information security weaknesses in systems or services.²⁶⁷

²⁶⁵ ISO/IEC 27002:2013 – 16.1.2

²⁶⁶ HIPAA 164.308(a)(6)(ii) | PCI DSS (v3.2) 12.8.3 | MA201CMR17 17.03(2)(j) | OR646A.604(1)-(5) | CA SB1386 SEC2-Section 1798.29 | NIST Cybersecurity Framework RS.CO-2

²⁶⁷ ISO/IEC 27002:2013 – 16.1.3

12.1.3.1 REPORTING WEAKNESSES

Control Objective: The firm tracks and documents information system security incidents.²⁶⁸

Standard: KR management and IT staff are responsible for reporting, managing and documenting information system weaknesses that can possibly lead to a security incident.

Supplemental Guidance: Documenting information system security incidents includes, for example, maintaining records about each incident, the status of the incident, and other pertinent information necessary for forensics, evaluating incident details, trends, and handling. Incident information can be obtained from a variety of sources including, for example, incident reports, incident response teams, audit monitoring, network monitoring, physical access monitoring, and user/administrator reports.

12.1.3.2 INCIDENT REPORTING ASSISTANCE

Control Objective: The firm provides an incident response support resource that offers advice and assistance to users of information systems for the handling and reporting of security incidents.

Standard: KR management and IT staff are required to:

- (a) Establish a direct, cooperative relationship between its incident response capability and external providers; and
- (b) Identify organizational incident response team members to work with external providers.

Supplemental Guidance: Incident response support resources provided by organizations include, for example, help desks, CIRTs, and access to forensics services, when required.

12.1.4 ASSESSMENT OF AND DECISION ON INFORMATION SECURITY EVENTS

Information security events should be assessed and it should be decided if they are to be classified as information security incidents.²⁶⁹

12.1.4.1 INTEGRATED INFORMATION SECURITY ANALYSIS TEAM

Control Objective: The firm establishes an integrated team of forensic/malicious code analysts, tool developers, and real-time operations personnel.²⁷⁰

Standard: The Computer Incident Response Team (CIRT) is KR's integrated information security analysis team.

Supplemental Guidance: Having an integrated team for incident response facilitates information sharing. Such capability allows organizational personnel, including developers, implementers, and operators, to leverage the team knowledge of the threat in order to implement defensive measures that will enable organizations to deter intrusions more effectively.

12.1.5 RESPONSE TO INFORMATION SECURITY INCIDENTS

Information security incidents should be responded to in accordance with the documented procedures.²⁷¹

12.1.5.1 INCIDENT RESPONSE PLAN (IRP)

Control Objective: The firm:²⁷²

- Develops an incident response plan that:
 - Provides the firm with a roadmap for implementing its incident response capability;
 - Describes the structure and organization of the incident response capability;
 - Provides a high-level approach for how the incident response capability fits into the overall organization;
 - Meets the unique requirements of the firm, which relate to mission, size, structure, and functions;
 - Defines reportable incidents;

²⁶⁸ PCI DSS (v3.2) 12.5.2 | NIST Cybersecurity Framework DE.AE-3, DE.AE-5, RS.AN-1 & RS.AN-4

²⁶⁹ ISO/IEC 27002:2013 – 16.1.4

²⁷⁰ PCI DSS (v3.2) 12.10.3

²⁷¹ ISO/IEC 27002:2013 – 16.1.5

²⁷² HIPAA 164.308(a)(6)(ii) | PCI DSS (v3.2) 12.8.3, 12.10, 12.10.1-12.10.6 | OR646A.622(2)(d)(B)(iii) | NIST Cybersecurity Framework PR.IP-7, PR.IP-9, DE.AE-3, DE.AE-5, RS.AN-4, RS.CO-1, RS.CO-2, RS.CO-3, RS.CO-4, RS.IM-1, RS.IM-2, RS.RP-1, RC.RP-1, RC.IM-1 & RC.IM-2

- Provides metrics for measuring the incident response capability within the firm.
- Defines the resources and management support needed to effectively maintain and mature an incident response capability; and
- Is reviewed and approved by designated officials within the firm;
- Distributes copies of the incident response plan to incident response personnel (identified by name and/or by role) and firm elements;
- Reviews the incident response plan on an firm -defined frequency;
- Revises the incident response plan to address system/organizational changes or problems encountered during plan implementation, execution, or testing; and
- Communicates incident response plan changes to incident response personnel (identified by name and/or by role) and firm elements.

Standard: KR management and IT staff are required to:

- (a) Be prepared to respond immediately to information security-related incidents;
- (b) Create the Incident Response Plan (IRP) to be implemented in the event of a system breach.
- (c) Test the IRP at least annually;
- (d) Designate specific personnel to be available on a 24/7 basis to respond to alerts;
- (e) Provide appropriate training to staff with security breach response responsibilities;
- (f) Include alerts from intrusion detection, intrusion prevention, and file integrity monitoring systems;
- (g) Develop a process to modify and evolve the incident response plan according to lessons learned and to incorporate industry developments; and
- (h) Ensure the plan addresses the following, at a minimum:
 1. Roles, responsibilities, and communication and contact strategies in the event of a compromise;
 2. Specific incident response procedures;
 3. Business recovery and continuity procedures;
 4. Data backup processes;
 5. Analysis of legal requirements for reporting compromises;
 6. Coverage and responses of all critical system components; and
 7. Reference or inclusion of incident response procedures from legal or contractual sources, if applicable.

Supplemental Guidance: It is important that organizations develop and implement a coordinated approach to incident response. Organizational missions, business functions, strategies, goals, and objectives for incident response help determine the structure of incident response capabilities. As part of a comprehensive incident response capability, organizations consider the coordination and sharing of information with external organizations, including, for example, external service providers and organizations involved in the supply chain for organizational information systems.

National Institute of Science & Technology (NIST) guidance is the authoritative source for selection and implementation of this control based on the security categorization and risk environment of the data and/or information system.

12.1.6 LEARNING FROM INFORMATION SECURITY INCIDENTS

Knowledge gained from analyzing and resolving information security incidents should be used to reduce the likelihood or impact of future incidents.²⁷³

12.1.6.1 INCIDENT RESPONSE LESSONS LEARNED

Control Objective: The firm develops, disseminates, reviews & updates lessons learned from incident response operations.²⁷⁴

Standard: KR is required to document incident response operations that, at a minimum, include:

- (a) A root cause analysis of the incident; and
- (b) If necessary, what controls must be put in place to prevent a future incident from occurring.

Supplemental Guidance: None

²⁷³ ISO/IEC 27002:2013 – 16.1.6

²⁷⁴ HIPAA 164.308(a)(6)(i)

12.1.7 COLLECTION OF EVIDENCE

The firm should define and apply procedures for the identification, collection, acquisition and preservation of information, which can serve as evidence.²⁷⁵

12.1.7.1 INCIDENT HANDLING

Control Objective: The firm: ²⁷⁶

- Implements an incident handling capability for security incidents that includes preparation, detection and analysis, containment, eradication, and recovery;
- Coordinates incident handling activities with contingency planning activities; and
- Incorporates lessons learned from ongoing incident handling activities into incident response procedures, training, and testing/exercises, and implements the resulting changes accordingly.

Standard: KR management and IT staff are required:

- (a) Identify the severity and classification of incidents; and
- (b) Define appropriate actions to take in response to ensure the continuation of business functions.

Supplemental Guidance: Organizations recognize that incident response capability is dependent on the capabilities of organizational information systems and the mission/business processes being supported by those systems. Therefore, organizations consider incident response as part of the definition, design, and development of mission/business processes and information systems. Incident-related information can be obtained from a variety of sources including, for example, audit monitoring, network monitoring, physical access monitoring, user/administrator reports, and reported supply chain events. Effective incident handling capability includes coordination among many organizational entities including, for example, mission/business owners, information system owners, authorizing officials, human resources offices, physical and personnel security offices, legal departments, operations personnel, procurement offices, and the risk executive (function).

12.1.7.2 INFORMATION SPILLAGE RESPONSE

Control Objective: The firm responds to information spills by:

- Identifying the specific information causing information system contamination;
- Alerting organization-defined personnel of the information spill using a secure method of communication;
- Isolating the contaminated information system;
- Eradicating the information from the contaminated information system; and
- Identifying other information systems that may have been subsequently contaminated.

Standard: KR is required to respond to information spillage in accordance with its Incident Response Plan (IRP).

Supplemental Guidance: Information spillage refers to instances where sensitive information (e.g., classified information, export controlled information) is inadvertently placed on information systems that are not authorized to process such information. Such information spills often occur when information that is initially thought to be of lower sensitivity is transmitted to an information system and then is subsequently determined to be of higher sensitivity. At that point, corrective action is required. The nature of the firm's response is generally based upon the degree of sensitivity of the spilled information (e.g., security category or classification level), the security capabilities of the information system, the specific nature of contaminated storage media, and the access authorizations (e.g., security clearances) of individuals with authorized access to the contaminated system.

²⁷⁵ ISO/IEC 27002:2013 – 16.1.7

²⁷⁶ PCI DSS (v3.2) 12.5.3 | NIST Cybersecurity Framework DE.AE-2, DE.AE-3, DE.AE-4, DE.AE-5, RS.AN-1, RS.AN-2, RS.AN-3, RS.AN-4, RS.CO-3, RS.CO-4, RS.IM-1, RS.IM-2, RS.MI-1, RS.MI-2, RS.RP-1, RC.RP-1, RC.IM-1, RC.IM-2 & RC.CO-3

13.0 Business Continuity Management Policy

KR shall establish, implement and maintain plans for the continuity of operations to ensure the availability of KR's information resources during adverse conditions.

Management Intent: The purpose of this policy is to establish processes that will help KR management to quickly determine the appropriate actions to be taken due to an interruption of service or disaster.

13.1 Information Security Continuity

The objective is to embed information security continuity in the firm's business continuity management systems.²⁷⁷

13.1.1 PLANNING INFORMATION SECURITY CONTINUITY

The firm should determine its requirements for information security and the continuity of information security management in adverse situations, e.g. during a crisis or disaster.²⁷⁸

13.1.1.1 CONTINGENCY PLAN

Control Objective: The firm:²⁷⁹

- Develops a contingency plan for information systems that:
 - Identifies essential missions and business functions and associated contingency requirements;
 - Provides recovery objectives, restoration priorities, and metrics;
 - Addresses contingency roles, responsibilities, assigned individuals with contact information;
 - Addresses maintaining essential missions and business functions despite an information system disruption, compromise, or failure;
 - Addresses eventual, full information system restoration without deterioration of the security measures originally planned and implemented; and
 - Is reviewed and approved by designated officials within the firm;
- Distributes copies of the contingency plan to key contingency personnel;
- Coordinates contingency planning activities with incident handling activities;
- Reviews the contingency plan as required by the firm -defined frequency;
- Revises the contingency plan to address changes to the firm, information system, or environment of operation and problems encountered during contingency plan implementation, execution, or testing; and
- Communicates contingency plan changes to key contingency personnel.

Standard: KR is required to establish, and implement as needed, procedures to enable the continuation of critical business processes while operating in other-than-normal conditions, that includes:

- (a) Developing a contingency plan that:
 - i. Identifies essential missions and business functions and associated contingency requirements;
 - ii. Provides recovery objectives, restoration priorities, and metrics;
 - iii. Addresses contingency roles, responsibilities, assigned individuals with contact information;
 - iv. Addresses maintaining essential missions and business functions despite an information system disruption, compromise, or failure;
 - v. Addresses eventual, full information system restoration without deterioration of the security measures originally planned and implemented; and
 - vi. Is reviewed and approved by company management;
- (b) Distributing copies of the contingency plan to key contingency personnel;
- (c) Coordinating contingency planning activities with incident handling activities;
- (d) Reviewing the contingency plan at least annually;
- (e) Revising the contingency plan to address necessary changes;
- (f) Communicating contingency plan changes to key contingency personnel; and

²⁷⁷ ISO/IEC 27002:2013 – 17.1

²⁷⁸ ISO/IEC 27002:2013 – 17.1.1

²⁷⁹ HIPAA 164.308(a)(7)(ii)(C) & 164.312(a)(2)(ii)

- (g) Establishing procedures for obtaining access to sensitive data during other-than-normal or emergency conditions.

Supplemental Guidance: None

13.1.1.2 CONTINGENCY TRAINING

Control Objective: The firm trains personnel in their contingency roles and responsibilities.²⁸⁰

Standard: Asset custodians and data owners are required to be trained in their contingency roles and responsibilities with respect to information systems.

Supplemental Guidance: Contingency training provided by organizations is linked to the assigned roles and responsibilities of organizational personnel to ensure the appropriate content and level of detail is included in such training. For example, regular users may only need to know when and where to report for duty during contingency operations and if normal duties are affected; system administrators may require additional training on how to set up information systems at alternate processing and storage sites; and managers/senior leaders may receive more specific training on how to conduct mission essential functions in designated off-site locations and how to establish communications with other entities for purposes of coordination of contingency-related activities.

13.1.2 IMPLEMENTING INFORMATION SECURITY CONTINUITY

The firm should establish, document, implement and maintain processes, procedures, and controls to ensure the required level of continuity for information security during an adverse situation.²⁸¹

13.1.2.1 CONTINGENCY PLANNING PROCEDURES

Control Objective: The firm develops, disseminates, reviews & updates:²⁸²

- A formal, documented contingency plan that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
- Formal, documented procedures to facilitate the implementation of the contingency planning policy and associated contingency planning controls.

Standard: KR is required to document organization-wide contingency planning controls that, at a minimum, include:

- (a) A formal, documented IT-specific contingency plan; and
- (b) Processes to facilitate the implementation of the contingency plan, procedures and associated controls.

Supplemental Guidance: None.

13.1.3 VERIFY, REVIEW AND EVALUATE INFORMATION SECURITY CONTINUITY

The firm should verify the established and implemented information security continuity controls at regular intervals in order to ensure that they are valid and effective during adverse situations.²⁸³

13.1.3.1 CONTINGENCY TESTING & EXERCISES

Control Objective: The firm tests the contingency plan for the information using organization-defined tests and/or exercises to determine the plan's effectiveness and the firm's readiness to execute the plan.²⁸⁴

Standard: Asset custodians and data owners are required to:

- (a) Establish and implement periodic testing procedures;
- (b) Test their contingency plan to determine the plan's effectiveness and the firm's readiness to execute the plan; and
- (c) Document the contingency plan test results.

²⁸⁰ NIST Cybersecurity Framework RS.CO-1

²⁸¹ ISO/IEC 27002:2013 – 17.1.2

²⁸² HIPAA 164.308(a)(7)(i) | NIST Cybersecurity Framework ID.AM-5, ID.AM-6, ID.BE-1, ID.BE-5, PR.DS-4, PR.IP-7, PR.IP-9, DE.AE-4, RS.AN-2, RS.AN-4, RS.CO-1, RS.CO-3, RS.CO-4, RS.IM-1, RS.IM-2, RS.RP-1, RC.IM-1, RC.IM-2 & RC.CO-3

²⁸³ ISO/IEC 27002:2013 – 17.1.3

²⁸⁴ HIPAA 164.308(a)(7)(ii)(D)

Supplemental Guidance: Asset custodians and data owners are required to perform a full recovery and reconstitution of critical information systems to a known state as part of contingency plan testing, at least once a year.

13.1.3.2 CONTINGENCY PLAN UPDATE

Control Objective: The firm reviews the contingency plan and any test/exercise results to initiates corrective actions.²⁸⁵

Standard: Asset custodians and data owners are required to:

- (a) Review the entire contingency plan at least once a year;
- (b) Review any test/exercise results; and
- (c) Initiate corrective actions, as necessary.

Supplemental Guidance: None

13.2 Redundancies

The objective is to ensure availability of information processing facilities.²⁸⁶

13.2.1 AVAILABILITY OF INFORMATION PROCESSING FACILITIES

Information processing facilities should be implemented with redundancy sufficient to meet availability requirements.²⁸⁷

13.2.1.1 ALTERNATE STORAGE SITE

Control Objective: The firm establishes an alternate storage site including necessary agreements to permit the storage and recovery of information system backup information.²⁸⁸

Standard: The responsible party for KR's technology infrastructure is required to identify an alternate storage site that is separated from the primary storage site so as not to be susceptible to the same hazards, in the event of an area-wide disruption or disaster.

Supplemental Guidance: KR should determine who needs access to facilities and offices in the event of a disaster. Access should be restricted to business essential personnel until operations and facilities are returned to normal operating conditions.

- The firm ensures that the established alternate storage site is separated from the primary storage site to reduce susceptibility to the same hazards.
- The firm configures the alternate storage site to facilitate recovery operations in accordance with recovery time and recovery point objectives.
- The firm identifies potential accessibility problems to the alternate storage site in the event of an area-wide disruption or disaster and outlines explicit mitigation actions.

13.2.1.2 ALTERNATE PROCESSING SITE

Control Objective: The firm:

- Identifies an alternate processing site that is separated from the primary processing site so as not to be susceptible to the same hazards; and
- Ensures that the alternate processing site provides information security measures equivalent to that of the primary site.

Standard: The responsible party for KR's technology infrastructure is required to identify an alternate processing site that is separated from the primary processing site so as not to be susceptible to the same hazards, in the event of an area-wide disruption or disaster.

Supplemental Guidance: Items covered by alternate processing site agreements include, for example, environmental conditions at alternate sites, access rules, physical and environmental protection requirements, and coordination for the transfer/assignment of personnel. Alternate processing sites reflect the continuity requirements in contingency plans to maintain essential missions/business functions despite the disruption, compromise, or failure in organizational information systems. Access should be restricted to business essential personnel until operations and facilities are returned to normal operating conditions.

²⁸⁵ HIPAA 164.308(a)(7)(ii)(E) | NIST Cybersecurity Framework PR.IP-4 & PR.IP-10

²⁸⁶ ISO/IEC 27002:2013 – 17.2

²⁸⁷ ISO/IEC 27002:2013 – 17.2.1

²⁸⁸ HIPAA 164.310(a)(2)(i) | NIST Cybersecurity Framework PR.IP-4

13.2.1.3 TELECOMMUNICATIONS SERVICES

Control Objective: The firm establishes alternate telecommunications services including necessary agreements to permit the resumption of information for essential missions and business functions within the firm's defined time period when the primary telecommunications capabilities system operations are unavailable.²⁸⁹

Standard: The responsible party for KR's technology infrastructure is required to establish alternate telecommunications services, including necessary Service Level Agreement (SLA) to permit the resumption essential communication functions within an acceptable time period when the primary telecommunications capability is unavailable.

Supplemental Guidance: The responsible party for KR's technology infrastructure is required to obtain alternate telecommunications service providers that are separated from primary service providers so as not to be susceptible to the same hazards. Alternate telecommunications services reflect the continuity requirements in contingency plans to maintain essential missions/business functions despite the loss of primary telecommunications services.

13.2.1.4 PRIORITY OF SERVICE PROVISIONS STORAGE SITE

Control Objective: The firm develops primary and alternate telecommunications service agreements that contain priority-of-service provisions in accordance with the firm's availability requirements.

Standard: The responsible party for KR's technology infrastructure is required to develop primary and alternate telecommunications service agreements that contain priority-of-service provisions in accordance with the business operations availability requirements.

Supplemental Guidance: None

²⁸⁹ NIST Cybersecurity Framework ID.BE-4 & PR.PT-4

14.0 Compliance Policy

In accordance with all applicable legal requirements, KR shall ensure appropriate safeguards are in place to protect sensitive business data against loss, unauthorized access, or disclosure.

Management Intent: The purpose of this policy is to ensure safeguards are in place to be aware of and comply with applicable statutory, regulatory and contractual compliance obligations.

14.1 Compliance with Legal and Contractual Requirements

The objective is to avoid breaches of legal, statutory, regulatory or contractual obligations related to information security and of any security requirements.²⁹⁰

14.1.1 IDENTIFICATION OF APPLICABLE LEGISLATION AND CONTRACTUAL REQUIREMENTS

All relevant legislative statutory, regulatory, contractual requirements and the firm's approach to meet these requirements should be explicitly identified, documented and kept up to date for each information system and the firm.²⁹¹

14.1.1.1 REGULATORY & NON-REGULATORY COMPLIANCE

Control Objective: The firm addresses information security issues in the development, documentation, implementation, and updating of a plan to protect its critical information systems and sensitive data in accordance with applicable local, state, and federal laws, as well as non-regulatory requirements that the firm is contractually bound to address.²⁹²

Standard: Asset custodians and data owners are required to protect KR's critical information systems and sensitive data in accordance with applicable local, state, and Federal laws, as well as other legal requirements that KR is contractually bound to address.

Supplemental Guidance: The requirements for defining critical infrastructure and key resources are found in applicable laws, regulations and contract requirements.

14.1.2 INTELLECTUAL PROPERTY RIGHTS

Appropriate procedures should be implemented to ensure compliance with legislative, regulatory and contractual requirements related to intellectual property rights and use of proprietary software products.²⁹³

14.1.2.1 SOFTWARE USAGE RESTRICTIONS

Control Objective: The org firm anization:²⁹⁴

- Uses software and associated documentation in accordance with contract agreements and copyright laws;
- Employs tracking systems for software and associated documentation protected by quantity licenses to control copying and distribution; and
- Controls and documents the use of peer-to-peer file sharing technology to ensure that this capability is not used for the unauthorized distribution, display, performance, or reproduction of copyrighted work.

Standard: Users are required to implement and utilize software in accordance with license agreements and copyright laws.

Supplemental Guidance: Tracking systems can include, for example, simple spreadsheets or fully automated, specialized applications depending on organizational needs. KR should:

- Employ tracking systems for software and associated documentation protected by quantity licenses to control copying and distribution; and

²⁹⁰ ISO/IEC 27002:2013 – 18.1

²⁹¹ ISO/IEC 27002:2013 – 18.1.1

²⁹² HIPAA 164.308(a)(8) | GLBA Sec 6801(b)(3) | PCI DSS (v3.2) 12.1 | NIST Cybersecurity Framework ID.BE-2, ID.BE-4, ID.GV-3 & ID.RM-3

²⁹³ ISO/IEC 27002:2013 – 18.1.2

²⁹⁴ NIST Cybersecurity Framework DE.CM-3

- Control and document the use of peer-to-peer file sharing technology to ensure that this capability is not used for the unauthorized distribution, display, performance, or reproduction of copyrighted work.

14.1.3 PROTECTION OF RECORDS

Records should be protected from loss, destruction, falsification, unauthorized access and unauthorized release, in accordance with legislative, regulatory, contractual and business requirements.²⁹⁵

14.1.3.1 MINIMIZING SENSITIVE DATA STORAGE

Control Objective: The firm implements a process for to minimize the storage of sensitive data.²⁹⁶

Standard: KR's data owners are required to determine the business requirements for data retention and securely dispose of sensitive data once the data is no longer necessary. This includes, but is not limited to:

- Implement data retention and disposal procedures that cover sensitive data handling;
- Limiting data retention time to that which is required for legal, regulatory, and business requirements;
- Conducting a quarterly process (automatic or manual) to identify and securely delete stored sensitive data that exceeds defined retention requirements;
- Performing secure deletion of electronic-based sensitive data; and
- Shredding physical-based sensitive data.

Supplemental Guidance: Specific requirements for the retention of sensitive data are driven by business needs (e.g., data needs to be held for X period for Y business reasons) and documentation should exist to justify the business need.

14.1.3.2 DATA MASKING

Control Objective: The firm applies data masking to sensitive information that is displayed or printed.²⁹⁷

Standard: Sensitive information that is displayed or printed is required to be masked. This includes, but is not limited to:

- Financial account numbers;
- Social Security Numbers (SSN); and
- Credit or debit Primary Account Numbers (PANs) (no more than the first six and last four digits allowed).

Supplemental Guidance: Only personnel with a legitimate business need should be able to see more than the first six/last four of the PAN.

14.1.3.3 STORING AUTHENTICATION DATA

Control Objective: The firm does not store sensitive authentication data after authorization.²⁹⁸

Standard: Asset custodians are required to ensure sensitive authentication data is not stored after authorization, even if it is encrypted. KR is prohibited from storing:

- The full contents of any track:
 - Tracks are from the magnetic stripe located on the back of a card, equivalent data contained on a chip, or elsewhere.
 - This data is alternatively called the full track, track, track 1, track 2, and magnetic-stripe data.
- Storing the card verification code or value (three-digit or four-digit number printed on the front or back of a payment card) used to verify card-not-present transactions; and
- Storing the Personal Identification Number (PIN) or the encrypted PIN block.

Supplemental Guidance: The following data sources should be examined to verify that the full contents of any track from the magnetic stripe on the back of the card or equivalent data on a chip are not stored under any circumstance:

- Incoming transaction data;

²⁹⁵ ISO/IEC 27002:2013 – 18.1.3

²⁹⁶ PCI DSS (v3.2) 3.1

²⁹⁷ PCI DSS (v3.2) 3.3

²⁹⁸ PCI DSS (v3.2) 3.2-3.2.3

- All logs (e.g., transaction, history, debugging, error);
- History files;
- Trace files;
- Several database schemas; and
- Database contents.

14.1.3.4 MAKING SENSITIVE DATA UNREADABLE IN STORAGE

Control Objective: The firm implements a process to ensure sensitive data is rendered unreadable anywhere sensitive data is stored.
299

Standard: Asset custodians are required to implement technical measures to ensure sensitive data is not accessible by unauthorized users or processes by using any of the following approaches:

- (a) Render sensitive data unreadable anywhere sensitive data is stored, including on portable digital media, backup media, and in logs through the means of:
 1. One-way hashes based on strong cryptography (hash must be of the entire sensitive data element);
 2. Truncation (hashing cannot be used to replace the truncated segment of the sensitive data element);
 3. Index tokens and pads (pads must be securely stored); or
 4. Strong cryptography with associated key-management processes and procedures; and
- (b) Preventing decryption keys from being tied to user accounts, if disk encryption is used, rather than file- or column-level database encryption:
 1. Logical access must be managed independently of native operating system access control mechanisms (e.g., by not using local user account databases).
 2. Decryption keys must not be tied to operating system-level user accounts.

Supplemental Guidance: Since it is a relatively trivial effort for a malicious individual to reconstruct original sensitive data if they have access to both the truncated and hashed version of sensitive data, where hashed and truncated versions of the same PAN are present KR's environment, additional controls should be in place to ensure that the hashed and truncated versions cannot be correlated to reconstruct the original sensitive data element.

14.1.4 PRIVACY AND PROTECTION OF PERSONALLY IDENTIFIABLE INFORMATION

Privacy and protection of personally identifiable information should be ensured as required in relevant legislation and regulation where applicable.³⁰⁰

14.1.4.1 MINIMIZATION OF PERSONALLY IDENTIFIABLE INFORMATION (PII)

Control Objective: The firm:³⁰¹

- Identifies the minimum PII elements (e.g., name, address, date of birth) that are relevant and necessary to accomplish the purpose of collection; and
- Limits the collection and retention of PII to the minimum elements identified for the purposes described in the notice and for which the individual has provided consent.

Standard: Where feasible and within the limits of technology, data owners are responsible for locating and removing/redacting unnecessary PII through the use of anonymization and de-identification techniques.

Supplemental Guidance: The collection of PII is consistent with a purpose authorized by law or regulation. The minimum set of PII elements required to support a specific organization business process may be a subset of the PII the firm is authorized to collect.

14.1.4.2 DATA RETENTION & DISPOSAL

Control Objective: The firm:³⁰²

²⁹⁹ PCI DSS (v3.2) 3.4-3.4.1

³⁰⁰ ISO/IEC 27002:2013 – 18.1.4

³⁰¹ UK Data Protection Act of 1998 (Chapter29-Schedule1-Part1-Principle 3)

³⁰² UK Data Protection Act of 1998 (Chapter29-Schedule1-Part1-Principle 5)

- Retains PII for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; and
- Disposes of, destroys, erases, and/or anonymizes the PII, regardless of the method of storage following a re-defined time period utilizing organization-defined techniques or methods to ensure secure deletion or destruction of PII (including originals, copies, and archived records).

Standard: Data owners are required to:

- (a) Define retention periods for PII; and
- (b) Dispose of, destroy, erase, and/or anonymizes the PII once the PII is no longer necessary for business purposes.

Supplemental Guidance: None

14.1.4.3 DATA COLLECTION

Control Objective: The firm limits how it collects, uses and discloses personal information.

Standard: Data owners are required to implement limitations on the collection, use, and disclosure of personal information.

Supplemental Guidance: Data collection guidelines include, but are not limited to:

- Notice and Consent: KR will collect and process information fairly and lawfully and where appropriate, with the knowledge or consent of the data subject. The type of notice or consent required will depend on the context and the circumstances, the sensitivity of the personal information, the data subject's reasonable expectations, and legal requirements.
- Specific Purpose: KR will collect and process personal information only for specified, limited and legitimate purposes.
- Limitations on Use: KR will not process personal information in a manner inconsistent with the purposes for which it was originally collected without first obtaining the data subject's consent. The type of consent required will depend on the context and the circumstances, the sensitivity of the personal information, the data subject's reasonable expectations, and legal requirements.
- Data Proportionality: The personal information KR collects will be relevant, adequate and not excessive for the purposes for which it is collected or to which the data subject subsequently consents.
- Direct Marketing: KR will not use personal information for direct marketing purposes without the data subject's consent. The data subject's consent may be express or implied, "opt-out" or "opt-in," depending on the circumstances and legal requirements.
- Data Retention: KR will keep data storage to a minimum and will securely dispose of all PII when it is no longer a business need for KR to retain the data.
- Automated Decisions: KR will not make decisions based solely on automated processing of personal information except as permitted by applicable law.
- Transfers to Third Parties: KR will disclose personal information to third parties (including our affiliates) only for purposes consistent with those for which the personal information was originally collected or to which the data subject has subsequently consented. KR will take appropriate measures, by contract or otherwise, to provide adequate protection for personal information that is disclosed to a third party.
 - Before KR transfers personal information to a third party to use for its own marketing purposes, KR will obtain the data subject's consent. The data subject's consent may be express or implied, "opt-out" or "opt-in," depending on the circumstances and legal requirements.
 - There may be exceptions to these general rules, depending on applicable law, if, for example, the disclosure is required by court order, to comply with law, to prevent crime, to enforce a legal right.
- Transfers to Other Countries: KR will take appropriate measures, by contract or otherwise, to provide adequate protection for personal information that is transferred from one country to another, including transfers among affiliates. If required by law, KR will first obtain the data subject's consent to the transfer. In such cases, the type of consent required will depend on the context and the circumstances, the sensitivity of the personal information, the data subject's reasonable expectations, and legal requirements.

Management of Personal Information:

- Quality: KR will take appropriate steps to ensure that personal information is accurate and reliable for its intended use and, where necessary for its intended use, kept up to date.
- Access: KR will maintain procedures to give data subjects appropriate access to their personal information and, when appropriate, an effective means to have their personal information corrected or deleted.

- **Security:** KR will implement reasonable administrative, physical and technological security measures to protect personal information from unauthorized access, unauthorized use, and unauthorized or accidental destruction, modification or disclosure. We will provide a level of security appropriate to the risks and the sensitivity of the personal information.
- **Retention:** KR will not keep personal information in a form that permits identification of data subjects for longer than is necessary for the purposes for which it was collected or to which the data subject has consented, except for legitimate purposes permitted by law, such as regulatory compliance.

Accountability and Enforcement:

- **Accountability:** KR will designate data subjects within KR to be accountable for compliance with privacy and data protection laws and our policies and procedures.
- **Enforcement:** KR will provide internal controls for verifying compliance with privacy and data protection laws and our policies and procedures.
- **Complaint Process:** KR will provide a fair process for investigating and resolving complaints and objections regarding our data practices and will take appropriate steps to communicate our process to the data subjects who entrust their personal information to us.

14.1.4.4 SENSITIVE DATA STORAGE

Control Objective: The firm limits storing sensitive data to explicit business requirements.³⁰³

Standard: Personally, Identifiable Information (PII) is prohibited from being stored for any longer than the legitimate business need exists to retain the data.

Supplemental Guidance: For credit or debit data, KR is required to not store:

- Sensitive authentication data after authorization, even if it is encrypted;
- The full contents of any track (from the magnetic stripe located on the back of a card, equivalent data contained on a chip, or elsewhere). This data is alternatively called full track, track, track 1, track 2, and magnetic-stripe data;
- The card verification code or value (three-digit or four-digit number printed on the front or back of a payment card) used to verify card-not-present transactions; or
- The personal identification number (PIN) or the encrypted PIN block.

In the normal course of business, the following data elements from the magnetic stripe may need to be retained (To minimize risk, store only these data elements as needed for business):

- The cardholder's name;
- Primary account number (PAN);
- Expiration date; or
- Service code

14.1.5 REGULATION OF CRYPTOGRAPHIC CONTROLS

Cryptographic controls should be used in compliance with all relevant agreements, legislation, and regulations.³⁰⁴

14.1.5.1 EXPORT-CONTROLLED INFORMATION

Control Objective: The firm prohibits exporting cryptographic software or hardware that would violate any regulatory requirement for export-controlled technologies.

Standard: KR users are prohibited from intentionally distributing any export-controlled cryptographic software or hardware.

Supplemental Guidance: None

³⁰³ PCI DSS (v3.2) 3.2 & 3.2.1-3.2.3

³⁰⁴ ISO/IEC 27002:2013 – 18.1.5

14.2 Information Security Reviews

The objective is to ensure that information security is implemented and operated in accordance with the firm's policies and procedures.³⁰⁵

14.2.1 INDEPENDENT REVIEW OF INFORMATION SECURITY

The firm's approach to managing information security and its implementation (e.g., control objectives, controls, policies, processes and procedures for information security) should be reviewed independently at planned intervals or when significant changes occur.³⁰⁶

14.2.1.1 INDEPENDENT ASSESSORS

Control Objective: The firm employs assessors or assessment teams with independence to conduct security control assessments.

Standard: Whenever feasible, KR will utilize independent assessors for security assessment functions.

Supplemental Guidance: Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of organizational information systems. Impartiality implies that assessors are free from any perceived or actual conflicts of interest with regard to the development, operation, or management of the organizational information systems under assessment or to the determination of security control effectiveness.

14.2.2 COMPLIANCE WITH SECURITY POLICIES AND STANDARDS

Managers should regularly review the compliance of information processing and procedures within their area of responsibility with the appropriate security policies, standards, and any other security requirements.³⁰⁷

14.2.2.1 SECURITY ASSESSMENTS

Control Objective: The firm:³⁰⁸

- Assesses the security controls in information systems to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the system;
- Produces a security assessment report that documents the results of the assessment; and
- Provides the results of the security control assessment, in writing, to the senior information security official or officially designated representative.

Standard: A formal information security risk analysis must be performed on all significant development and/or acquisitions, prior to information systems being placed into production:

- (a) New information systems and applications must be appropriately tested for functionality prior to being placed in production; and
- (b) Asset custodians and data owners are required to perform a gap analysis, at least once per year, to determine any deviations from their systems' current state of compliance and that which is required.

Supplemental Guidance: Control evaluators should have sufficient independence to provide confidence that the assessment results produced are sound and can be used to make a credible, risk-based decision.

14.2.3 TECHNICAL COMPLIANCE REVIEW

Information systems should be regularly reviewed for compliance with the firm's information security policies and standards.³⁰⁹

14.2.3.1 FUNCTIONAL PROPERTIES OF SECURITY CONTROLS

Control Objective: The firm requires, in acquisition documents, that vendors/contractors provide information describing the functional properties of the security controls to be employed within information systems, information system components, or information system services in sufficient detail to permit analysis and testing of the controls.

³⁰⁵ ISO/IEC 27002:2013 – 18.2

³⁰⁶ ISO/IEC 27002:2013 – 18.2.1

³⁰⁷ ISO/IEC 27002:2013 – 18.2.2

³⁰⁸ MA201CMR17 17.03(2)(h) | OR646A.622(2)(B)(i)-(iv) | NIST Cybersecurity Framework ID.RA-1, PR.IP-7, DE.DP-1, DE.DP-2, DE.DP-3, DE.DP-4, DE.DP-5 & RS.CO-3

³⁰⁹ ISO/IEC 27002:2013 – 18.2.3

Standard: Vendors are required to provide documentation describing the functional properties of the security controls employed within information systems, information system components, or information system services in sufficient detail to permit analysis and testing of the controls.

Supplemental Guidance: Functional properties of security controls describe the functionality (e.g., security capability, functions, and mechanisms) visible at the interfaces of the controls and specifically exclude functionality and structures internal to the operation of the controls. The purpose of this control enhancement is to ensure that development processes produce a design that increases the likelihood of greater security strength. In contrast, the purpose of SA-05 is to ensure that documentation is available to facilitate organizational understanding of testing, implementation, and/or operational issues associated with deployed security controls.

14.3 Anti- Fraud Policy

It is our policy that there is zero tolerance for actions constituting fraud.

Definition

Actions defined as “fraud” include, but are not limited to:

- Misappropriation, personal use of, personal benefit from, or outright theft of KR’s cash, securities, merchandise, equipment, supplies, or other KR assets.
- Unauthorized use of Company employees, property, credit cards, cell phones or other resources.
- Submission of personal or fictitious employee expenses for reimbursement or fictitious or inflated vendor invoices or payroll records for payment.
- Receiving kickbacks or other unauthorized personal benefits from vendors or others.
- Forgery or fraudulent alteration of any check, bank draft, statement, billing, record, form, report, return or other financial document.
- Intentional material misclassification or misrepresentation of revenues, expenses, costs or other data in financial statements, reports, regulatory returns, applications or other communications.
- Intentional failure to disclose material related party transactions, noncompliance with lender requirements or donor/grantor restrictions or other required disclosure matters.
- Intentional, improper use or disclosure of client/customer, employee or Company’s proprietary information.
- Any violation of copyright, intellectual property, or licensing laws.
- Any other activities constituting illegal and/or unethical behavior by Federal or State laws.

No employee, consultant or volunteer will be adversely affected because they refuse to carry out a directive which constitutes fraud or is considered a violation of state or Federal law.

Who is included in the Anti-Fraud Policy

The anti-fraud policy applies to fraud or suspected fraud carried out by Board members, employees, volunteers, vendors, contractors, consultants and others doing business with KR and/or its subsidiaries.

14.4 ANTI-BRIBERY & CORRUPTION POLICY

Policy Statement

Bribery and corruption are criminal offences and are punishable for individuals by up to ten years' imprisonment and an unlimited fine, and if the Company is found to have taken part in corruption, we could face an unlimited fine, be excluded from public contracts and face damage to our brand and reputation. We therefore take our legal responsibilities very seriously and expect you to do the same.

It is our policy to conduct all of our business in an honest and ethical manner. We take a zero-tolerance approach to bribery and corruption and are committed to acting professionally, fairly and with integrity in all our business dealings and relationships wherever we operate. It is our best practice objective that those we do business with take a similar zero-tolerance approach to bribery and corruption.

The Company does not take part in acts of corruption or pay bribes or receive kickbacks either directly or indirectly. A typical example of indirect bribery would be a case where a company employs a commercial agent to help it secure a government license to operate in a particular jurisdiction. The agent is paid a fee and awarded an additional bonus if the license is secured, and part of that bonus is passed on to a government official.

The Company prohibits its employees from engaging in acts of corruption, and from paying bribes or kickbacks to, or accepting bribes or kickbacks from, public officials and private individuals such as the personnel of companies with which the Company does business. The Company does not tolerate such practices in any form or wherever paid. It is the responsibility of all employees who are involved at any time in engaging the services of external consultants, suppliers or advisers to ensure that such individuals are made aware of the content of the Company's Anti-Bribery & Anti-Corruption Policy at the outset of the relationship and on a regular basis thereafter.

Bribery: May be defined as offering, giving, receiving or soliciting anything of value to influence an official act or business decision. Under the FCPA and the UKBA, a bribe is an inducement, payment, reward or advantage offered, promised or provided to any person in order to gain any commercial, contractual, regulatory or personal advantage. It is illegal to directly or indirectly offer a bribe or receive a bribe. It is also a separate offence to bribe a government/ public official. "Government/ public official" includes officials, whether elected or appointed, who hold a legislative, administrative or judicial

APPENDICES

Appendix A: Data Classification & Handling Guidelines

A-1: Data Classification

Information assets are assigned a sensitivity level based on the appropriate audience for the information. If the information has been previously classified by regulatory, legal, contractual, or company directive, then that classification will take precedence. The sensitivity level then guides the selection of protective measures to secure the information. All data are to be assigned one of the following four sensitivity levels:

CLASSIFICATION	DATA CLASSIFICATION DESCRIPTION	
RESTRICTED	Definition	Restricted information is highly valuable, highly sensitive business information and the level of protection is dictated externally by legal and/or contractual requirements. Restricted information must be limited to only authorized employees, contractors, and business partners with a specific business need.
	Potential Impact of Loss	• SIGNIFICANT DAMAGE would occur if Restricted information were to become available to unauthorized parties either internal or external to KR. • Impact could include negatively affecting KR's competitive position, violating regulatory requirements, damaging the firm's reputation, violating contractual requirements, and posing an identity theft risk.
CONFIDENTIAL	Definition	Confidential information is highly valuable, sensitive business information and the level of protection is dictated internally by KR
	Potential Impact of Loss	• MODERATE DAMAGE would occur if Confidential information were to become available to unauthorized parties either internal or external to KR. • Impact could include negatively affecting KR's competitive position, damaging the firm's reputation, violating contractual requirements, and exposing the geographic location of individuals.
INTERNAL USE	Definition	Internal Use information is information originated or owned by KR or entrusted to it by others. Internal Use information may be shared with authorized employees, contractors, and business partners who have a business need, but may not be released to the general public, due to the negative impact it might have on the firm's business interests.
	Potential Impact of Loss	• MINIMAL or NO DAMAGE would occur if Internal Use information were to become available to unauthorized parties either internal or external to KR. • Impact could include damaging the firm's reputation and violating contractual requirements.
PUBLIC	Definition	Public information is information that has been approved for release to the general public and is freely shareable both internally and externally.
	Potential Impact of Loss	• NO DAMAGE would occur if Public information were to become available to parties either internal or external to KR. • Impact would not be damaging or a risk to business operations.

A-2: General Assumptions

- Any information created or received by KR employees in the performance of their jobs at is Internal Use, by default, unless the information requires greater confidentiality or is approved for release to the general public.
- Treat information that is not assigned a classification level as “Internal Use” at a minimum and use corresponding controls.
- When combining information with different sensitivity levels into a single application or database, assign the most restrictive classification of the combined asset. For example, if an application contains Internal Use and Confidential information, the entire application is Confidential.
- Restricted, Confidential and Internal Use information must never be released to the general public but may be shared with third parties, such as government agencies, business partners, or consultants, when there is a business need to do so and the appropriate security controls are in place according to the level of classification.
- You may not change the format or media of information if the new format or media you will be using does not have the same level of security controls in place. For example, you may not export Restricted information from a secured database to an unprotected Microsoft Excel spreadsheet.

A-3: Personally, Identifiable Information (PII)

Personally, Identifiable Information (PII) is defined as the first name or first initial and last name, in combination with any one or more of the following data elements:

- Government-Issued Identification Number (e.g., passport, permanent resident card, etc.)
 - Social Security Number (SSN) / Taxpayer Identification Number (TIN) / National Identification Number (NIN)
 - Passport number
 - Permanent resident card
- Driver License (DL)
- Financial account number
 - Payment card number (credit or debit)
 - Bank account number
- Electronic Protected Health Information (ePHI)

A-4: Data Handling Guidelines

HANDLING CONTROLS	RESTRICTED	CONFIDENTIAL	INTERNAL USE	PUBLIC
Non-Disclosure Agreement (NDA)	▪ NDA is required prior to access by non-KR employees.	▪ NDA is recommended prior to access by non-KR employees.	<i>No NDA requirements</i>	<i>No NDA requirements</i>
Internal Network Transmission (wired & wireless)	▪ Encryption is required ▪ Instant Messaging is prohibited ▪ FTP is prohibited	▪ Encryption is recommended ▪ Instant Messaging is prohibited ▪ FTP is prohibited	<i>No special requirements</i>	<i>No special requirements</i>
External Network Transmission (wired & wireless)	▪ Encryption is required ▪ Instant Messaging is prohibited ▪ FTP is prohibited ▪ Remote access should be used only when necessary and only with VPN and two-factor authentication	▪ Encryption is required ▪ Instant Messaging is prohibited ▪ FTP is prohibited	▪ Encryption is recommended ▪ Instant Messaging is prohibited ▪ FTP is prohibited	<i>No special requirements</i>
Data At Rest (file servers, databases, archives, etc.)	▪ Encryption is required ▪ Logical access controls are required to limit unauthorized use ▪ Physical access restricted to specific individuals	▪ Encryption is recommended ▪ Logical access controls are required to limit unauthorized use ▪ Physical access restricted to specific groups	▪ Encryption is recommended ▪ Logical access controls are required to limit unauthorized use ▪ Physical access restricted to specific groups	▪ Logical access controls are required to limit unauthorized use ▪ Physical access restricted to specific groups

HANDLING CONTROLS	RESTRICTED	CONFIDENTIAL	INTERNAL USE	PUBLIC
Mobile Devices (iPhone, iPad, MP3 player, USB drive, etc.)	▪ Encryption is required ▪ Remote wipe must be enabled, if possible	▪ Encryption is required ▪ Remote wipe must be enabled, if possible	▪ Encryption is recommended ▪ Remote wipe should be enabled, if possible	<i>No special requirements</i>
Email (with and without attachments)	▪ Encryption is required ▪ Do not forward	▪ Encryption is required ▪ Do not forward	▪ Encryption is recommended	<i>No special requirements</i>
Physical Mail	▪ Mark "Open by Addressee Only" ▪ Use "Certified Mail" and sealed, tamper- resistant envelopes for external mailings ▪ Delivery confirmation is required ▪ Hand deliver internally	▪ Mark "Open by Addressee Only" ▪ Use "Certified Mail" and sealed, tamper- resistant envelopes for external mailings ▪ Delivery confirmation is required ▪ Hand delivering is recommended over interoffice mail	▪ Mail with company interoffice mail ▪ US Mail or other public delivery systems and sealed, tamper- resistant envelopes for external mailings	<i>No special requirements</i>
Printer	▪ Verify destination printer ▪ Attend printer while printing	▪ Verify destination printer ▪ Attend printer while printing	▪ Verify destination printer ▪ Retrieve printed material without delay	<i>No special requirements</i>
Web Sites	▪ Posting to intranet sites is prohibited, unless it is pre-approved to contain Restricted data. ▪ Posting to Internet sites is prohibited, unless it is pre-approved to contain Restricted data.	▪ Posting to publicly accessible Internet sites is prohibited.	▪ Posting to publicly accessible Internet sites is prohibited	<i>No special requirements</i>
Telephone	▪ Confirm participants on the call line ▪ Ensure private location	▪ Confirm participants on the call line ▪ Ensure private location	<i>No special requirements</i>	<i>No special requirements</i>
Video / Web Conference Call	▪ Pre-approve roster of attendees ▪ Confirm participants on the call line ▪ Ensure private location	▪ Pre-approve roster of attendees ▪ Confirm participants on the call line ▪ Ensure private location	▪ Pre-approve roster of attendees ▪ Confirm participants on the call line	<i>No special requirements</i>
Fax	▪ Attend receiving fax machine ▪ Verify destination number ▪ Confirm receipt ▪ Do not fax outside company without manager approval	▪ Attend receiving fax machine ▪ Verify destination number ▪ Confirm receipt ▪ Do not fax outside company without manager approval	<i>No special requirements</i>	<i>No special requirements</i>
Paper, Film/Video, Microfiche	▪ Return to owner for destruction ▪ Owner personally verifies destruction	▪ Shred or delete all documents or place in secure receptacle for future shredding	▪ Shred or delete all documents or place in secure receptacle for future shredding	<i>No special requirements</i>

HANDLING CONTROLS	RESTRICTED	CONFIDENTIAL	INTERNAL USE	PUBLIC
Storage Media (Hard Disk Drives (HDDs), Flash drives, tapes, CDs/DVDs, etc.)	▪ Physically destroy the hard drives and media ▪ Requires use of company-approved vendor for destruction	▪ Physically destroy the hard drives and media or use commercial overwrite software to destroy the data on the media (quick reformat of the media is not sufficient)	▪ Physically destroy the hard drives and media or use commercial overwrite software to destroy the data on the media	▪ Physically destroy the hard drives and media or use commercial overwrite software to destroy the data on the media

Appendix B: Data Classification Examples

The table below shows examples of common data instances that are already classified to simplify the process. This list is not inclusive of all types of data, but it establishes a baseline for what constitutes data sensitivity levels and will adjust to accommodate new types or changes to data sensitivity levels, when necessary.

IMPORTANT: You are instructed to classify data more sensitive than this guide, if you feel that is warranted by the content.

DATA CLASS	SENSITIVE DATA ELEMENTS	PUBLIC	INTERNAL USE	CONFIDENTIAL	RESTRICTED
Client or Employee Personal Data	Social Security Number (SSN)				X
	Employer Identification Number (EIN)				X
	Driver's License (DL) Number				X
	Financial Account Number				X
	Payment Card Number (credit or debit)				X
	Government-Issued Identification (e.g., passport, permanent resident card, etc.)				X
	Birth Date			X	
	First & Last Name		X		
	Age		X		
	Phone and/or Fax Number		X		
	Home Address		X		
	Gender		X		
	Ethnicity		X		
	Email Address		X		
Employee-Related Data	Compensation & Benefits Data				X
	Medical Data				X
	Workers Compensation Claim Data				X
	Education Data			X	
	Dependent or Beneficiary Data			X	
Sales & Marketing Data	Business Plan (including marketing strategy)			X	
	Financial Data Related to Revenue Generation			X	
	Marketing Promotions Development		X		
	Internet-Facing Websites (e.g., company website, social networks, blogs, promotions, etc.)	X			
	News Releases	X			
Networking & Infrastructure Data	Username & Password Pairs				X
	Public Key Infrastructure (PKI) Cryptographic Keys (public & private)				X
	Hardware or Software Tokens (multifactor authentication)				X
	System Configuration Settings			X	
	Regulatory Compliance Data			X	
	Internal IP Addresses			X	
	Privileged Account Usernames			X	
	Service Provider Account Numbers			X	
Strategic Financial Data	Corporate Tax Return Information			X	
	Legal Billings			X	
	Budget-Related Data			X	
	Unannounced Merger and Acquisition Information			X	
	Trade Secrets (e.g., design diagrams, competitive information, etc.)			X	
Operating Financial Data	Electronic Payment Information (Wire Payment / ACH)			X	
	Paychecks			X	
	Incentives or Bonuses (amounts or percentages)			X	
	Stock Dividend Information			X	
	Bank Account Information			X	
	Investment-Related Activity			X	
	Account Information (e.g., stocks, bonds, mutual funds, money markets, etc.)			X	
	Debt Amount Information			X	

DATA CLASS	SENSITIVE DATA ELEMENTS	PUBLIC	INTERNAL USE	CONFIDENTIAL	RESTRICTED
	SEC Disclosure Information			X	

Appendix C: Baseline Security Categorization Guidelines

Assets and services are categorized by two primary attributes: (a) the potential impact they pose from misuse and (b) the data classification level of the data processed, stored or transmitted by the asset or process. These two attributes combine to establish a basis for controls that should be assigned to that system or asset. *This basis is called an Assurance Level (AL).*

C-1: DATA SENSITIVITY

This is straightforward where the data sensitivity rating represents the highest data classification of the data processed, stored or transmitted by the asset or process

C-2: SAFETY & CRITICALITY

The Safety & Criticality (SC) rating reflects two aspects of the “importance” of the asset or process:

- On one hand, SC simply represents the importance of the asset relative to the achievement of the firm’s goals and objectives (e.g., business critical, mission critical, or non-critical).
- On the other hand, SC represents the potential for harm that misuse of the asset or service could cause to KR, its clients, its partners, or the general public.

Where the data sensitivity and SC levels meet is considered the Assurance Levels (AL). The AL represents the “level of effort” that is needed to properly ensure the Confidentiality, Integrity, Availability and Safety (CIAS) of the asset or process.

Asset Categorization Matrix		Data Sensitivity			
		RESTRICTED	CONFIDENTIAL	INTERNAL USE	PUBLIC
Safety & Criticality	HIGH	Enhanced	Enhanced	Enhanced	Enhanced
	MODERATE	Enhanced	Enhanced	Basic	Basic
	LOW	Enhanced	Basic	Basic	Basic

Figure C-1: Asset Categorization Risk Matrix

C-3: BASIC ASSURANCE REQUIREMENTS

- The minimum level of controls is defined as industry-recognized leading practices (e.g., PCI DSS, NIST 800-53, ISO 27002, etc.).
- For security controls in Basic assurance projects or initiatives, the focus is on the digital security controls being in place with the expectation that no obvious errors exist and that as flaws are discovered they are addressed in a timely manner.

C-4: ENHANCED ASSURANCE REQUIREMENTS

- The minimum level of controls is defined as exceeding industry-recognized leading practices (e.g., DLP, FIM, DAM, etc.).
- For security controls in Enhanced Assurance projects, it is essentially the Standard Assurance level that is expanded to require more robust IT security capabilities that are commensurate with the value of the project to KR.

Appendix D: Information Security Roles & Responsibilities

D-1: Information Security Roles

Every user at KR, regardless of position or job classification, has an important role, when it comes to safeguarding the Confidentiality, Integrity, and Availability (CIA) of the information systems and data maintained by KR. It is important that every individual fully understands their role, their associated responsibilities, and abide by the security standards, policies, and procedures set forth by the Information Security Program (ISP).

Role	Description of Security Role	
Chief Information Security Officer (ISO)	The ISO is accountable to the firm's senior management for the development and implementation of the information security program. The ISO will be the central point of contact for setting the day-to-day direction of the information security program and its overall goals, objectives, responsibilities, and priorities	Vlad Rudnitsky
Asset Owners	Business or department manager with budgetary authority over the system(s) with responsibility for the basic operation and maintenance of the system(s).	Alan Chosed (Audit) Mike Custer (Tax) Merideth Tucker (Entrepreneurial & Family Offices) Kara Sharp, Adam Rabinowicz (FAVS) Scott Goldberg (E&T) Jackie Straziuso (Administration) Jordan Kendall (Marketing) Joy Batteen (KRU & HR) Jorge Lopez (Internal Accounting) Ivan Garces (RAS) Scott Soucy (Outsourcing/BCS) Jerry Rodriguez (IT) Albert Primo (Technology Development) Richard Salinas (Operations) Jay Pelham (Wealth) Robert Alonso (KRAIS)
Asset Custodians	Under the direction of the ISO, asset custodians (e.g., system & network administrators) are responsible for the technical implementation and management of the Information Security Program (ISP). Party responsible for certain aspects of system security, such as adding and deleting user accounts, as authorized by the asset owner, as well as normal operations of the system in keeping with job requirements.	
End Users	All employees (and contractors) are considered both custodians and users of the information systems and data on their issued information systems and are required to uphold all applicable Information Security Program (ISP) policies, procedures, standards, and guidelines.	

Below is KR's data security steering group.

- Blain Heckaman – CEO (part of the Management Committee)
- Marc Fiegelson - CFO
- Ivan Garces (RAS practice leader & part of the Management Committee)
- Richard Salinas COO (part of Management Committee)
- Robert Alonso – KRAIS practice leader
- Albert Primo - CTO
- Jerry Rodriguez – CIO, Mike Sidnam – IT Dir.
- Vlad Rudnitsky - CISO

D-2: Information Security Responsibilities

Responsibilities shall be assigned based on “ownership” or stake-holding by the CISO.

Role	Description of Security Responsibility
Management Committee	The Firm is managed by the Management Committee, which is led by Managing Partner, Blain L. Heckaman. Managing Committee ultimately oversees the Data Security Steering Committee.
Data Security Steering Group	▪ Oversee and approve the firm’s information security program; ▪ Appoint, an Information Security Officer to implement the information security program; ▪ Ensure an appropriate level of protection for all company owned or maintained information resources; whether retained in-house or under the control of contractors; ▪ Ensure that funding and resources are programmed for staffing, training, and support of the information security program and for implementation of system safeguards, as required; ▪ Ensure that persons working in an information security role are properly trained, and supported with the appropriate resources; and ▪ Provide a secure processing environment including redundancy, backup, and fault-tolerance services.
Chief Information Security Officer (CISO)	▪ Oversee and approve the firm’s information security program including the employees, contractors, and vendors who safeguard the firm’s information systems and data, as well as the physical security precautions for employees and visitors; ▪ Ensure an appropriate level of protection for the firm’s information resources; whether retained in-house or under the control of outsourced contractors; ▪ Issue the Information Security Program (ISP) policies and guidance that establish a framework for an Information Security Management System (ISMS); ▪ Identify protection goals, objectives, and metrics consistent with corporate strategic plan; ▪ Ensure appropriate procedures are in place for Security Testing & Evaluation (ST&E) for all information systems; and monitor, evaluate, and report to company management on the status of IT security within the firm; ▪ Ensure that persons working in an information security role are properly trained, and supported with the appropriate resources; ▪ Assist in compliance reviews and other reporting requirements; ▪ Provide feedback to company management on the status of the information security program, and suggest improvements or areas of concern in the program or any other security-related activity; ▪ Promote best practices in information security management; ▪ Monitor and evaluate the status of the firm’s information security posture by performing annual compliance reviews of the Information Security Program (ISP) and system controls (including reviews of security plans, risk assessments, security testing processes, and others); ▪ Provide security-related guidance and technical assistance to all operating units; ▪ Develop the Computer Incident Response Program (CIRP) and act as the firm’s central point of contact for incident handling, in concert with the firm’s Computer Incident Response Team (CIRT). ▪ Maintain liaison with external organizations on security-related issues; ▪ Identify resource requirements, including funds, personnel, and contractors, needed to manage the information security program; and ▪ Assign ownership of resources.
Data Owner	▪ Include security considerations in applications systems procurement or development, implementation, operation and maintenance, and disposal activities (e.g., life cycle management); ▪ Ensure the security of data and application software residing on system(s); ▪ Develop and maintain security plans and contingency plans for all general support systems and major applications under their responsibility, which document the business associations and dependencies of

Role	Description of Security Responsibility
	their system (e.g., examine linked IT resources and flow of information); ▪ Perform risk assessments to periodically re-evaluate sensitivity of the system, risks, and mitigation strategies; ▪ Conduct self-assessments of system safeguards and program elements and ensure certification and accreditation of the system; ▪ Report all incidents to the Computer Incident Response Team (CIRT) in a timely manner; ▪ Ensure system users have proper IT security training (relevant to the system); ▪ Ensure IT contracts pertaining to the system include provisions for necessary security; ▪ Ensure that access to sensitive data is limited to those with a “need to know” or “need to use”; and ▪ Ensure systems’ personnel are properly designated, monitored, and trained; ▪ Implement the system-level controls and maintain system documentation; ▪ Advise the system owner regarding security considerations in applications systems procurement or development, implementation, operation and maintenance, and disposal activities (e.g., life cycle management); ▪ Assist in the determination of an appropriate level of system and physical security commensurate with the level of sensitivity; ▪ Assist in the development and maintenance of security plans and contingency plans (e.g., Business Recovery Plans) for all general support systems and major applications under their responsibility; ▪ Participate in risk assessments to periodically re-evaluate sensitivity of the system, risks, and mitigation strategies; ▪ Participate in self-assessments of system safeguards and program elements and in certification and accreditation of the system; ▪ Attend security awareness training and programs; ▪ Maintain a cooperative relationship with business partners or other interconnected systems; ▪ Maintain an inventory of hardware and software; and ▪ Handle and investigate incidents in cooperation with and under direction of the CISO
Asset Custodians (System & Network Administrators)	▪ Assist in the development and maintenance of security plans and contingency plans for all general support systems and major applications under their responsibility; ▪ Participate in risk assessments to periodically re-evaluate sensitivity of the system, risks, and mitigation strategies; ▪ Participate in self-assessments of system safeguards and program elements and in certification and accreditation of the system; ▪ Evaluate proposed technical security controls to assure proper integration with other system operations; ▪ Identify requirements for resources needed to effectively implement technical security controls; ▪ Ensure integrity in implementing and operating technical security controls; ▪ Report all incidents to the Computer Incident Response Team (CIRT) in a timely manner; ▪ Read and understand all applicable training and awareness materials; ▪ Read and understand all applicable use policies or other rules of behavior regarding use or abuse of company IT resources; ▪ Develop system administration and operational procedures and manuals; ▪ Evaluate and develop procedures that assure proper integration of service continuity with other system operations; ▪ Inventory those systems or parts of systems for which they are directly responsible (e.g., network equipment, servers, LAN, application administration, etc.); ▪ Know the sensitivity of the data they handle and take appropriate measures to protect it; and ▪ Know and abide by all applicable company policies and procedures.
End Users	NOTE: end user’s responsibilities center upon being aware of the sensitivity and proper handling method of sensitive information. ▪ Know and abide by all applicable policies and procedures; ▪ Complete all required user training and awareness programs;

Role	Description of Security Responsibility
	▪ Understand and abide by the Rules of Behavior (see Appendix H); ▪ Know which systems or parts of systems for which they are directly responsible (printer, desktop, browser, etc.); ▪ Know the sensitivity of the data handled by systems under your control and take appropriate measures to protect it; ▪ Report all incidents to the Computer Incident Response Team (CIRT) in a timely manner; ▪ Follow labeling, handling, sharing, storage and destruction requirements based on appropriate classification / sensitivity level; ▪ When in doubt about the classification of specific information, ask your supervisor; ▪ Comply with all regulatory, business or legal data retention policies before disposing of information.

Appendix E: Information Security Exception Request Procedures

The following procedure defines the process for the review and approval of exceptions to the Information Security Program (ISP)'s policies, standards, guidelines, and procedures:

- 1) A manager (or an appointed designee) seeking an exception must assess the risks that non-compliance creates for the firm. If the manager believes the risk is reasonable, then the manager prepares a written request describing the risk analysis and request for an exception (Note: The only reason to justify an exception is when compliance with a policy adversely affects business objectives or when the cost to comply offsets the risk of non-compliance). The risk analysis shall include:
 - a) Identification of the threats and vulnerabilities, how likely each is to occur and the potential costs of an occurrence.
 - b) The cost to comply.
- 2) Submit the request for an exception to the KR's CISO. The CISO will gather any necessary background information and make a recommendation to approve or deny the request. The CISO may recommend that other areas such as managers, asset custodians, and legal representatives review certain decisions.
- 3) The ISO will approve or deny the request for an exception.
- 4) The requestor will be notified of the decision to approve or deny.
- 5) All requests for exception will be retained by the CISO.
- 6) Exceptions are valid for a one-year period. Annually, the CISO will send a copy of approved exceptions back to the requestor, who must determine whether the conditions that justified the original exceptions are still in effect. If the conditions have substantially changed, a new request for exception must be submitted. Where little has changed, the review process may be shortened as recommended by the CISO.

Appendix F: Types of Security Controls

F-1: Preventative Controls

Preventive security controls are put in place to prevent intentional or unintentional disclosure, alteration, or destruction of sensitive information. Examples include, but are not limited to:

- Policy - Unauthorized network connections are prohibited.
- Firewall - Blocks unauthorized network connections.
- Locked wiring closet - Prevents unauthorized equipment from being physically plugged into a network switch.

F-2: Detective Controls

Detective security controls are like a burglar alarm. They detect and report an unauthorized or undesired event (or an attempted undesired event). Detective security controls are invoked after the undesirable event has occurred. Examples include, but are not limited to:

- Log monitoring and review – monitoring for anomalous traffic can detect unauthorized activity.
- System audit – monitoring for unauthorized changes can detect a breakdown in the change control process.
- File integrity checkers – monitoring for file changes can detect integrity compromises.
- Motion detection systems – monitoring for physical activity can detect a break in of a facility.

F-3: Corrective Controls

Corrective security controls are used to respond to and fix a security incident. Corrective security controls also limit or reduce further damage from an attack. In many cases the corrective security control is triggered by a detective security control. Examples include, but are not limited to:

- Procedures to clean a virus from an infected system.
- A guard checking and locking a door left unlocked by a careless employee.
- Updating firewall rules to block an attacking IP address as the attack is occurring.

F-4: Recovery Controls

Recovery security controls are those controls that put a system back into production after an incident. Most Disaster Recovery activities fall into this category. Examples include, but are not limited to:

- After a disk failure, data is restored from a backup tape.
- A server automatically fails over to another server when a heartbeat (connectivity) is lost.

F-5: Directive Controls

Directive security controls are the equivalent of administrative controls. Directive controls dictate that some action is taken to protect sensitive organizational information. Examples include, but are not limited to:

- Policy, standards, procedures, or guidelines.
- HR handbook

F-6: Deterrent Controls

Deterrent security controls are controls that discourage security violations. Examples include, but are not limited to:

- An "Unauthorized Access Prohibited" sign may deter a trespasser from entering an area.
- The presence of security cameras might deter an employee from stealing equipment.
- A policy that states access to servers is monitored could deter unauthorized access.

F-7: Compensating Controls

Compensating security controls are controls that provide an alternative to normal controls that cannot be used for some reason. Examples include, but are not limited to:

- If a specific server cannot have antivirus software installed because it interferes with a critical application, a compensating control would be to increase monitoring of that server or isolate that server on its own network segment.
- If a system is not able to restrict who can log onto it, network segmentation would be a compensating control to protect the rest of the network from the lack of access control on the system.

Appendix G: Rules of Behavior / User Acceptable Use

These Rules of Behavior apply to the use of KR-provided IT resources, regardless of the geographic location:

- Data and information system use must comply with KR policies and standards.
- Unauthorized access to data and/or information systems is prohibited.
- Users must prevent unauthorized disclosure or modification of sensitive information, including Personally Identifiable Information (PII).

Please refer to the Employee Declaration – Computer, Internet and Communications policy

G-1: Additional Rules For Security & Privileged Users

Security and system administration personnel with elevated privileges have significant access to processes and data in information systems. As such, Security, Network, Systems, and Database Administrators have added responsibilities to ensure the secure operation of any KR system.

Personnel with elevated privileges are to:

- Advise the asset owner on matters concerning information security.
- Assist the asset owner in developing security plans, risk assessments, and supporting documentation for the certification and accreditation process.
- Ensure that any changes to any information system that affect contingency and disaster recovery plans are conveyed to the asset custodian responsible for maintaining continuity of operations plans for that information system.
- Ensure that adequate physical and technical safeguards are operational within their areas of responsibility and that access to information and data is restricted to authorized personnel on a need to know basis.
- Verify that users have received appropriate security training before allowing access to any information system.
- Implement applicable security access procedures and mechanisms, incorporate appropriate levels of system auditing, and review audit logs.
- Document and investigate known or suspected security incidents or violations and report them to the CISO.
- Future labor management agreements shall comply with this policy.

Appendix H: System Hardening

H-1: Server-Class Systems

Server-class systems are defined as:

- Microsoft Server 2000
- Microsoft Server 2003
- Microsoft Server 2008
- Microsoft Server 2012
- Microsoft Server 2016
- Microsoft Server 2020
- Redhat Enterprise Linux (RHEL)
- Unix
- Solaris

Server-class systems should follow hardening procedures from the following sources:

- Center for Information Security (CIS): <https://benchmarks.cisecurity.org/downloads/multiform/index.cfm>
- Defense Information Security Agency (DISA): <http://iase.disa.mil/stigs/a-z.html>
- Manufacturer security configuration recommendations

H-2: Workstation-Class Systems

Workstation-class systems are defined as:

- Microsoft Windows XP
- Microsoft Windows Vista
- Microsoft Windows 7
- Microsoft Windows 8
- Microsoft Windows 10
- Apple
- Fedora (Linux)
- Ubuntu (Linux)
- SuSe (Linux)

Workstation-class systems should follow hardening procedures from the following sources:

- Center for Information Security (CIS): <https://benchmarks.cisecurity.org/downloads/multiform/index.cfm>
- Defense Information Security Agency (DISA): <http://iase.disa.mil/stigs/a-z.html>
- Manufacturer security configuration recommendations

H-3: Network Devices

Network devices are defined as:

- Firewalls
- Routers
- Load balancers
- Virtual Private Network (VPN) concentrators
- Wireless Access Points (WAPs)
- Wireless controllers
- Printers
- Multi-Function Devices (MFDs)

Network devices should follow hardening procedures from the following sources:

- Center for Information Security (CIS): <https://benchmarks.cisecurity.org/downloads/multiform/index.cfm>
- Defense Information Security Agency (DISA): <http://iase.disa.mil/stigs/a-z.html>
- Manufacturer security configuration recommendations

H-4: Mobile Devices

Mobile devices are defined as:

- Tablets
- Mobile phones
- Other portable electronic devices

Network devices should follow hardening procedures from the following sources:

- Center for Information Security (CIS): <https://benchmarks.cisecurity.org/downloads/multiform/index.cfm>
- Defense Information Security Agency (DISA): <http://iase.disa.mil/stigs/a-z.html>
- Manufacturer security configuration recommendations

H-5: Databases

Databases are defined as:

- MySQL
- Windows SQL Server
- Windows SQL Express
- Oracle
- DB2

Network devices should follow hardening procedures from the following sources:

- Center for Information Security (CIS): <https://benchmarks.cisecurity.org/downloads/multiform/index.cfm>
- Defense Information Security Agency (DISA): <http://iase.disa.mil/stigs/a-z.html>
- Manufacturer security configuration recommendations

GLOSSARY: ACRONYMS & DEFINITIONS

Acronyms

BCP. Business Continuity Plan
PDCA. Plan-Do-Check-Act
CDE. Data Environment
CERT. Computer Emergency Response Team
CIRT. Computer Incident Response Team
DRP. Disaster Recovery Plan
E PHI. Electronic Protected Health Information
IRP. Incident Response Plan
ISMS. Information Security Management System
FACTA. Fair and Accurate Credit Transaction Act
HIPAA. Health Insurance Portability and Accountability Act
NIST. National Institute of Standards and Technology
PCI DSS. Payment Card Industry Data Security Standard
SOX. Sarbanes-Oxley Act

Definitions

The National Institute of Standards and Technology (NIST) IR 7298, Revision 1, *Glossary of Key Information Security Terms*, is the approved reference document used to define common IT security terms.³¹⁰

³¹⁰ NIST IR 7298 - <http://csrc.nist.gov/publications/nistir/ir7298-rev1/nistir-7298-revision1.pdf>

KEY WORD INDEX

Acceptable Use

Rules of Behavior, 23, 33

Compliance, 130

Identifiers

Privileged Accounts, 45

Service Accounts, 45

User Names, 44

Information Security Management System, 9, 159

Plan-Check-Do-Act, 9, 159

Least Functionality, 40

Least Privileges, 40

Mobile Devices, 16

Password

Complexity, 50

Length, 50

Maximum Life, 50

Privacy Policy

Data Collection, 133

Remote Access, 19

Roles & Responsibilities

Information Security Officer, 10

Responsibilities, 146

Roles, 146

System Use Notification

Logon Banner, 49

User Names. *See* Identifiers

Virtual Private Network (VPN). *See* Remote Access

RECORD OF CHANGES

Issue	Date	Pages Affected	Description
Original	2/6/2017	All	Original version for first publish and review.
1.0	7/26/217	All	Approved.
1.0	7/30/2018	None	No changes have been made.
1.1	7/24/2019	Some	Appendix D-2 (better document the reporting line of the Data Security Committee and the Management Committee). Updated software patching to include standards (c), (d) and (e).
1.2	7/20/2019	All	Replaced the word “organization” with “firm”, removed Reggie as the head of KRU and updated the malware policy to identify that Ubuntu / Linux machines are not required to have anti-virus installed. Jorge Rey reviewed and approved the changes.
1.3	3/22/2019	5	Included the KR group entities that are covered under this policy.
1.4	7/16/2021	115	Removed some sections that are not applicable to our environment. Added new members of the data security steering committee. Reviewed and approved by Jorge Rey.
1.5	7/26/2021	108 & 109	Added Anti-fraud & Anti-bribery policy.
1.6	7/14/2022	117	Updated data owners and removed Gerry Michelson from the data security steering committee. Reviewed and approved by Jorge Rey.
1.7	7/10/2023	All	Replaced Jorge Rey’s name with Vlad Rudnitsky for ISO responsibilities.
1.8	7/10/2024	All	Reviewed, no updates.
1.8	7/2/2025	All	Reviewed by Vlad Rudnitsky (CISO) & Edin Mejia (Sec. Eng.), no updates.